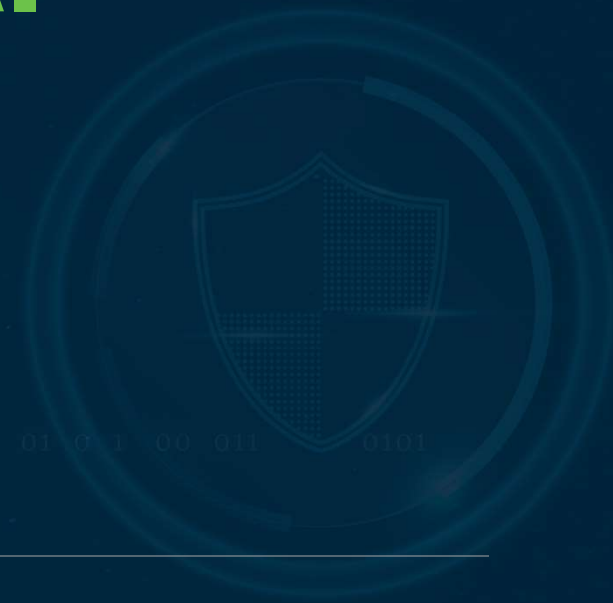


Threat Intelligence & AI Attack Chains

Chapter 05 · Episode 1 — Dr. Michael Solomon



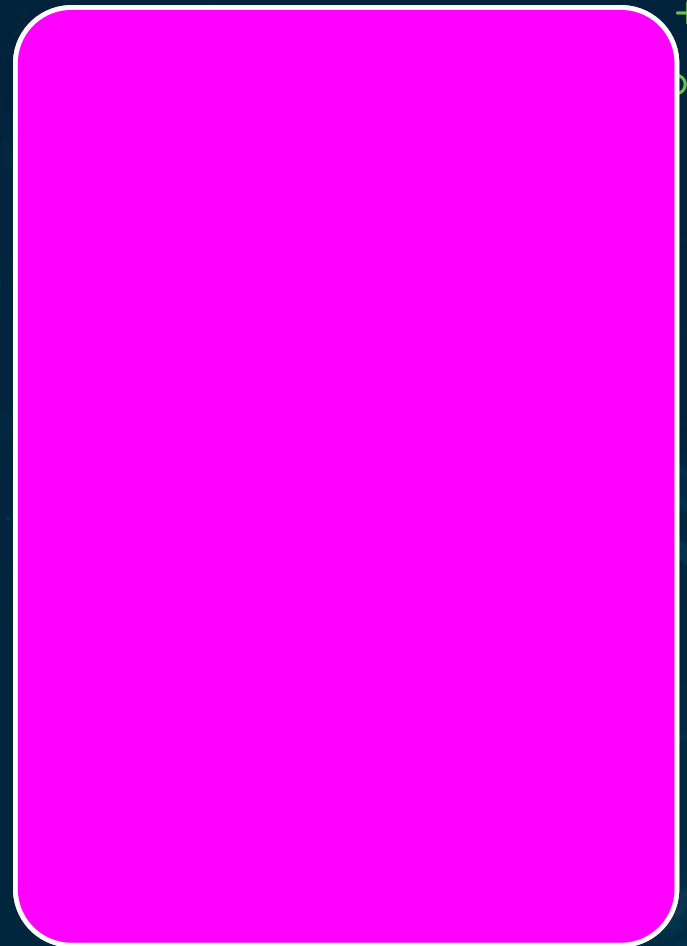
AI-Specific TI Sources

MITRE ATLAS, AI Incident Database, CVE feeds

Foundation-model provider advisories

Supplement STIX/TAXII — they don't overlap enough

Document feed selection + cadence in the plan

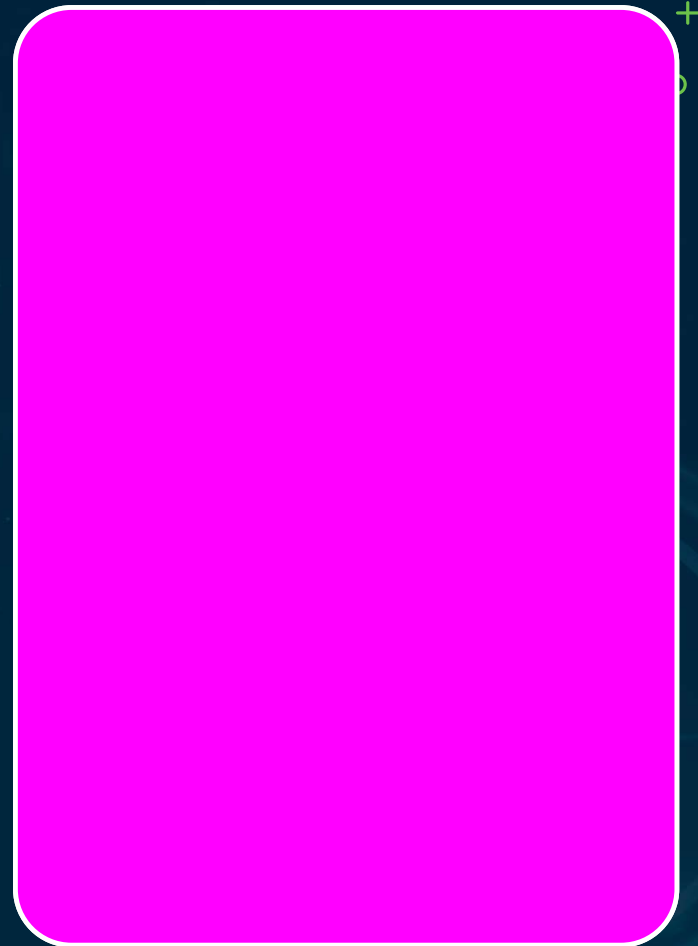


MITRE ATLAS = AI Adversary Framework

Adversarial TTP framework — the AI analog to ATT&CK

Tactics: ML attack staging, execution, exfiltration, impact

Drives the threat-to-control mapping table

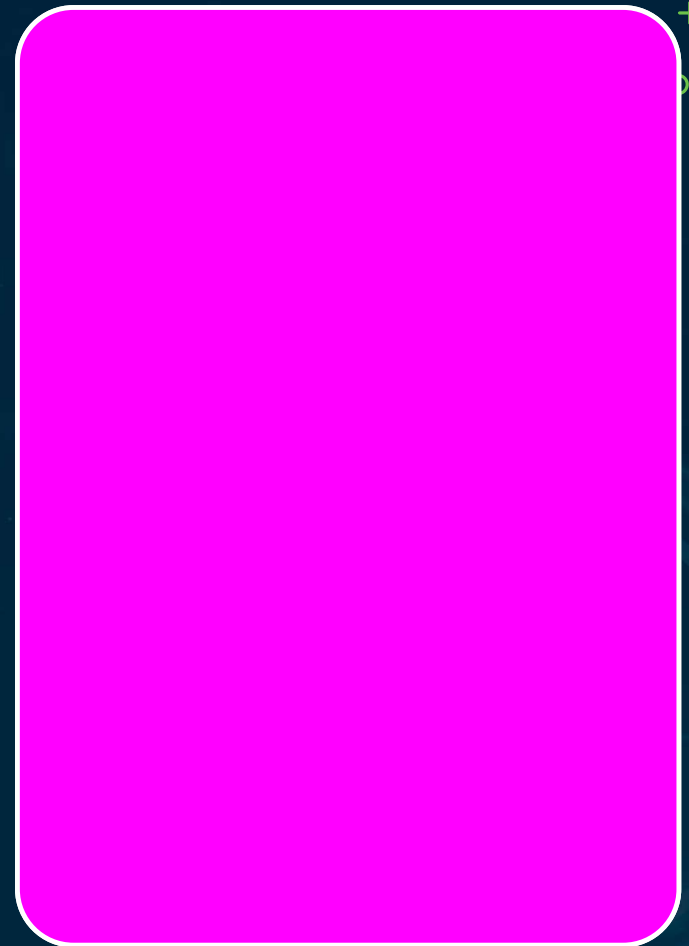


Strategic Threat Intelligence

Emerging regulation, new model capabilities, threat activity

Updates the threat model → triggers risk-register reviews

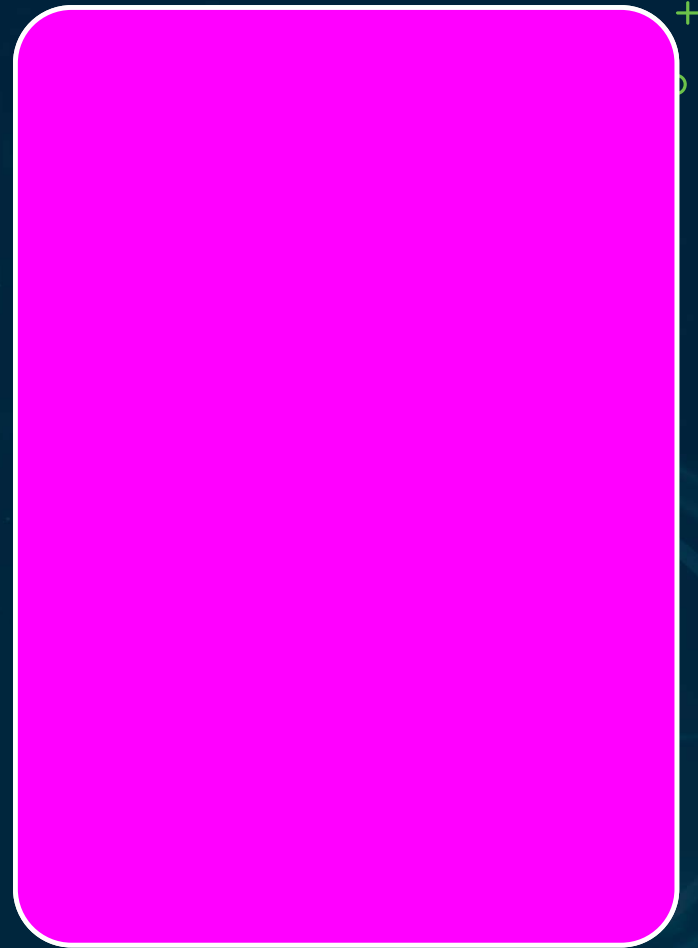
AI security lead reviews quarterly; reports to steering committee



AI Breaks Traditional Threat Modeling

STRIDE, attack trees, DFDs assume deterministic behavior

AI is non-deterministic — same input, different output

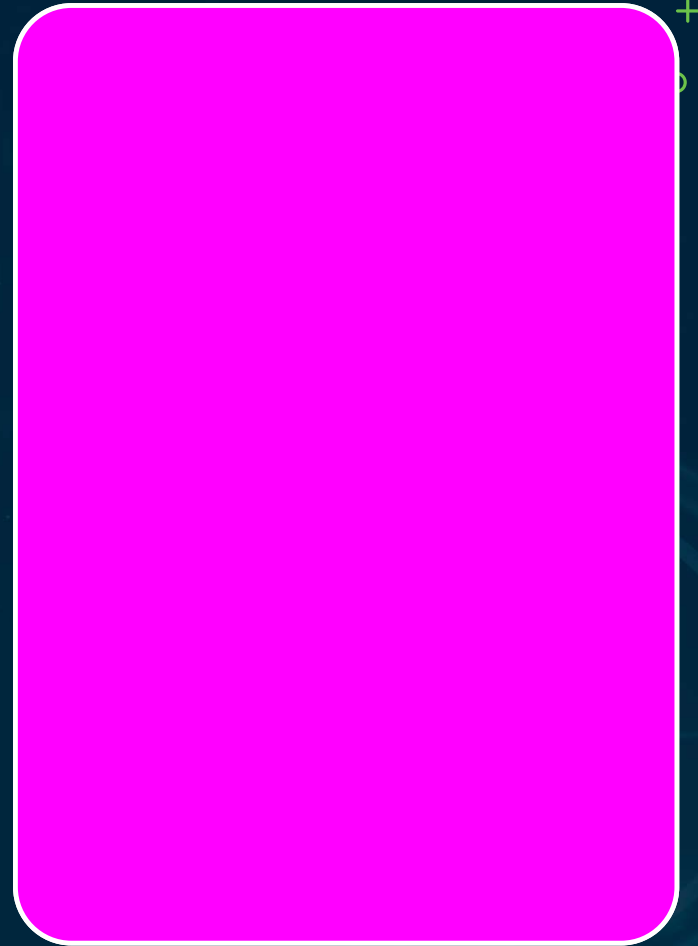


Why AI Threat Modeling Differs

Attack surface includes data, not just code

Training-time attacks surface later at inference

The model itself is an IP asset



Four AI Attack Surfaces

1 Data

Poisoning, label manipulation, supply chain

2 Model

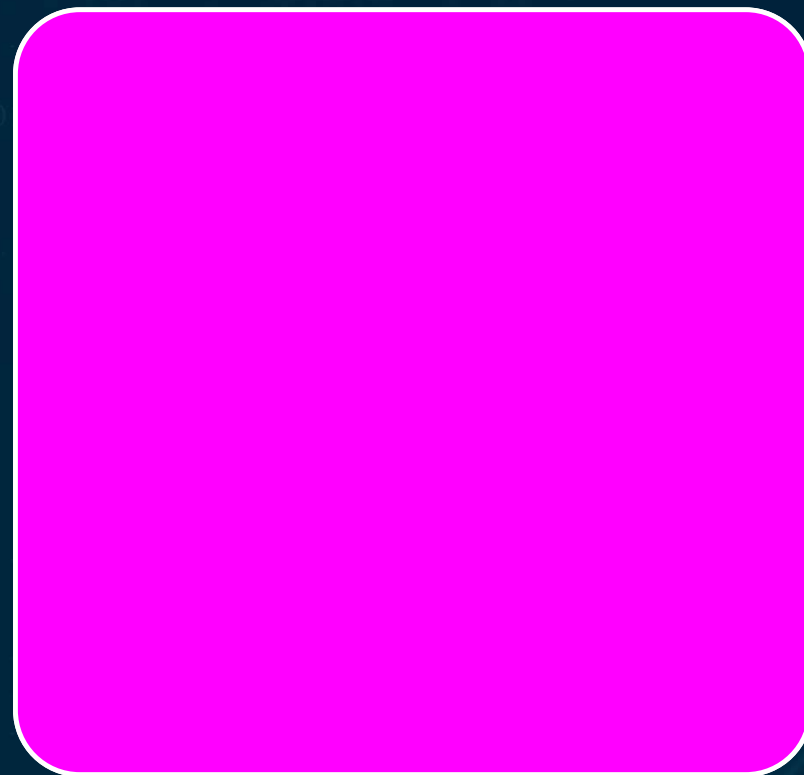
Inversion, membership inference, extraction

3 Inference

Prompt injection, jailbreaking, context

4 Integration

Excessive agency, indirect injection



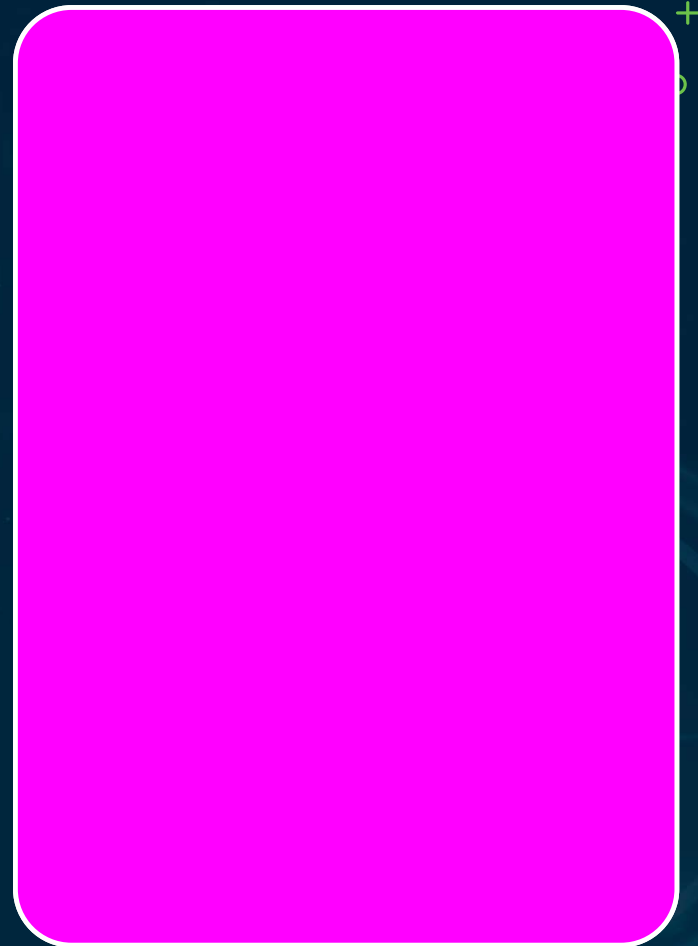
Operational vs Strategic TI

Operational TI — IOCs, extraction & injection signatures

Updates SIEM rules within a defined SLA

Stale detection rules = a control-effectiveness failure

Operational TI → SIEM rules; Strategic TI → risk register

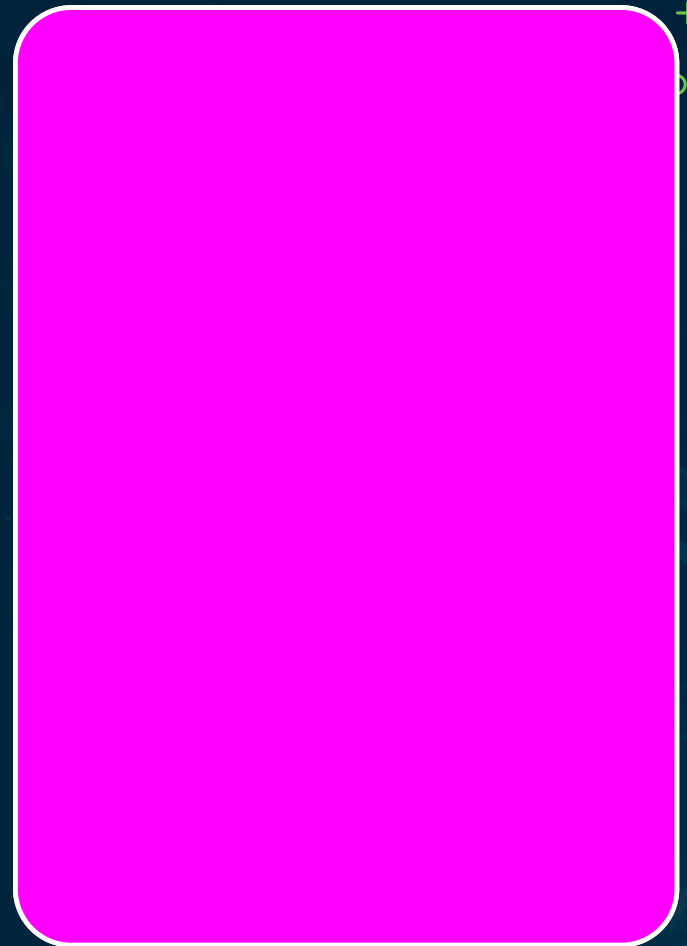


OWASP LLM Top 10

The most exam-tested AI framework

Web vulns live in code; LLM vulns live in interaction

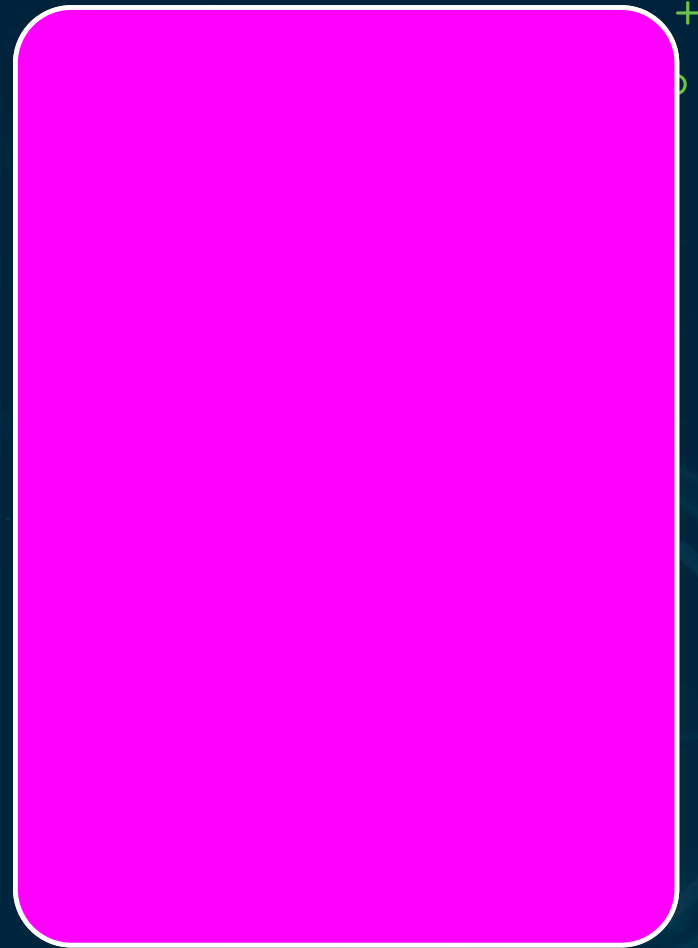
A standardized vocabulary for LLM risk



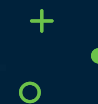
Recognize + Map Each Category

Prompt injection is probabilistic, not deterministic

Exam: name the category, or pick the mitigation



OWASP LLM01-04



LLM01 Injection

Direct + indirect; template & input validation



LLM03 Poisoning

Data provenance + integrity checks



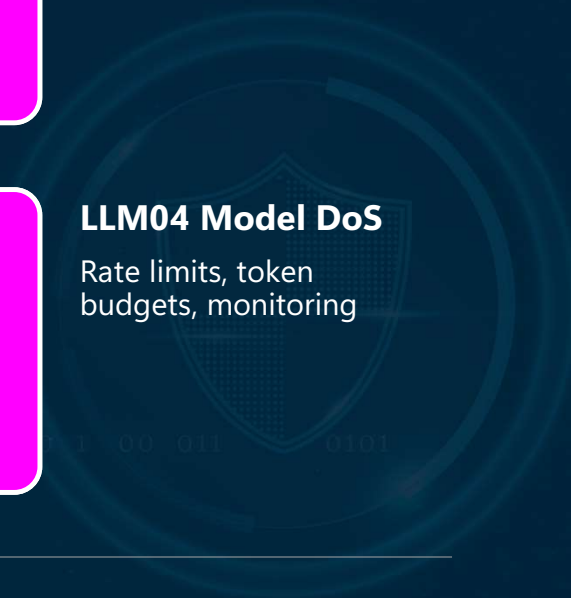
LLM02 Output

Sanitize + schema-validate downstream



LLM04 Model DoS

Rate limits, token budgets, monitoring



OWASP LLM05–08



LLM05 Supply Chain

Verify external components;
AI SBOM



LLM07 Plugins

Permission boundaries +
input validation



LLM06 Disclosure

Data minimization +
output filtering



LLM08 Excess Agency

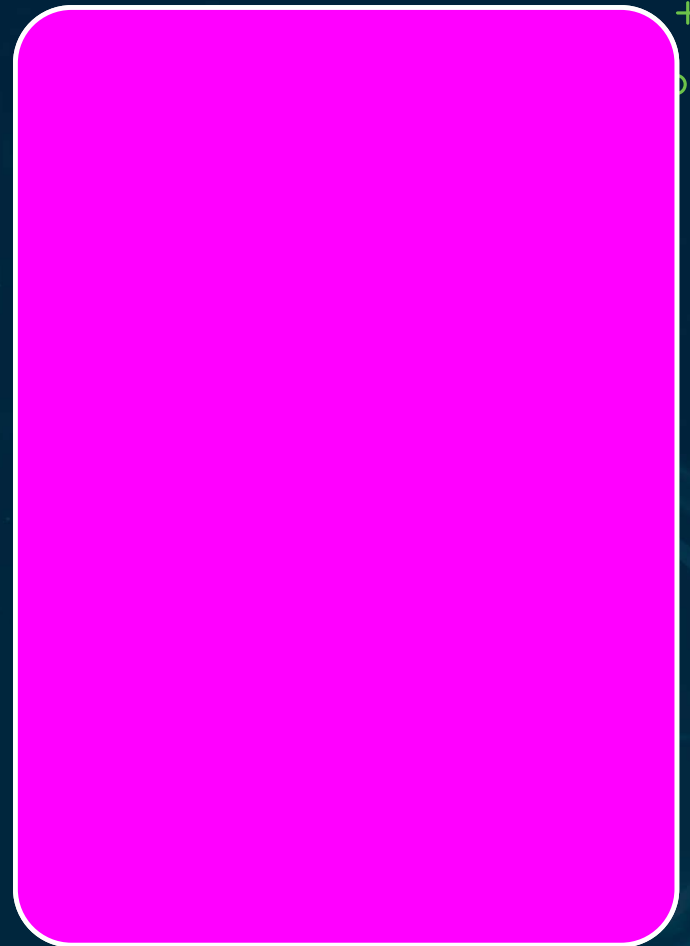
Least privilege +
human approval



OWASP LLM09–10

LLM09 Overreliance — confidence scores, human review, disclaimers

LLM10 Model Theft — rate limits, auth, query-anomaly detection

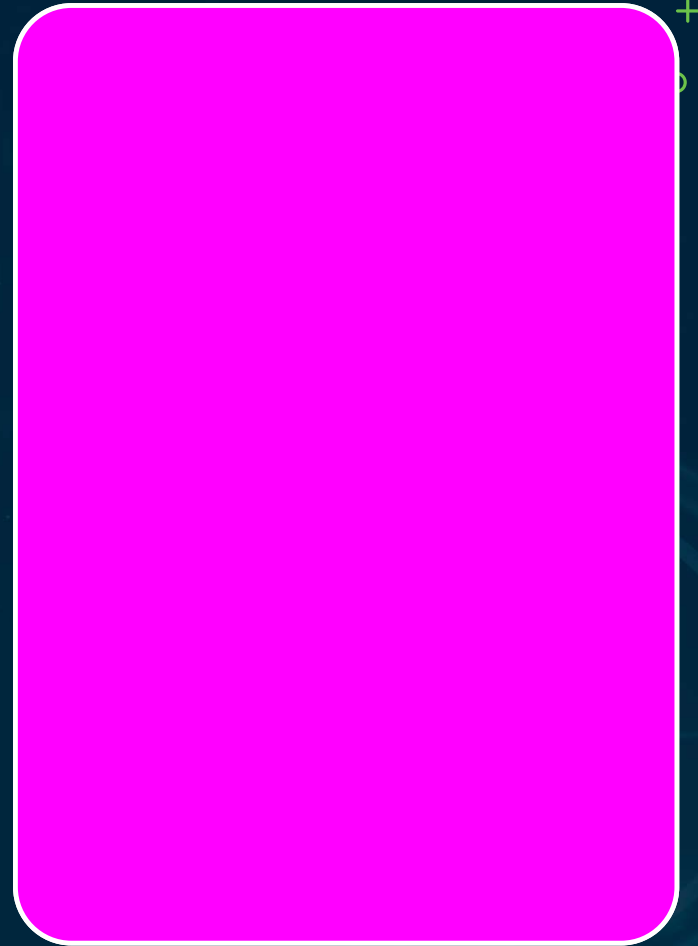


Map Categories to Surfaces

LLM01–02 → inference interface

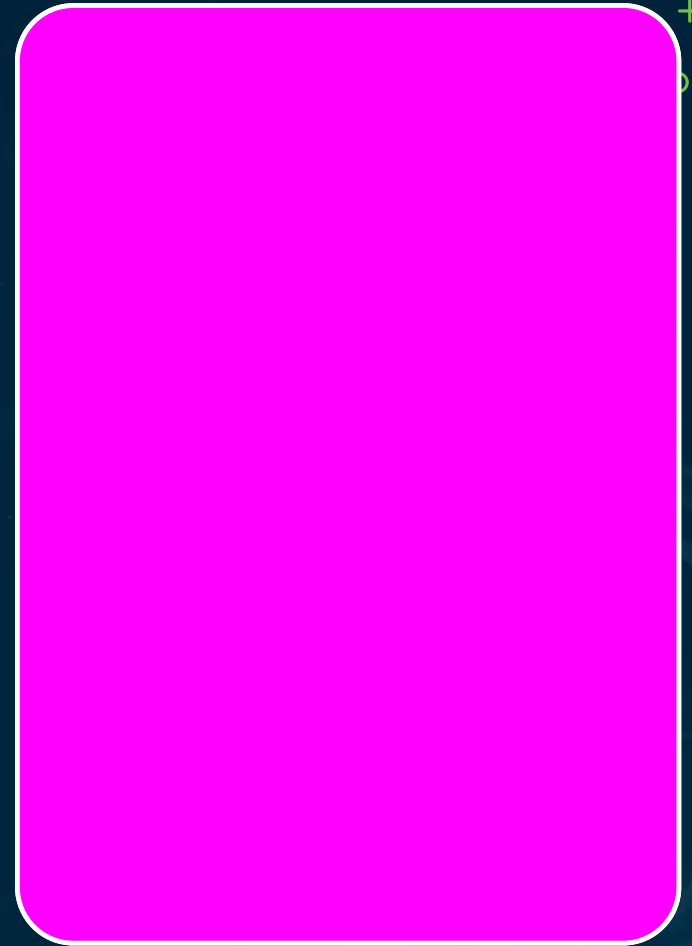
LLM03 → data layer; LLM04–05 → infra & supply chain

LLM06 & 08 → integration; LLM09–10 → governance



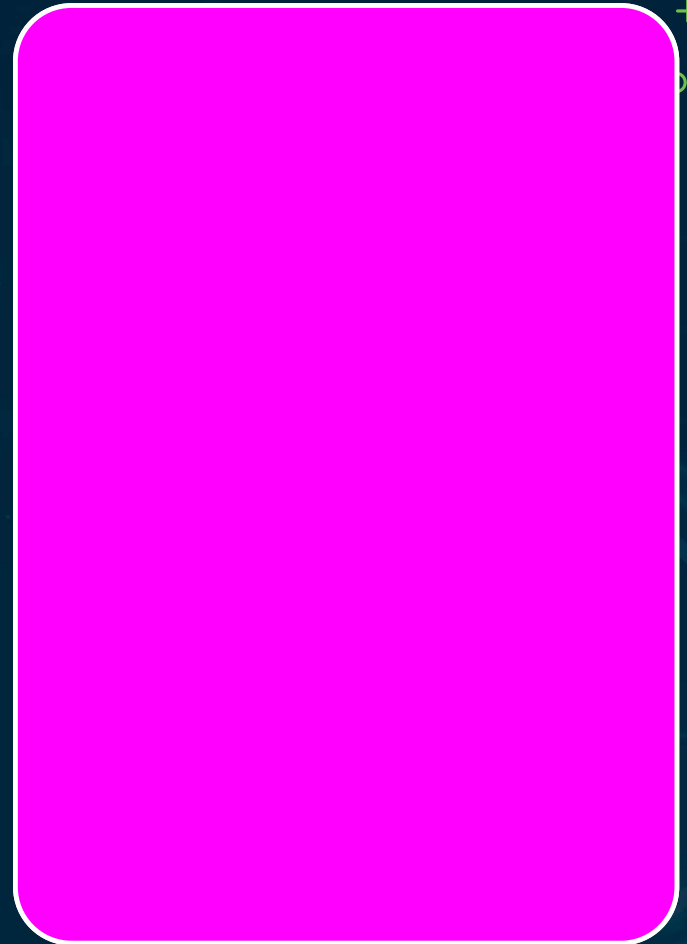
The Three-Question Framework

- 1 → Where in the lifecycle? train / inference / post-deploy
- 2 → Which asset is at risk? behavior, weights, data, integrity
- 3 → Root cause? missing control, governance gap, or both



Supply-Chain TI Component

- Monitor CVEs for all AI components in the inventory
- Foundation-model incident notices are a TI feed
- A provider incident activates the vendor procedure

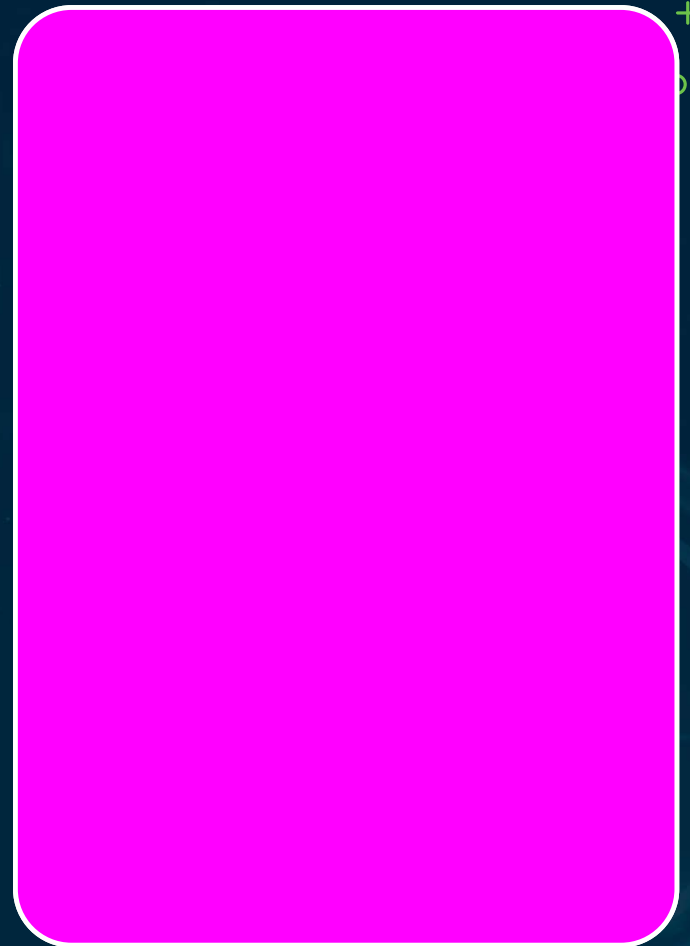


MITRE ATT&CK vs ATLAS

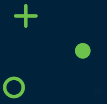
ATT&CK exploits software & config weaknesses

ATLAS exploits ML math — inversion,
membership inference

Some ATLAS techniques have no ATT&CK equivalent

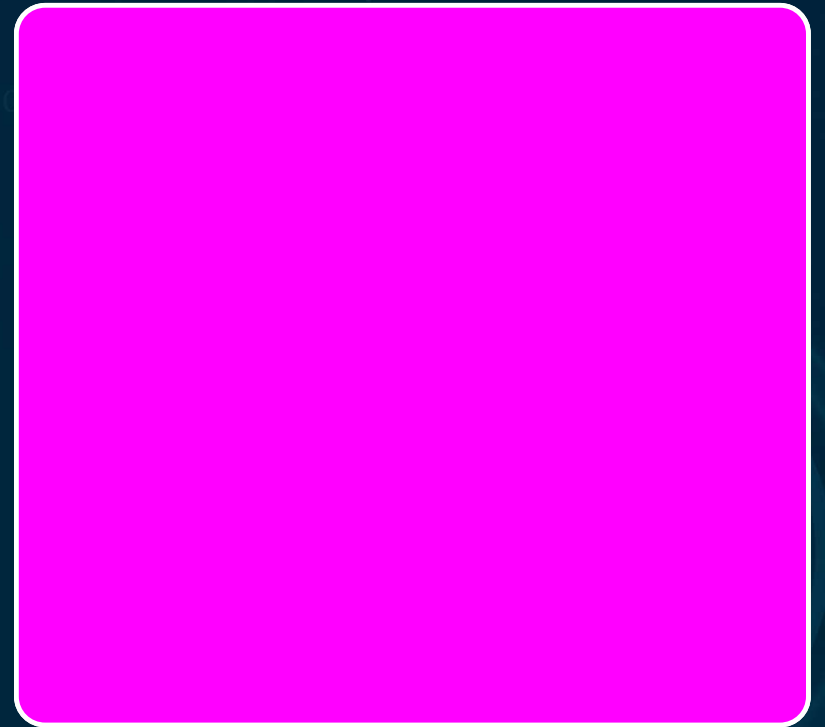


ATLAS + OWASP = COMPLEMENTARY



ATLAS — how adversaries attack AI

OWASP Top 10 — what vulnerabilities exist

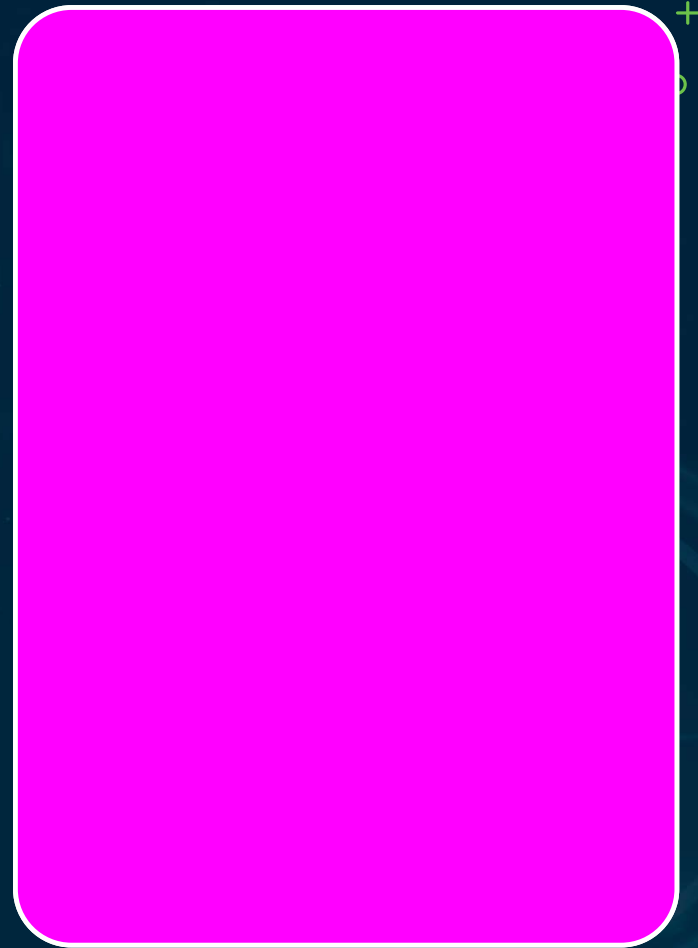


Interface & Integration Techniques

Prompt injection — direct & indirect

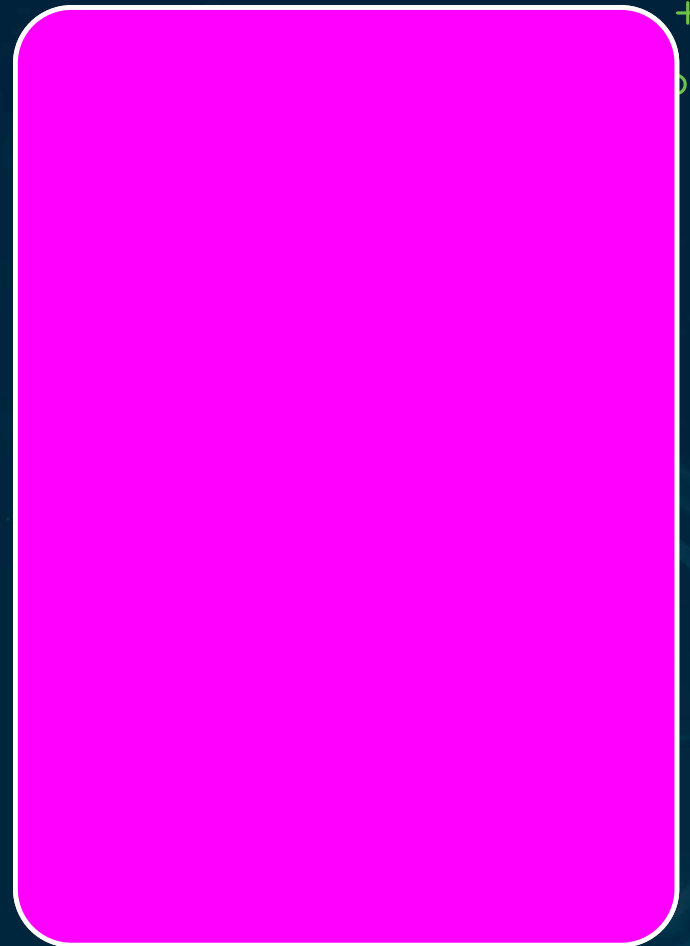
Jailbreaking removes guardrails (vs
redirecting output)

API abuse + privilege escalation via tool calls



Recap · Threat Intelligence

AI-specific TI sources; MITRE ATLAS is primary
Strategic vs operational TI + supply-chain component
Strategic TI → risk register; Operational TI → SIEM rules



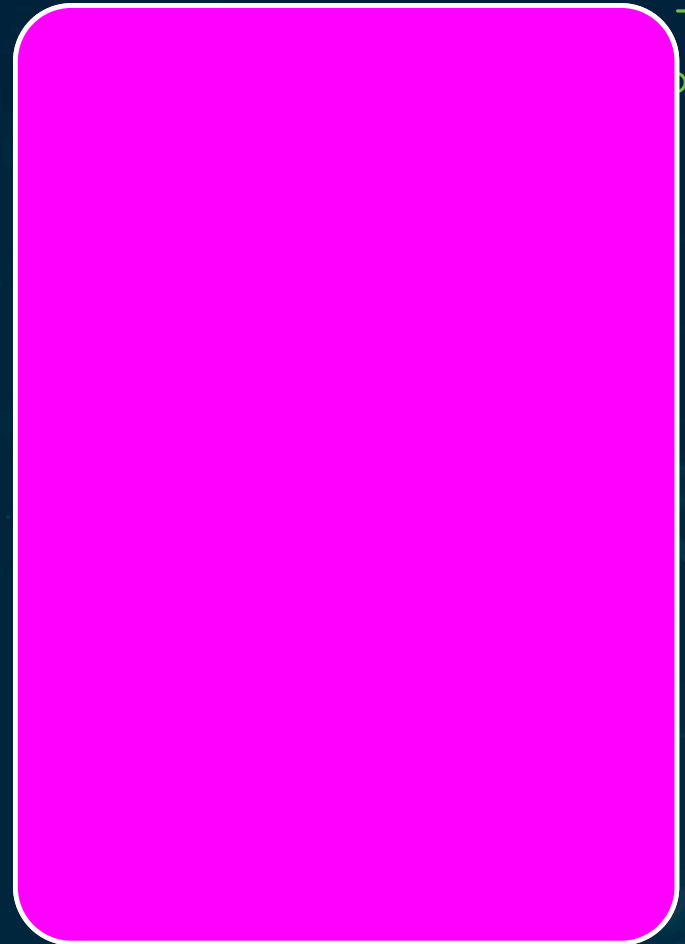
Deepfakes, Insider Threat & AI Agents

Chapter 05 · Episode 2 — Dr. Michael Solomon



Synthetic-Media Detection

Deploy detection tools on high-risk comms channels
Classify deepfake incidents quickly

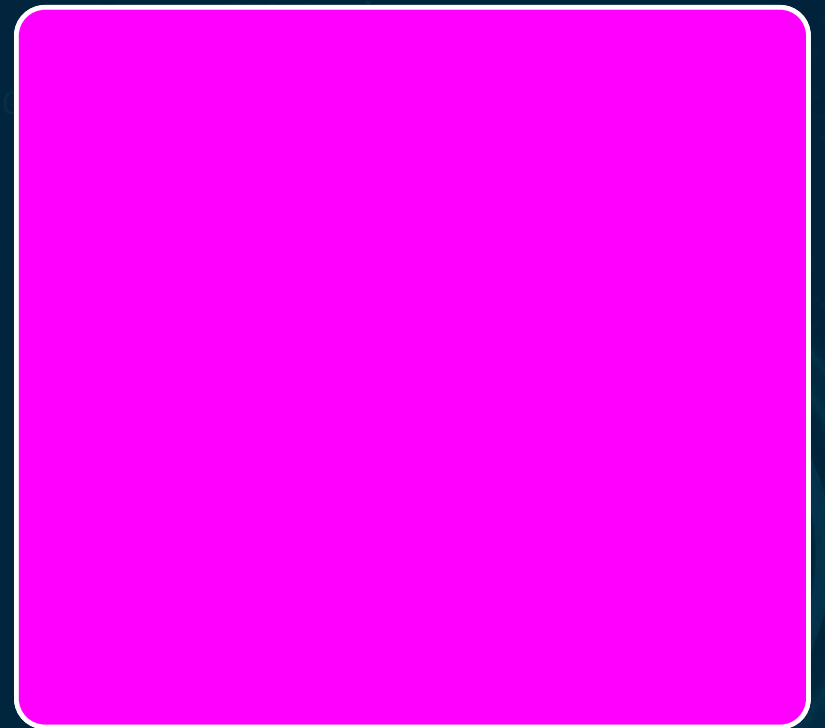


CATEGORY F — REPUTATIONAL



Deepfake incidents involving employees
or customers

Classify as Category F (reputational) at minimum

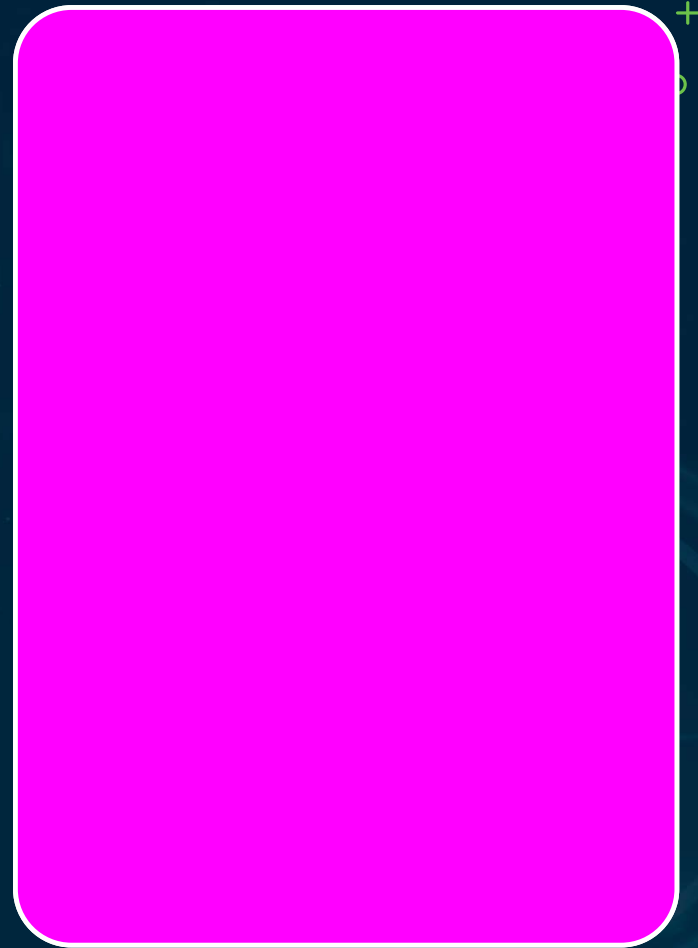


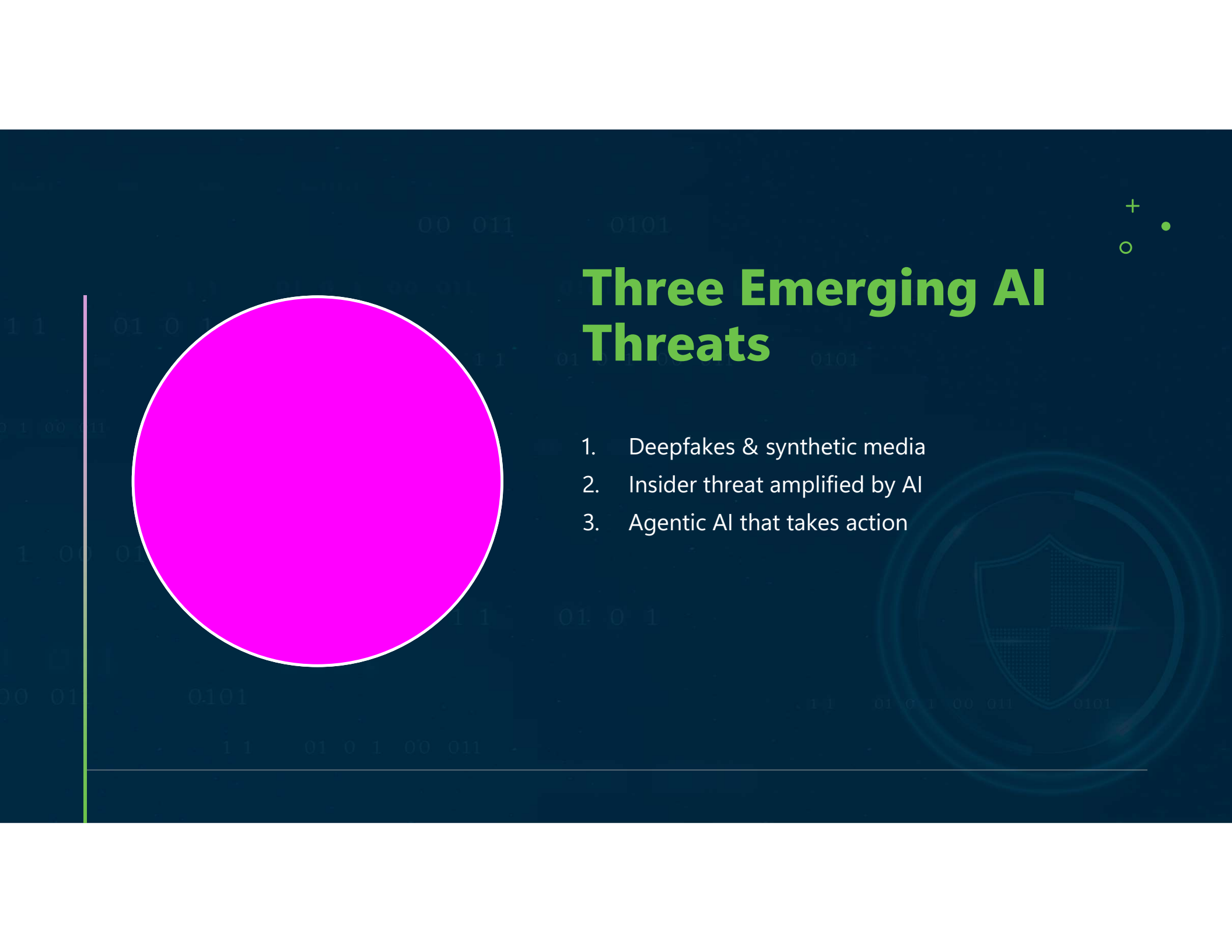
Detection Tools Are AI Systems

A deepfake detector is itself a governed AI system

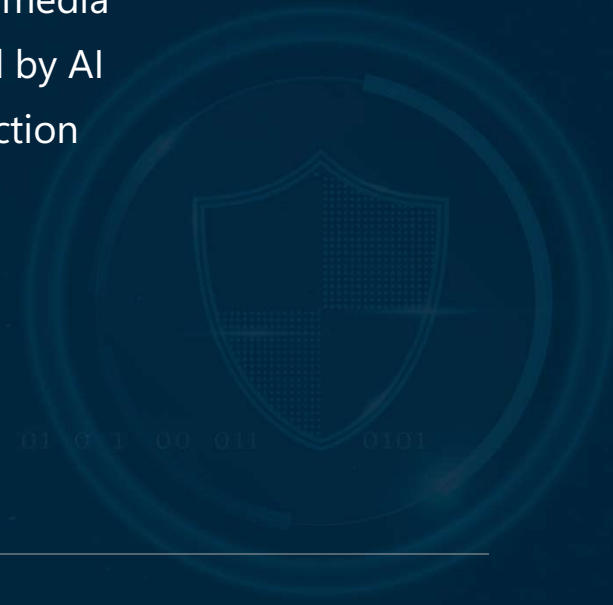
Needs asset-inventory registration + oversight

Exam: AUP prohibition + governed detection
both testable



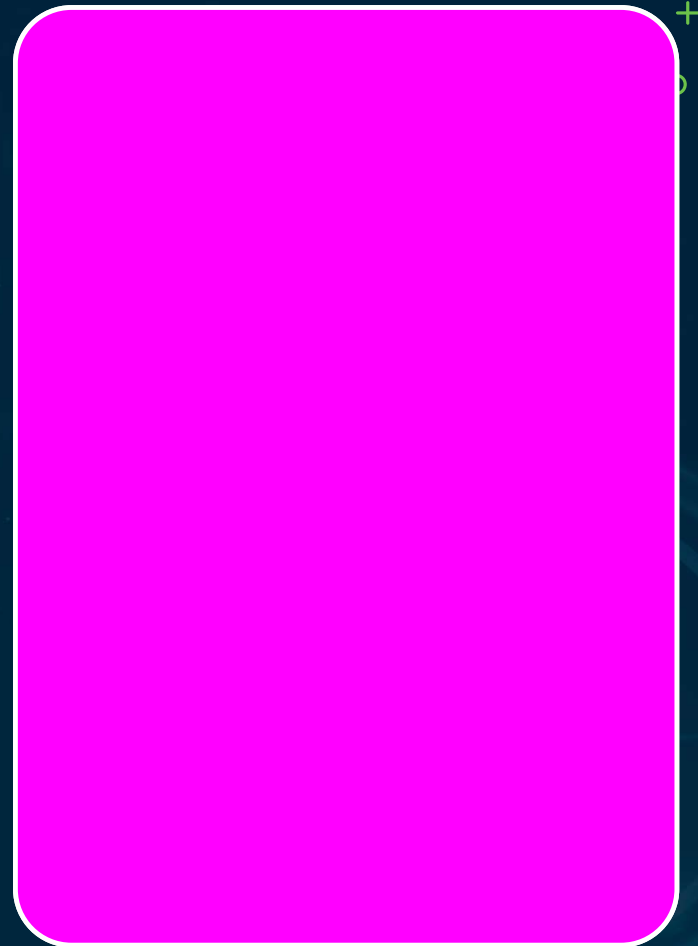


Three Emerging AI Threats

1. Deepfakes & synthetic media
 2. Insider threat amplified by AI
 3. Agentic AI that takes action
- 

What the Exam Tests Here

- Recognize AI-enabled attack techniques
- Understand how they work + their indicators
- Recommend appropriate defensive responses



Deepfake Modalities

Video

Fabricated executive
- meeting footage

Audio

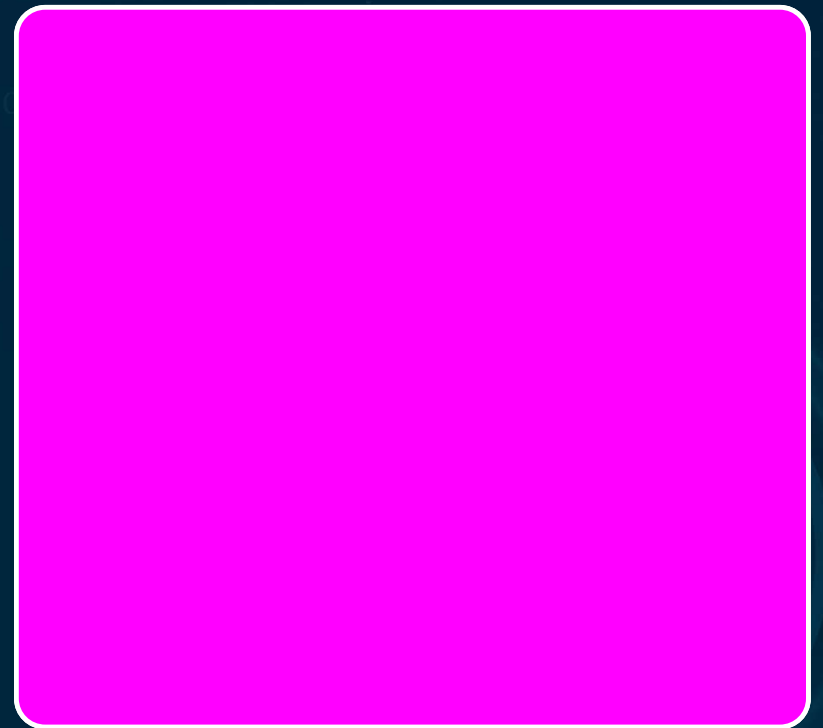
Voice cloning from
seconds of audio

Image

Synthetic photos for
identity fraud

CANONICAL CASE

2019 UK energy-firm CEO voice fraud
Synthesized voice authorized a fraudulent
wire transfer

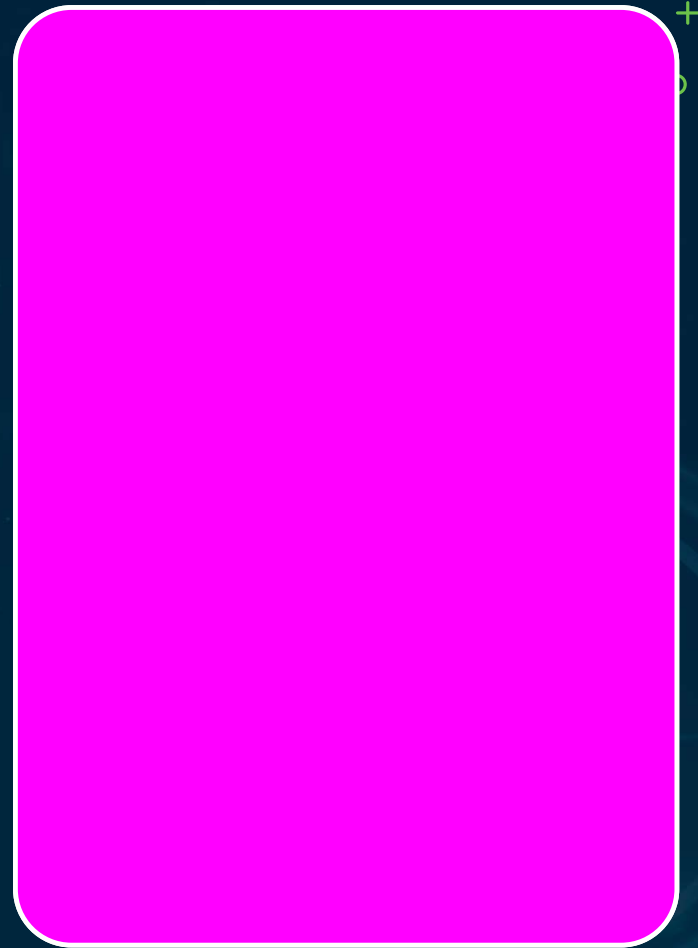


AI-Enhanced Social Engineering

Spear-phishing at scale

OSINT gathering + message generation automated

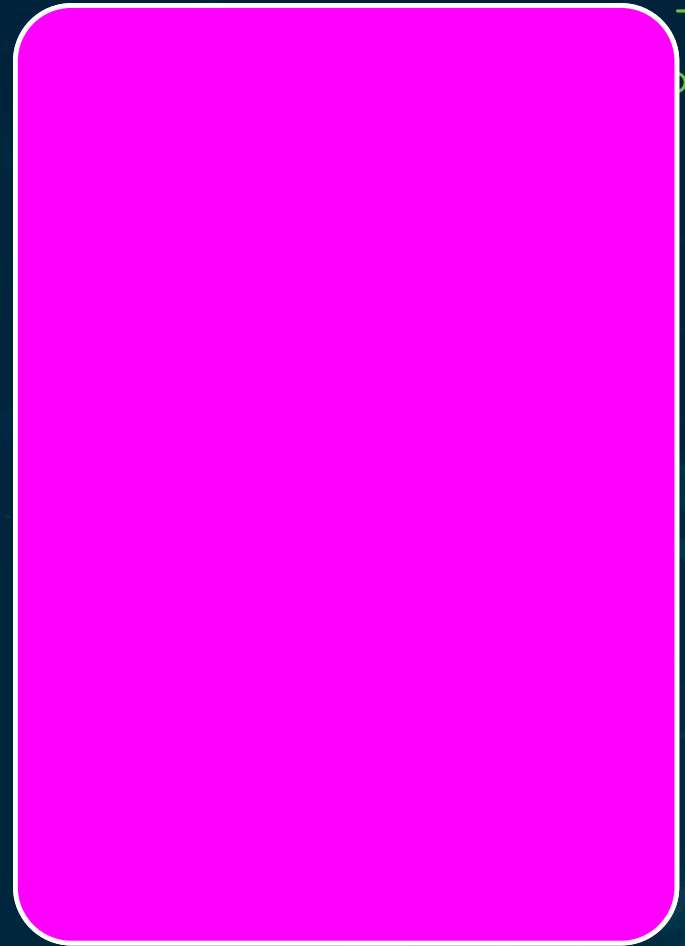
Thousands of personalized messages at once



Real-Time Voice & AI Pretext

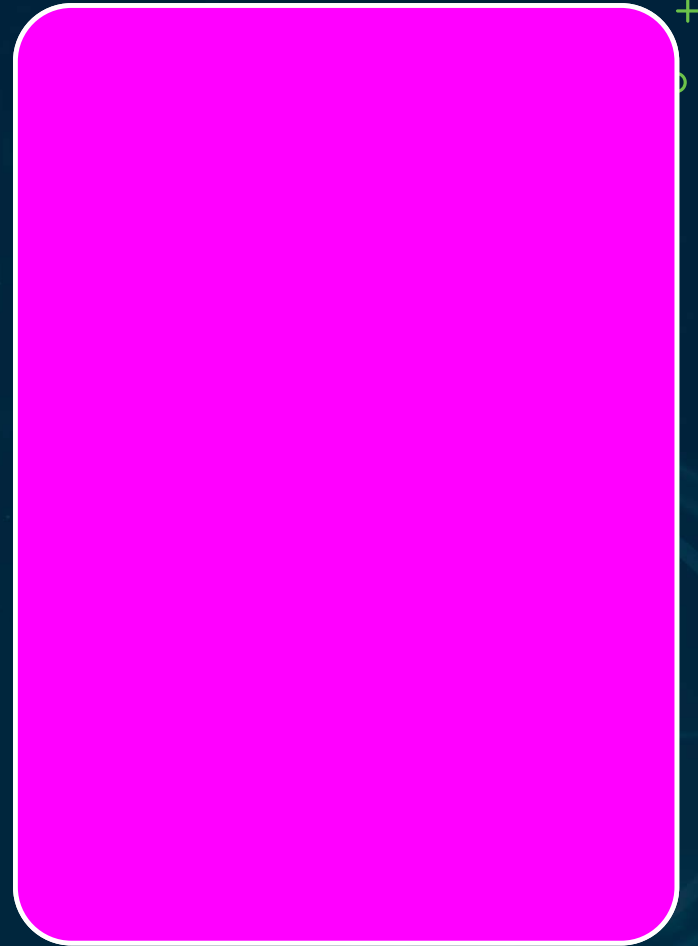
Live voice conversion bypasses voice authentication

Fabricated profiles, sites, reference letters



Scale · Personalization · Automation

AI removes the old effort-vs-quality tension
The combination beats any single capability

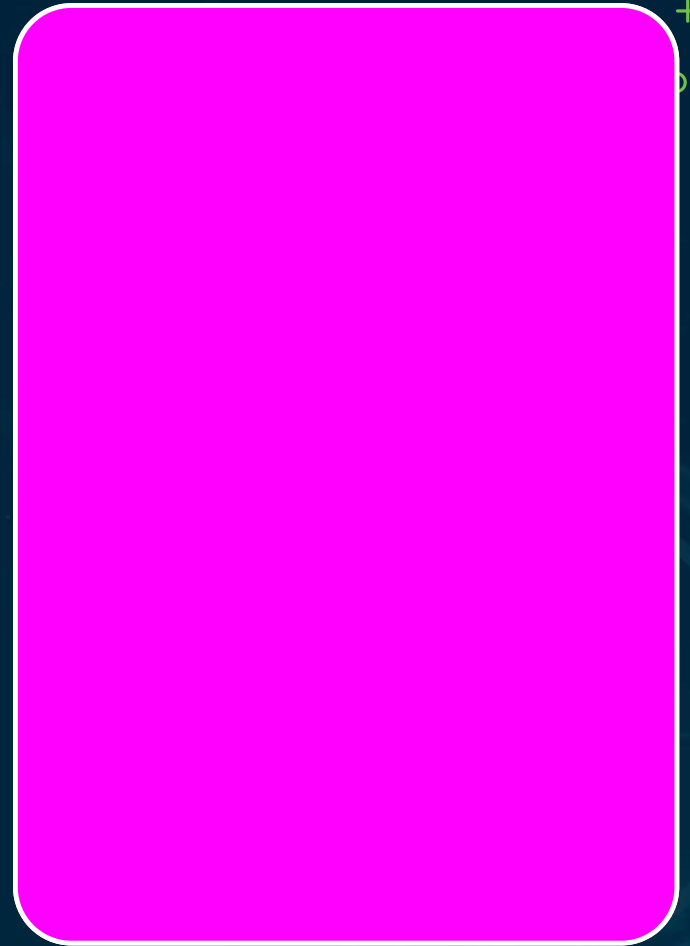


Deepfake Detection Indicators

Audio — unnatural rhythm, latency artifacts

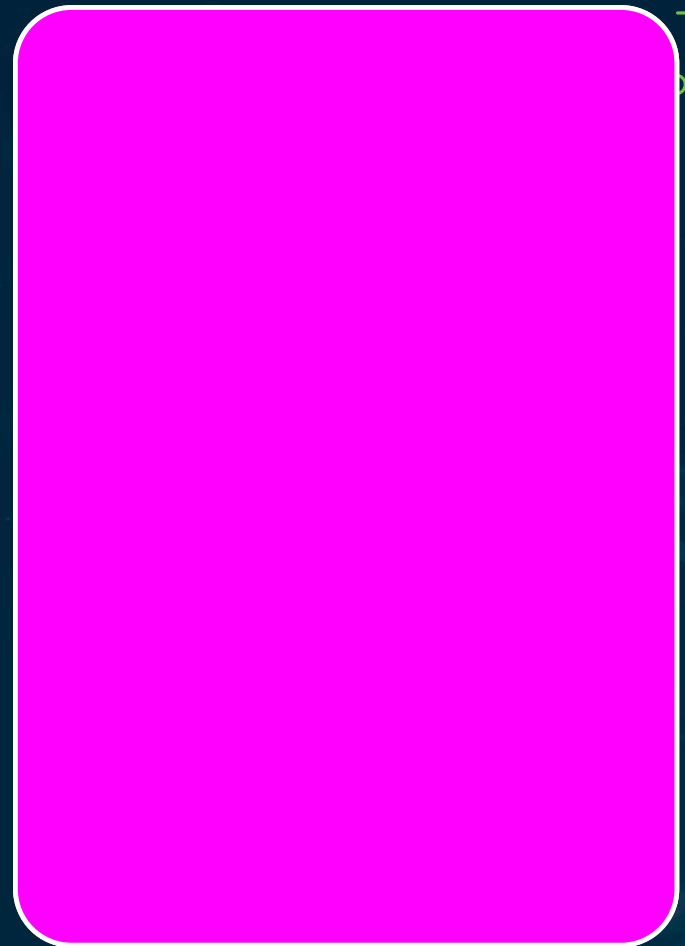
Video — bad lighting, blinking, lip-sync errors

Written — uniform style, odd repetition, no context



Layered Defenses

Out-of-band confirmation for high-risk actions
Deepfake-awareness training builds skepticism

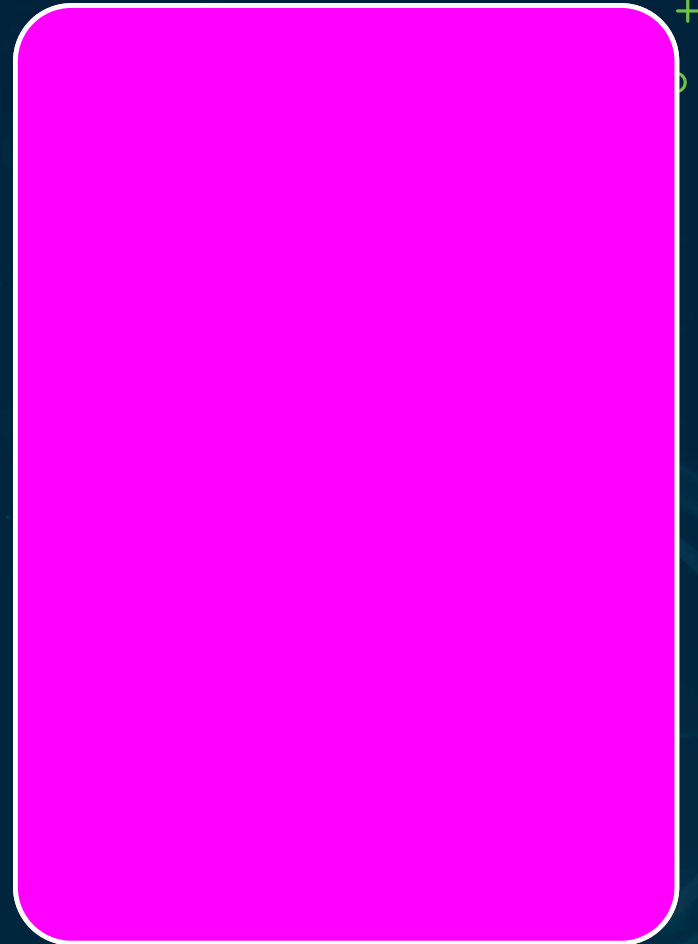


Verification Discipline

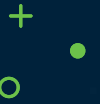
Treat unusual phone/video requests with verification

Metadata & forensic tools flag AI generation

Require multi-channel corroboration

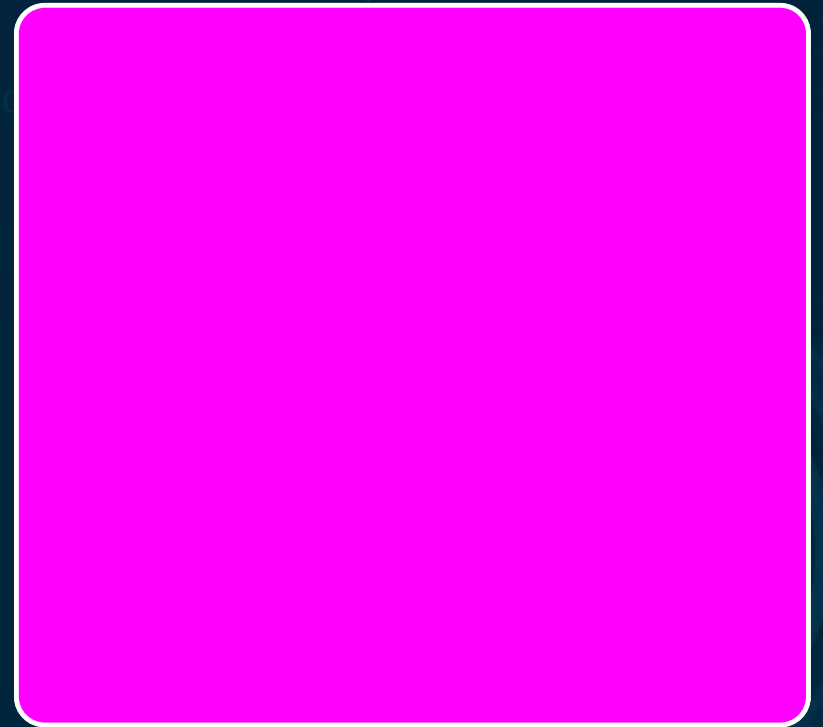


PROCESS > DETECTION



No detection method is reliable alone

Out-of-band verification is the exam answer for deepfake defense

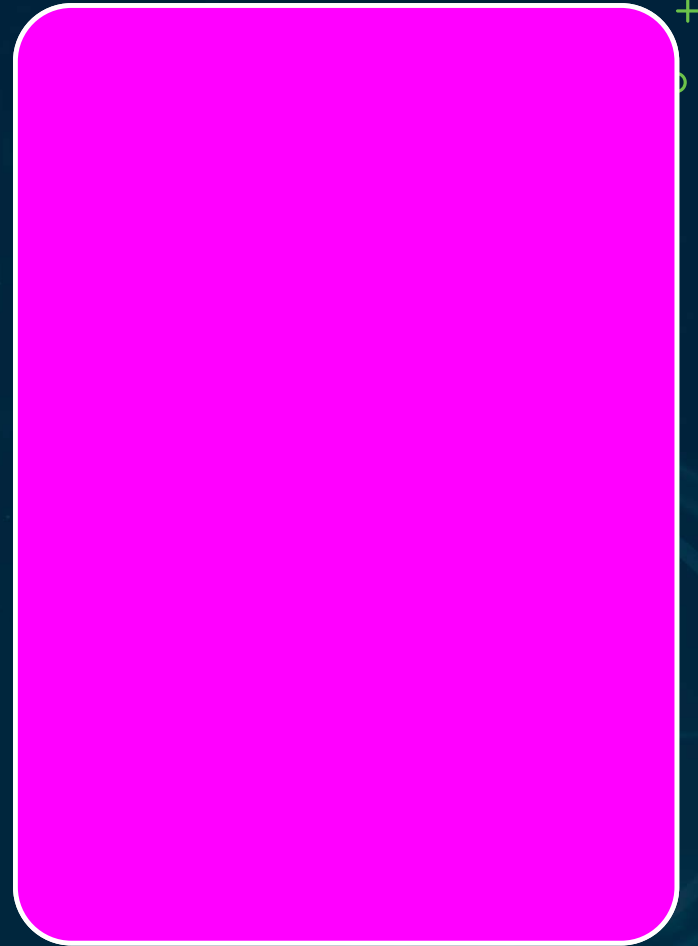


Insider Threat: UEBA Baselines

Configure UEBA with AI-specific access baselines

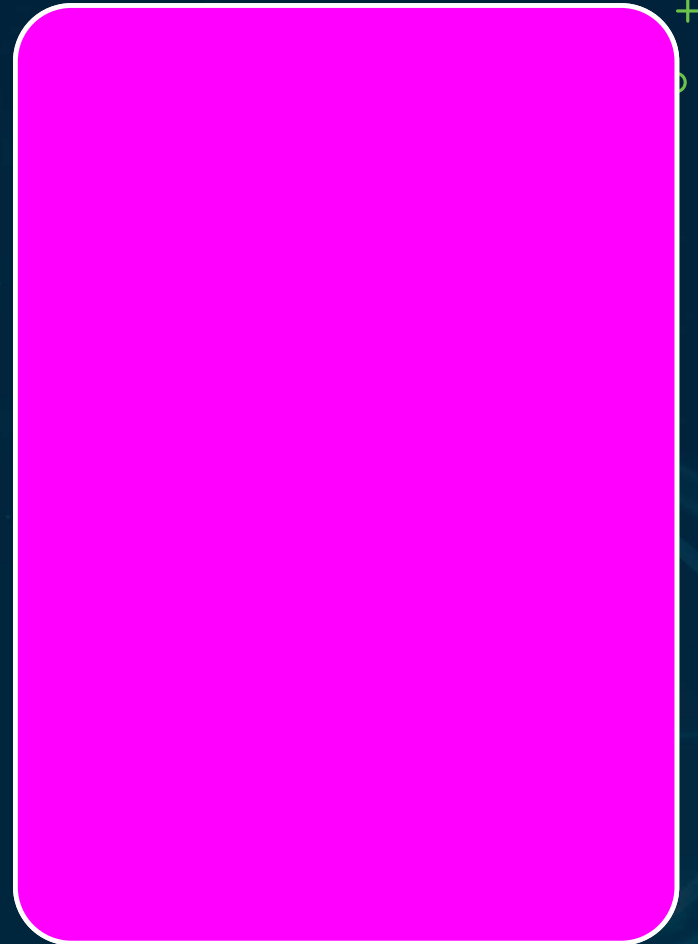
High-risk: bulk data export, off-hours access

Model-registry access, unusual inference volume



Separation of Duties

Model trainer $\neq$ unilateral deployment authority
Insider controls sit at architecture layers 1 & 2
Exam: UEBA AI baselines are a program obligation



Agent Orchestration Patterns

Sequential

Agents chained stage to stage

Parallel

Agents run at once, results merged

Hierarchical

Supervisor decomposes + dispatches

Agent Governance – Four Pillars



Scope

Enforced boundaries on tools & data



Logging

Every action logged with reasoning



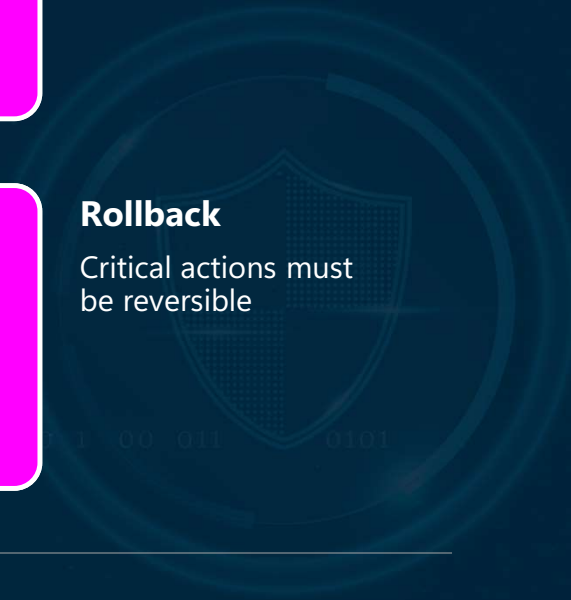
Human-in-loop

Approval gates for high-impact acts



Rollback

Critical actions must be reversible

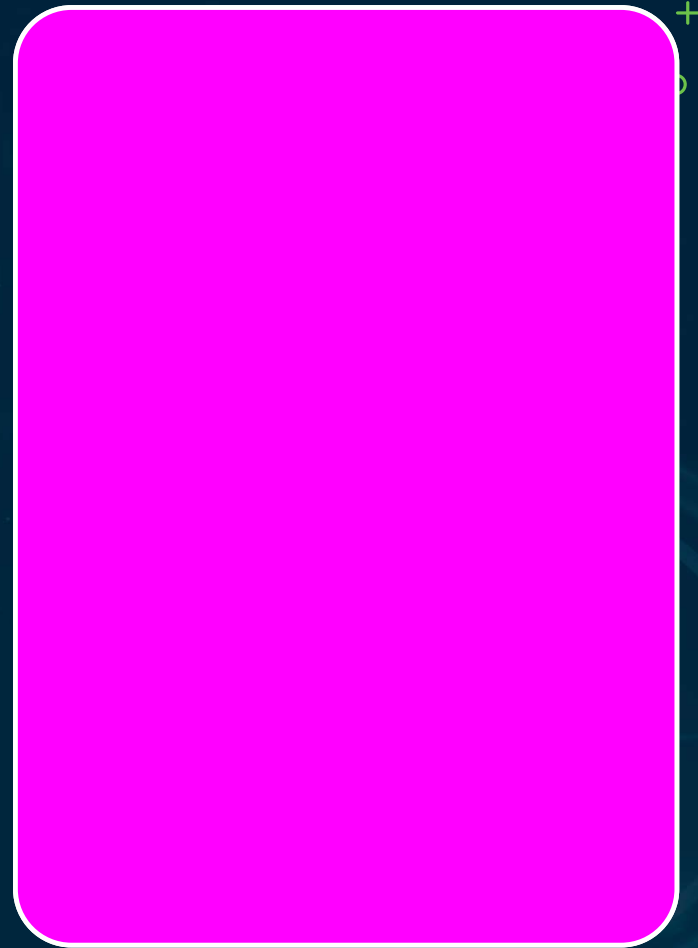


Autonomous Agent Risks

Goal misalignment — harmful side effects

Prompt injection into agent workflows

Agent-chaining failure cascades

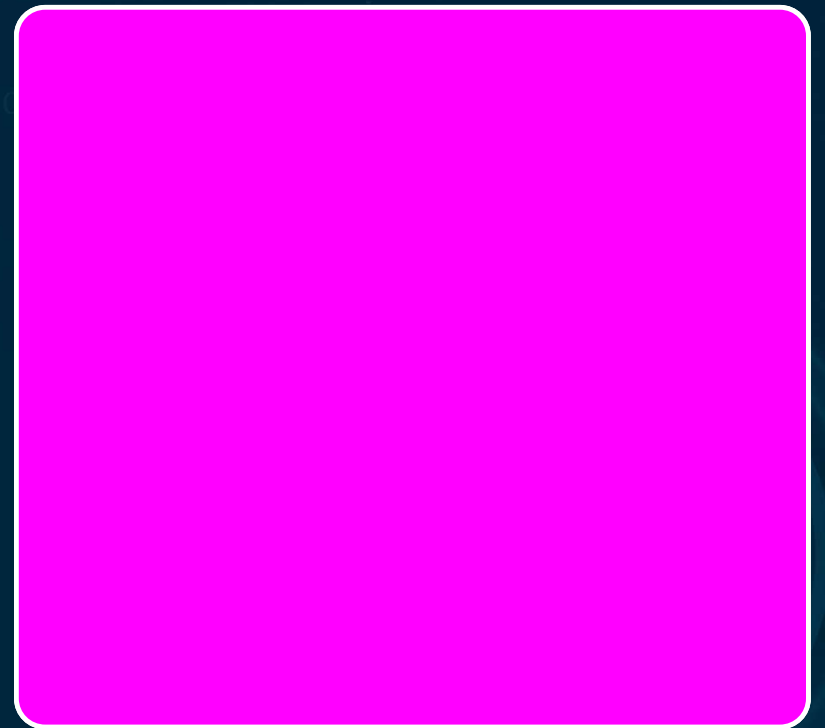


PROMPT INJECTION INTO AGENTS



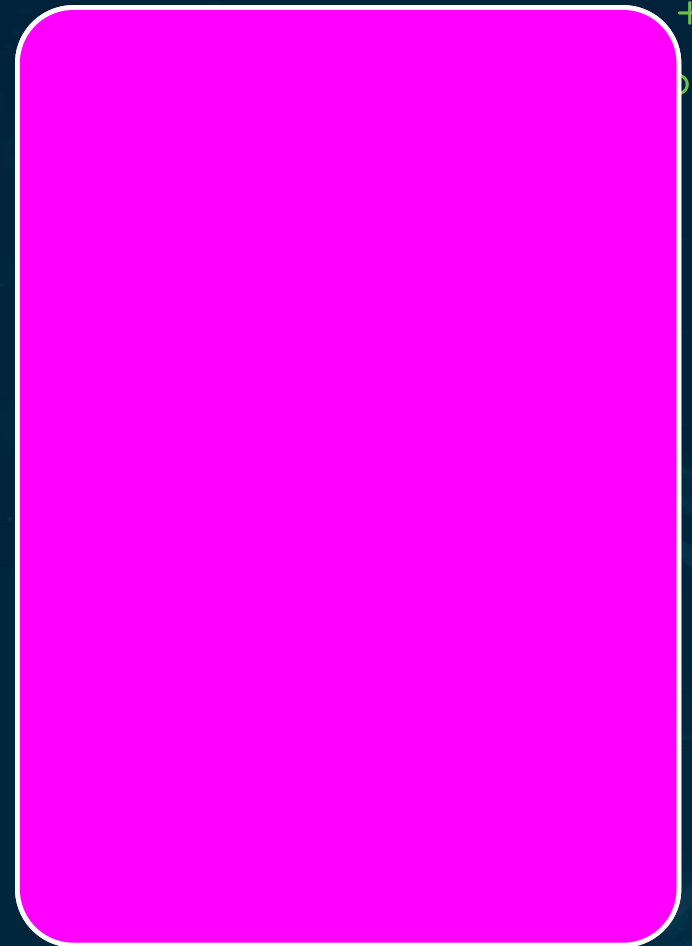
High-priority exam topic

Agents turn injection from bad text into real action



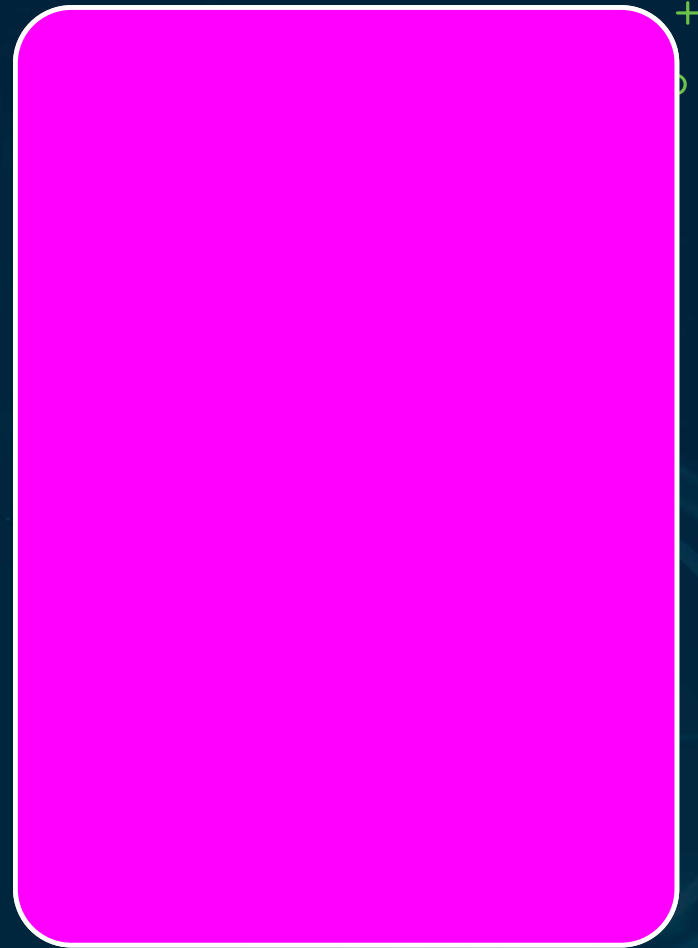
Agentic Governance Requirements

- Action-scope boundaries + human approval gates
- Log actions; record autonomy level in inventory
- External API access = fourth-party supply-chain risk



Model Generates, Agent Acts

- Connected agents become operational actors
- Execution authority multiplies impact
- Unintended operational change = excessive agency

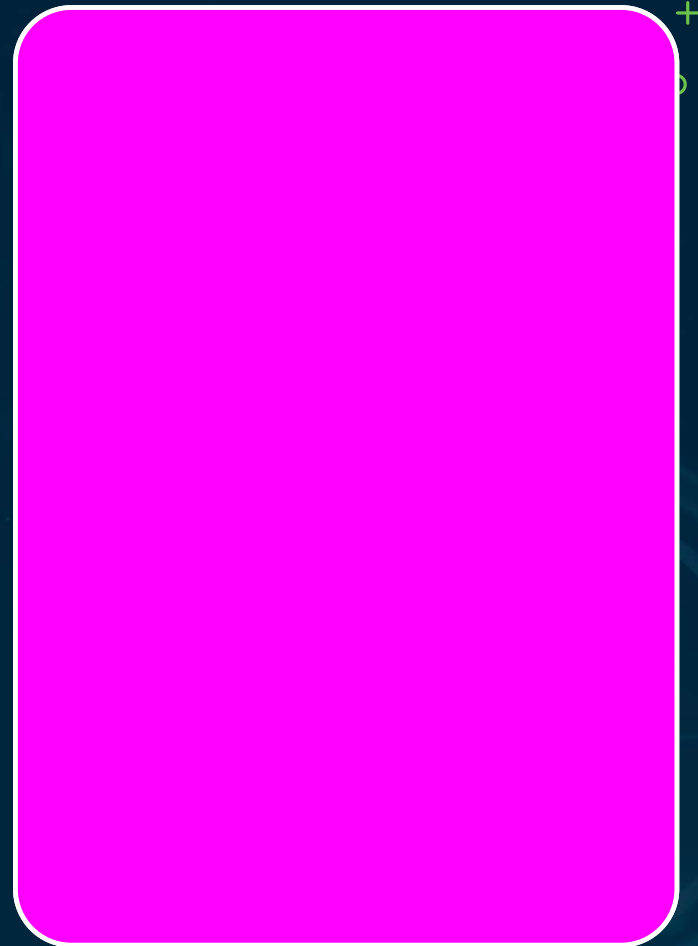


Agent Least Privilege

Scoped tool permissions per role

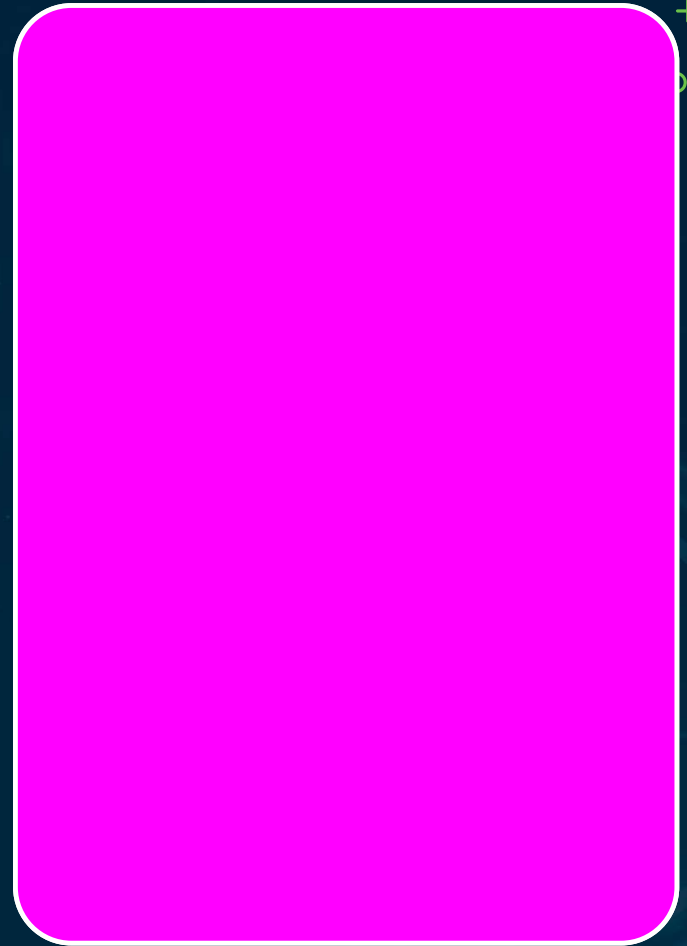
Command allow-lists + granular API authorization

Time-bound access tokens

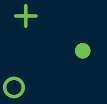


Delegation & Approval

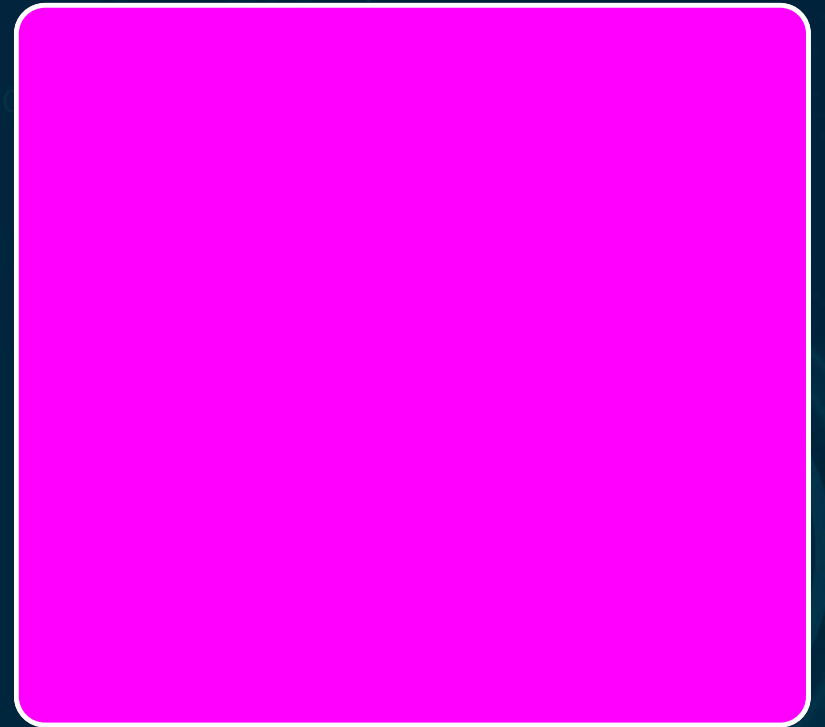
- High-impact ops require human validation
- Escalation thresholds route critical decisions
- Watch automation bias — AI isn't always right



HUMAN-IN-THE-LOOP = MATURITY



Harm executed unchecked = insufficient HITL
Oversight is a maturity signal, not a limitation

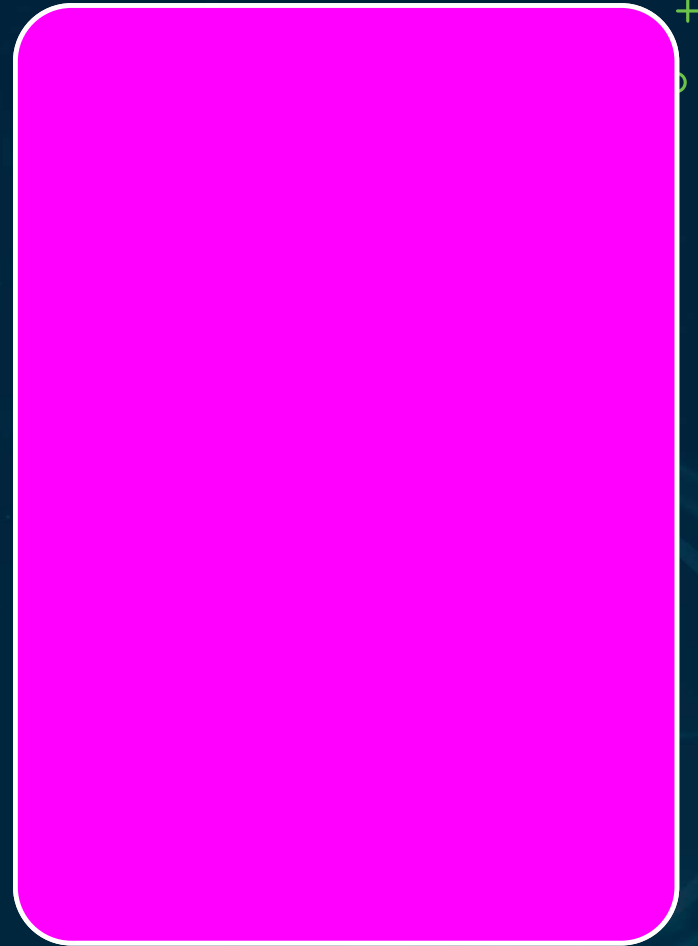


Recap · Three Threat Categories

Deepfakes — AUP prohibition + governed detection

Insider — UEBA AI baselines required

Agentic — scope, boundaries, human gates



Vendor Due Diligence & Contracts

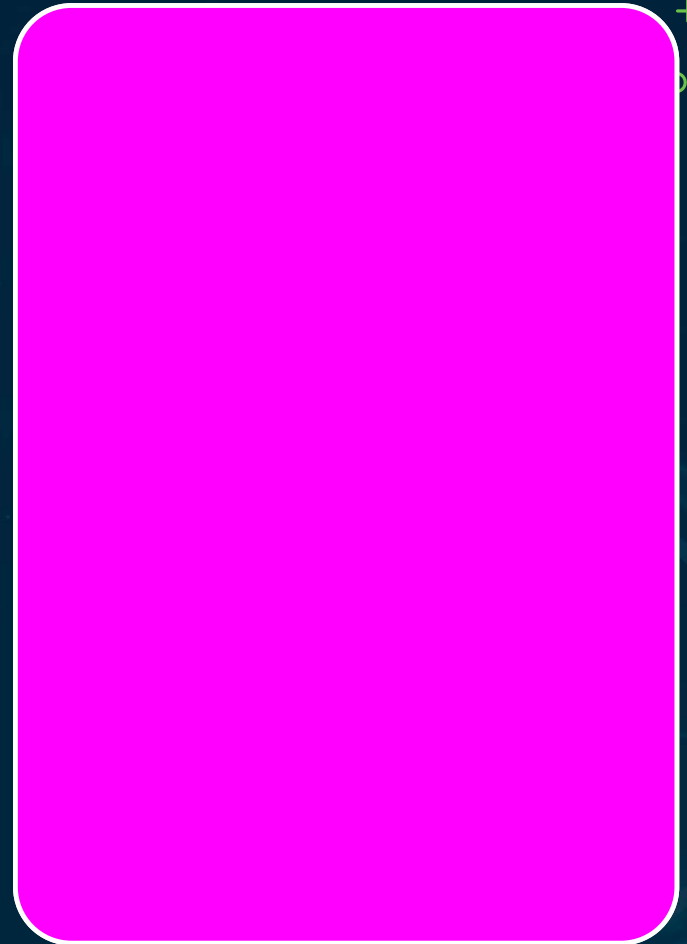
Chapter 05 · Episode 3 — Dr. Michael Solomon



Standard IT DD Isn't Enough

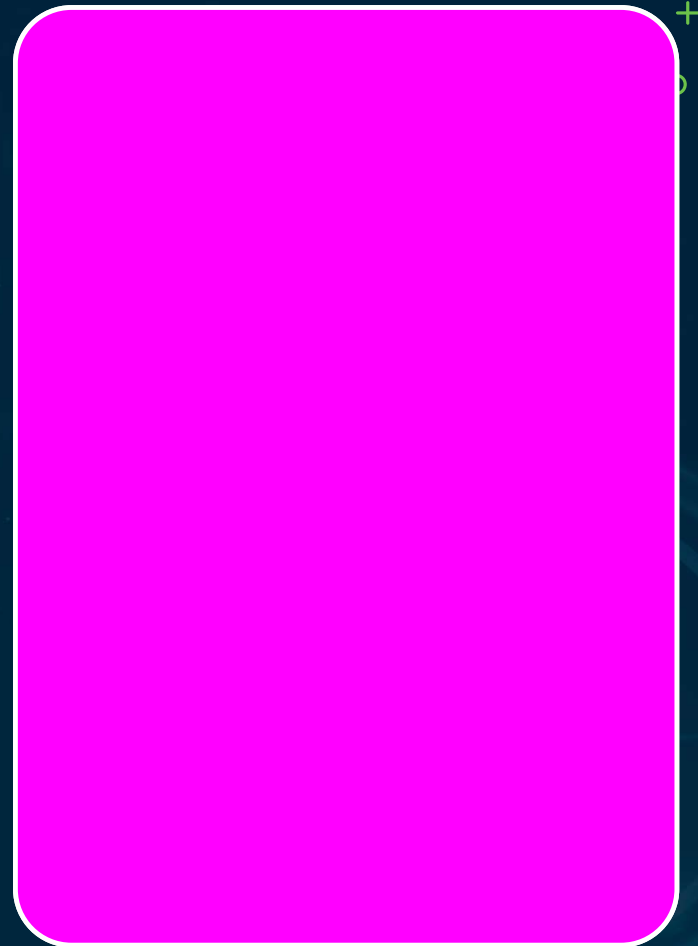
ISO 27001, SOC 2, DPA — necessary but not sufficient

Inadequate DD is a direct path to EU AI Act liability



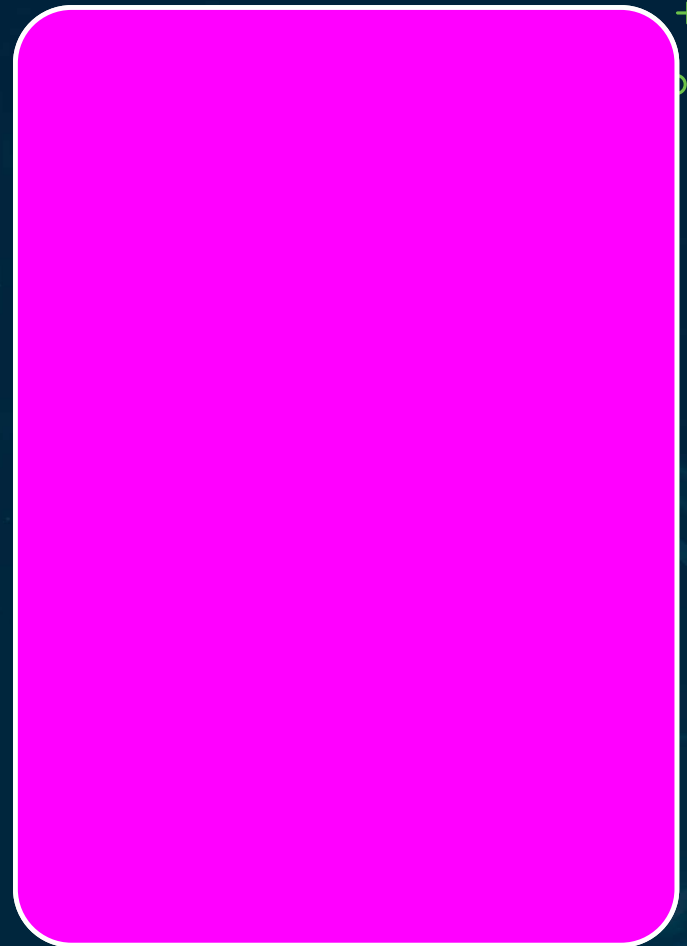
Five AI-Specific Additions

- Model transparency / model card
- Training-data provenance + license
- EU AI Act compliance status
- Model-change notification process
- AI-specific security testing

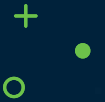


Six Questionnaire Categories

- Model transparency
- Training data & privacy
- Regulatory status (EU AI Act Annex III)
- Security testing
- Model change mgmt & incident response
- Sub-processors



Seven Contract Clauses · 1–4



1 — Transparency

Current model card
on request



2 — Change Notice

Defined advance-
notice period



3 — Data Warranties

Licensed; no unlicensed
personal data



4 — EU AI Act

Compliance warranty



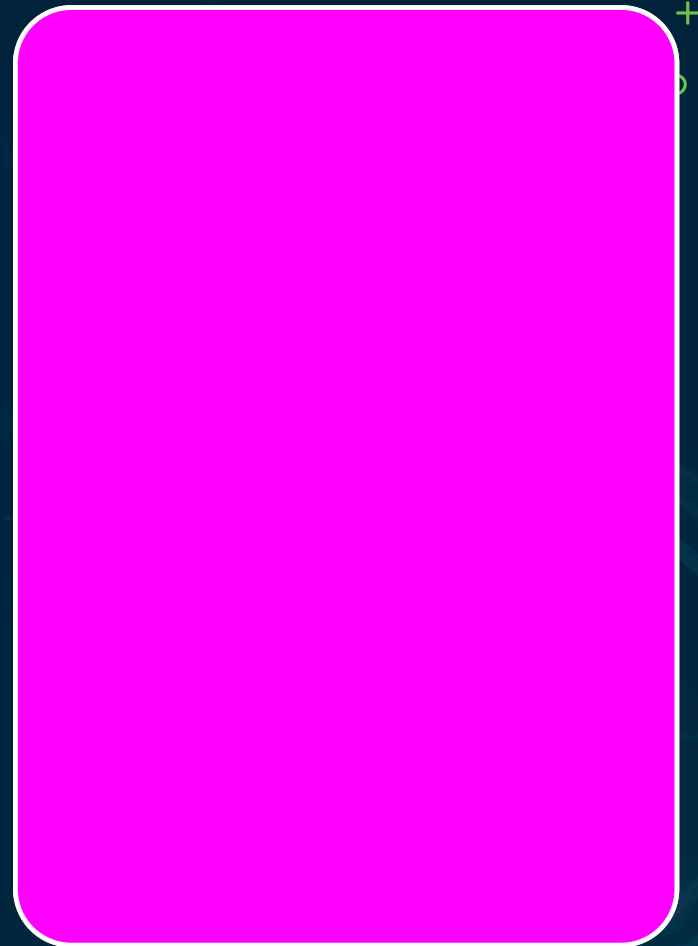
Contract Clauses 5–7

5 AI incident-notification SLA

6 Security-testing disclosure (annual, under NDA)

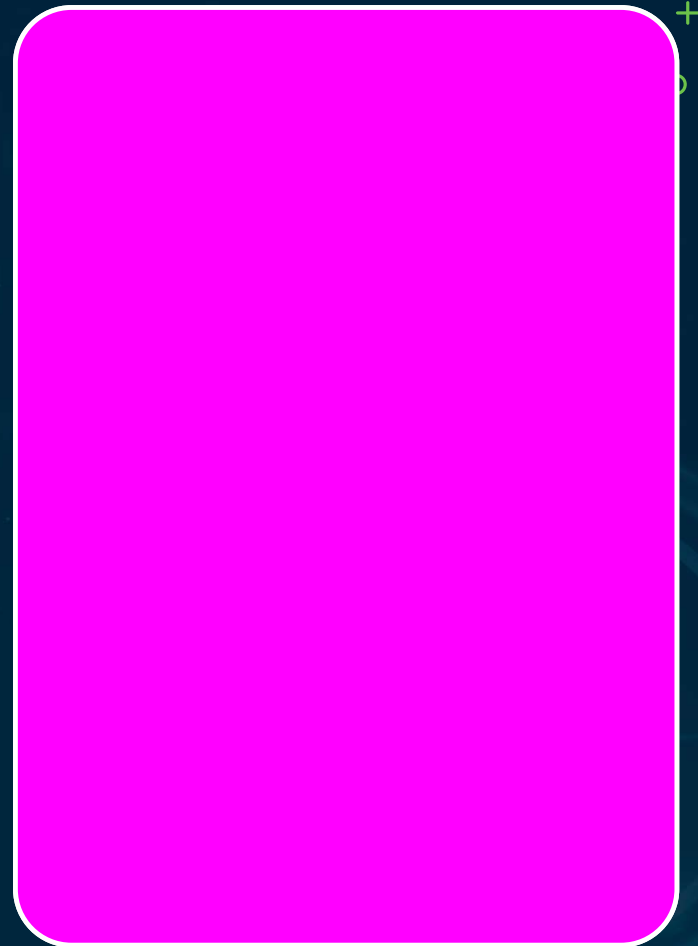
7 Data deletion / model retirement —
written confirmation

Clause 7 (fine-tuning protection) is the most-missed



Six AI-Specific DPA Additions

- Training data = personal-data treatment
- Fine-tuning scope limitations
- Model output as personal data
- AI-specific breach definition
- Article 22 accountability + audit right
- 'Just an AI vendor' is no exemption



Vendor Tiering

Tier 1 Critical

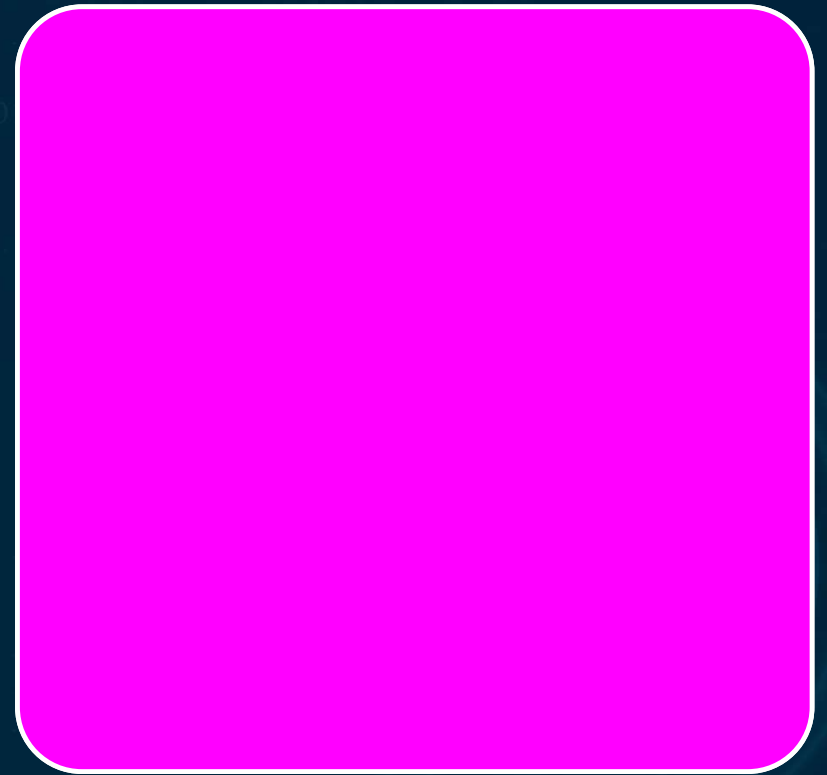
Personal data at scale /
high-risk / foundational

Tier 2

Confidential data / core
integration

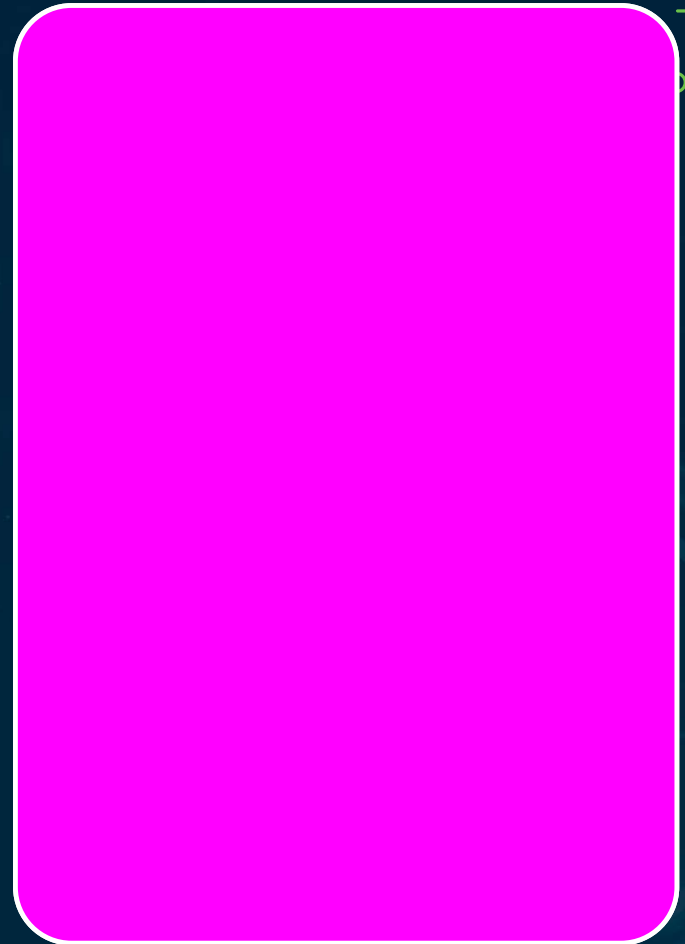
Tier 3 Standard

Public or internal
informational only



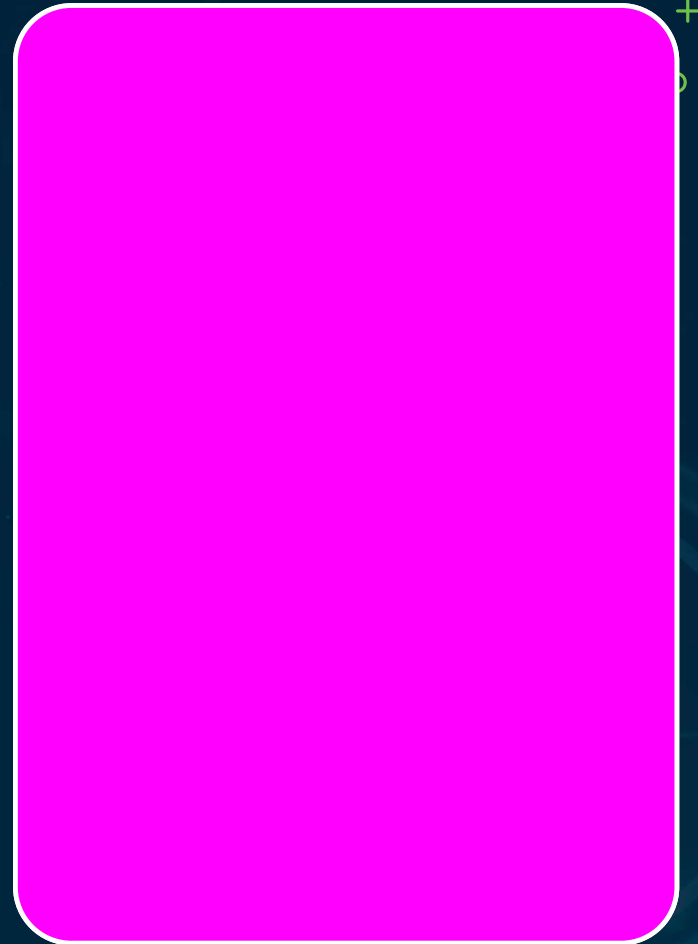
Six Monitoring Streams

- Model-change notifications
- Security incidents
- Regulatory compliance
- Performance & fairness drift
- Sub-processor changes
- Annual DD refresh (tier 1)



Four DD Failures

- Standard IT DD with no AI additions
- No model-change-notification clause → stale DPA
- DPA silent on fine-tuning scope
- No ongoing monitoring → DPA stale after acquisition

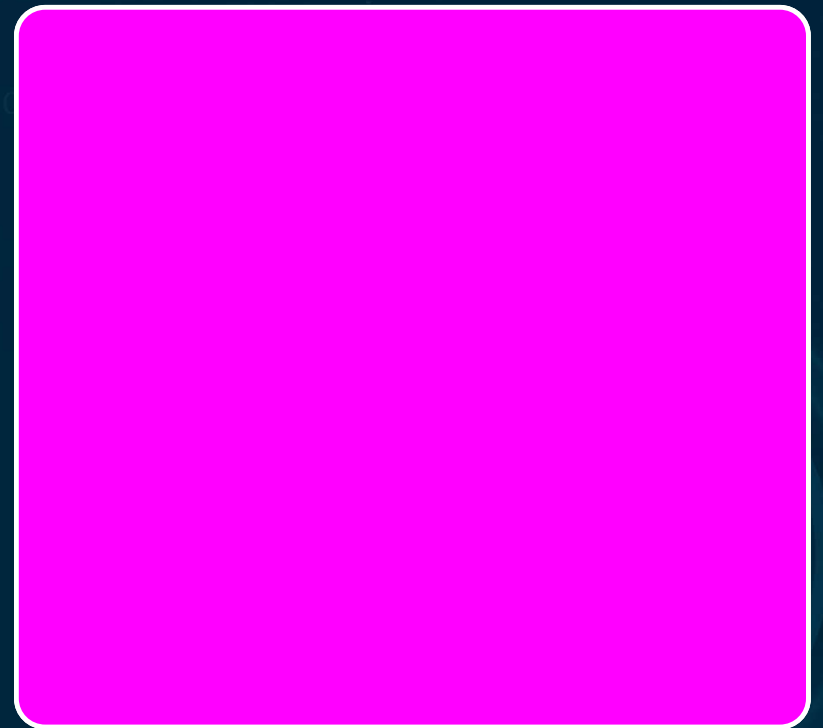


THE FIX

Six AI questionnaire categories; model-change notice not optional

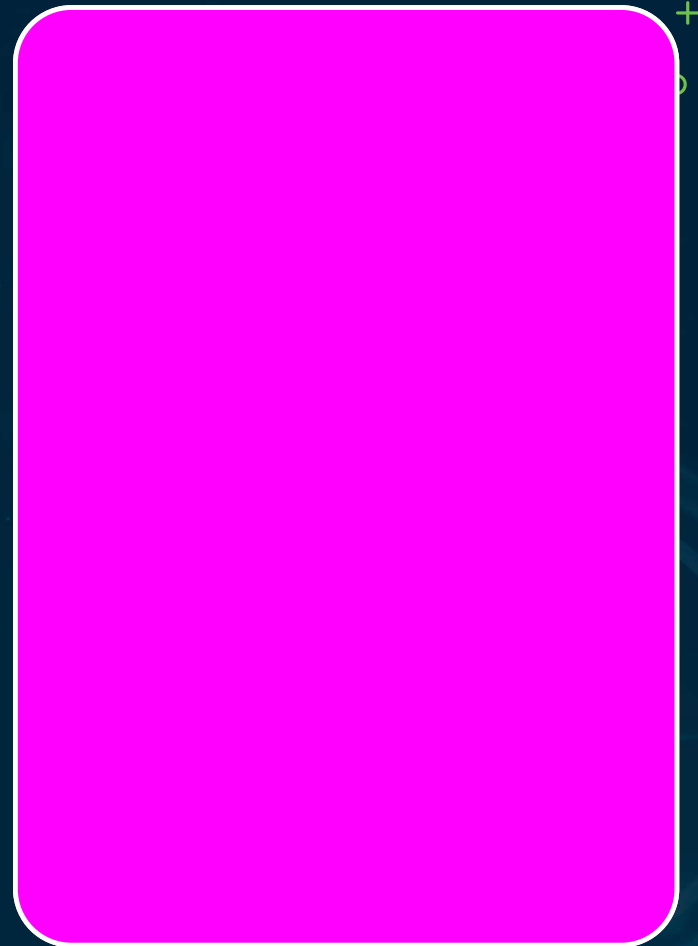
DPA must address fine-tuning; monitoring with triggers

Exam: fine-tuning in DPA + model-change notice most testable



Recap · Vendor Due Diligence

- DD areas + AI-specific contract clauses
- DPA requirements + ongoing monitoring
- DPA is mandatory for personal-data processing

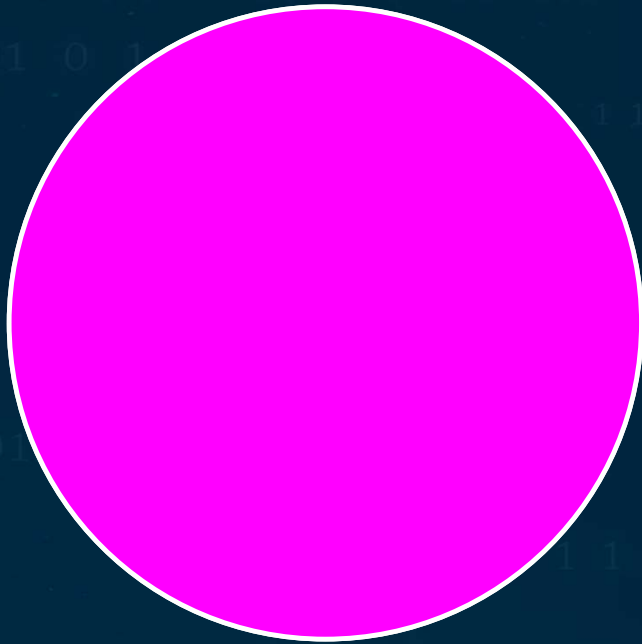


Provider vs Deployer Accountability

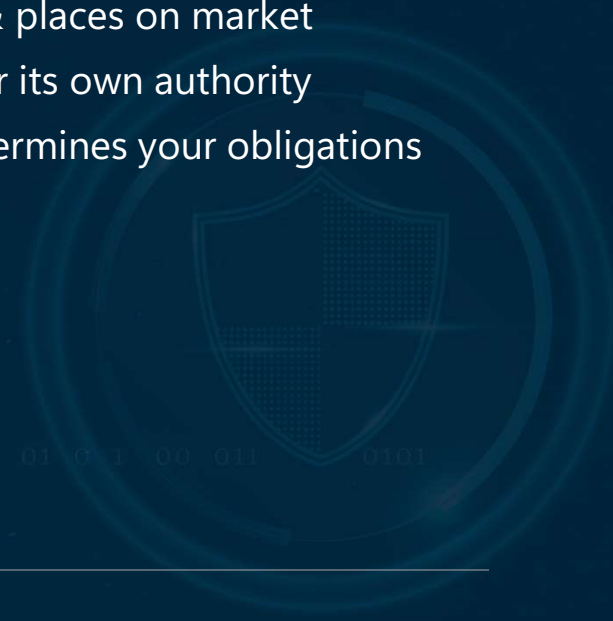
Chapter 05 · Episode 4 — Dr. Michael Solomon



Two EU AI Act Roles



1. Provider — develops & places on market
2. Deployer — uses under its own authority
3. Which role applies determines your obligations



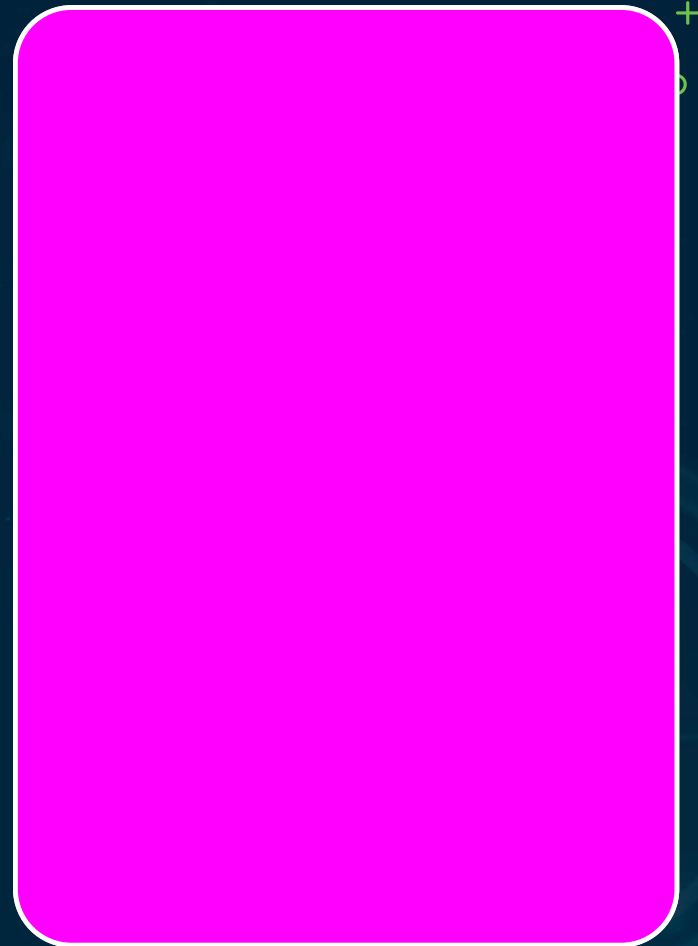
Provider Obligations

Conformity assessment + technical documentation

CE marking for high-risk AI

EU AI Act database registration

QMS + post-market surveillance



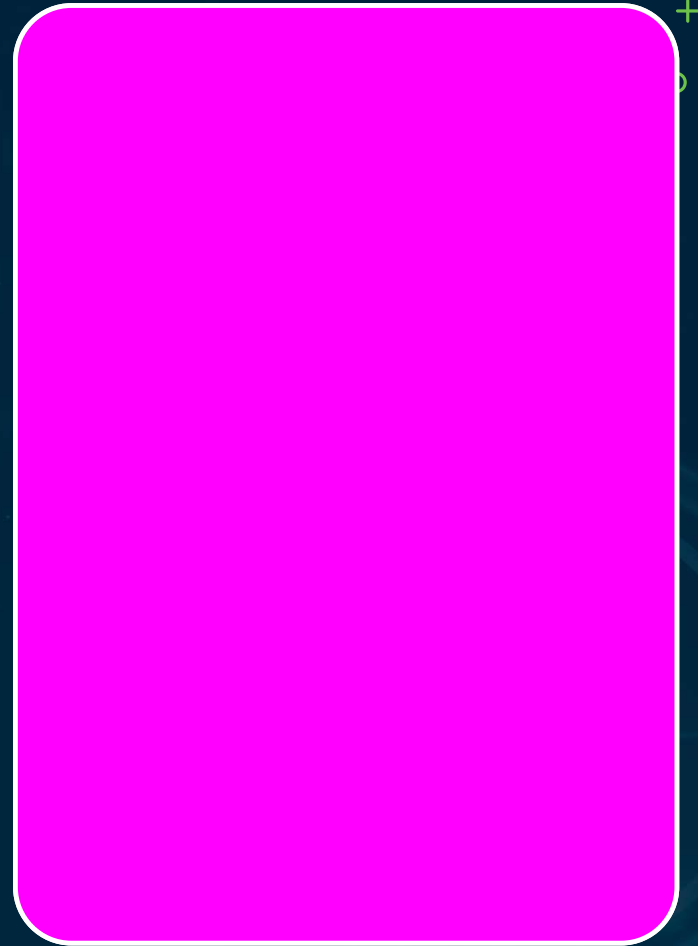
Deployer Obligations

FRIA before deployment

Human oversight + logging

Transparency to affected individuals

Incident notification to the provider



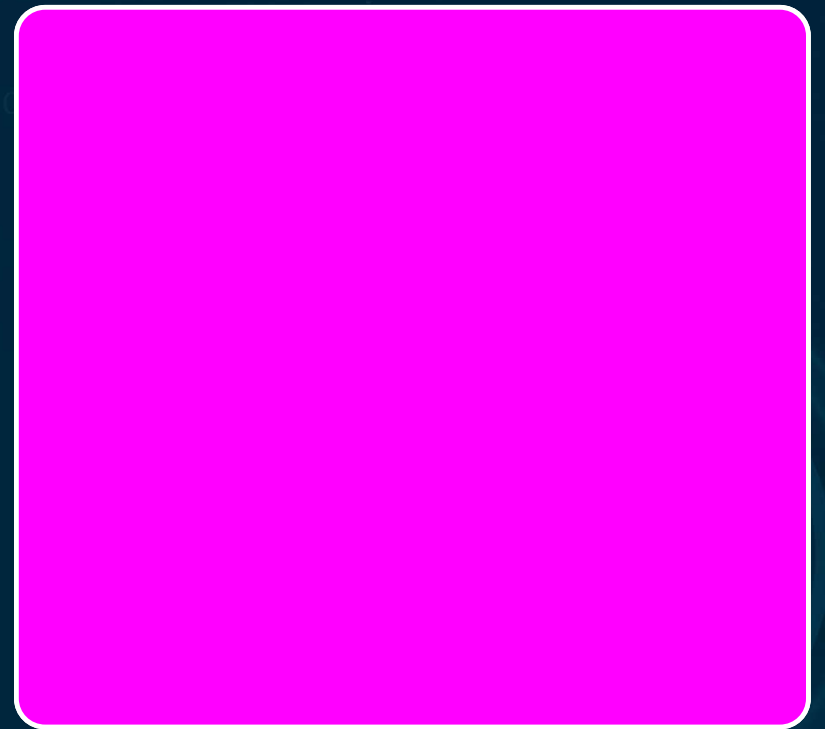
OBLIGATIONS ARE NOT TRANSFERABLE



They attach to the role, not the contract

A deployer can't contract out its FRIA

The provider's DPIA $\neq$ the deployer's FRIA



Four Deemed-Provider Scenarios



1 — Own Name

Places system on market under own brand



2 — Substantial Mod

Substantially modifies a high-risk system



3 — New Purpose

Change makes a system high-risk



4 — GPAI Integrated

Builds GPAI into a high-risk app



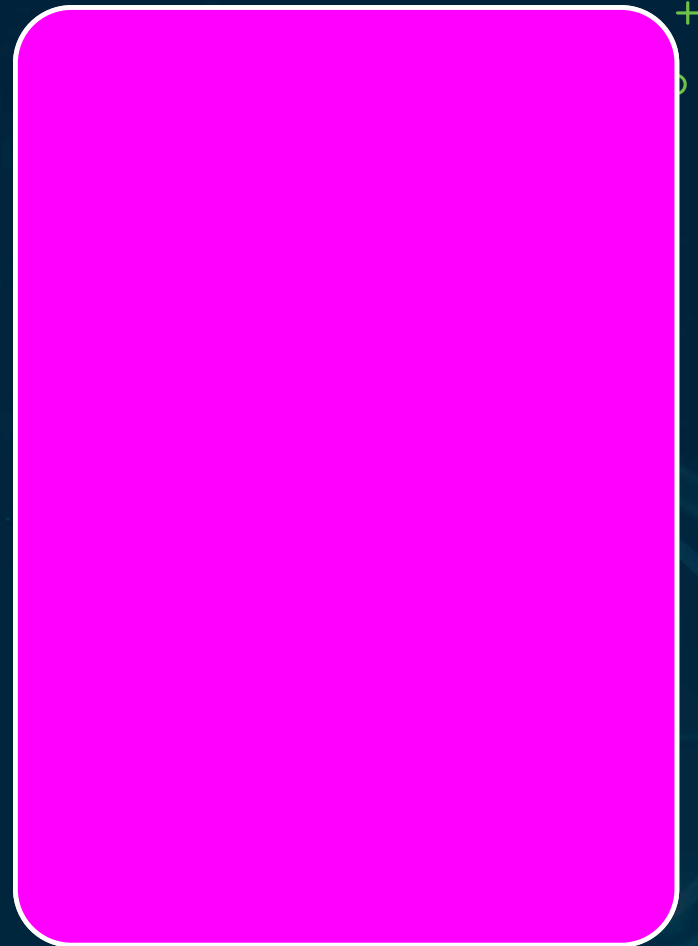
GPAI — The Third Layer

GPAI provider: training-data docs + methodology

Copyright-compliance policy + training-data summary

Downstream capability/limitation info + incident notice

Systemic-risk models: adversarial testing + EU AI Office reporting

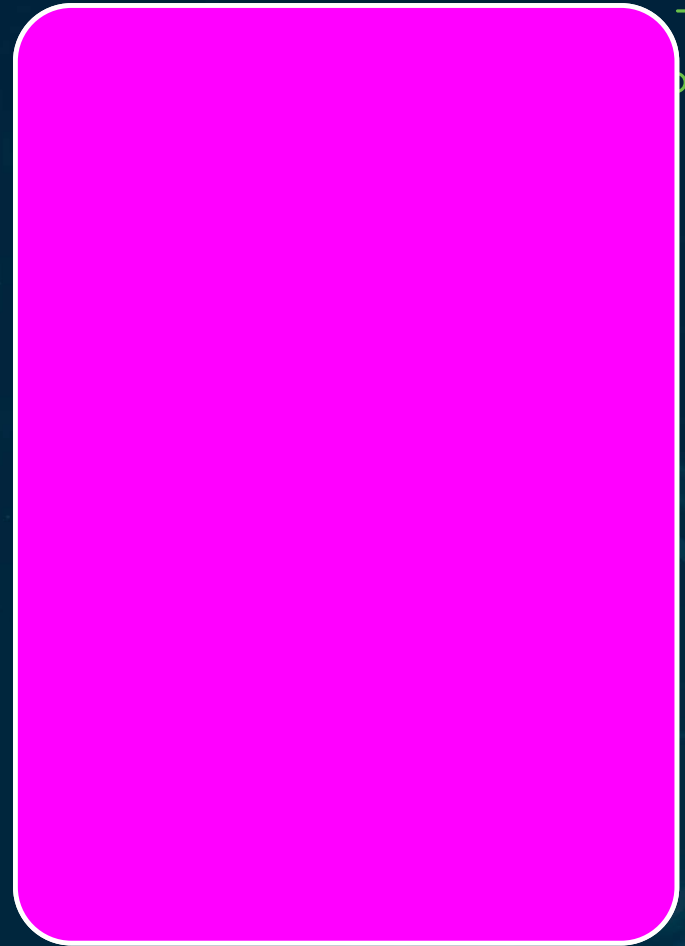


Using a GPAI API

Build high-risk on a GPAI API → you are the deployer

The GPAI provider owes you sufficient technical docs

Three layers: GPAI → system provider → deployer



EU AI Act x GDPR – Four Combinations



1

Provider + Controller —
full provider + DPIA

2

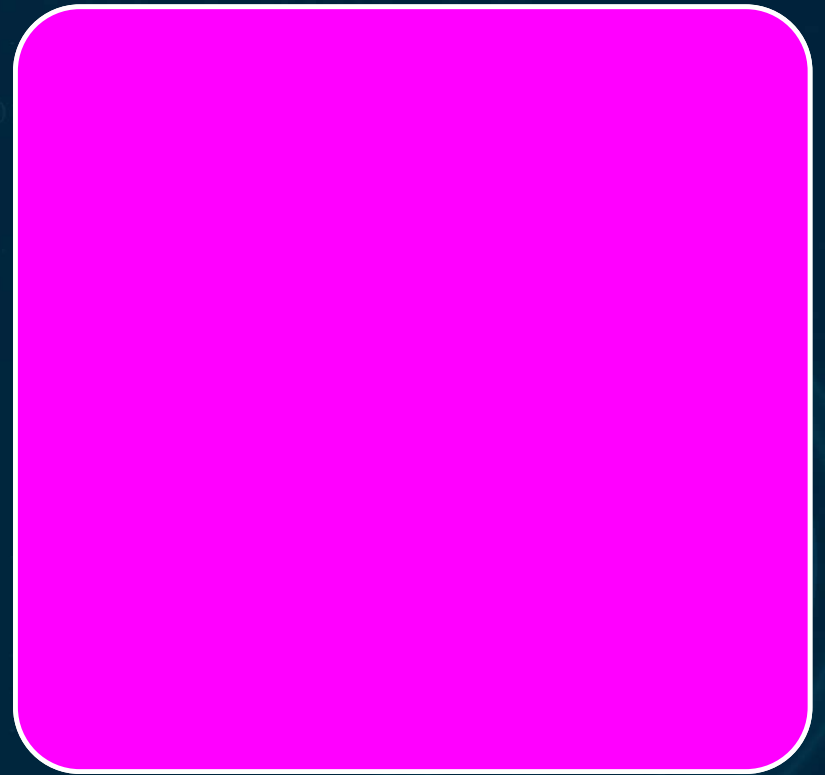
Provider + Processor —
provider + processor; DPA

3

Deployer + Controller —
FRIA + PIA (most tested)

4

Deployer + Processor —
to its own customers

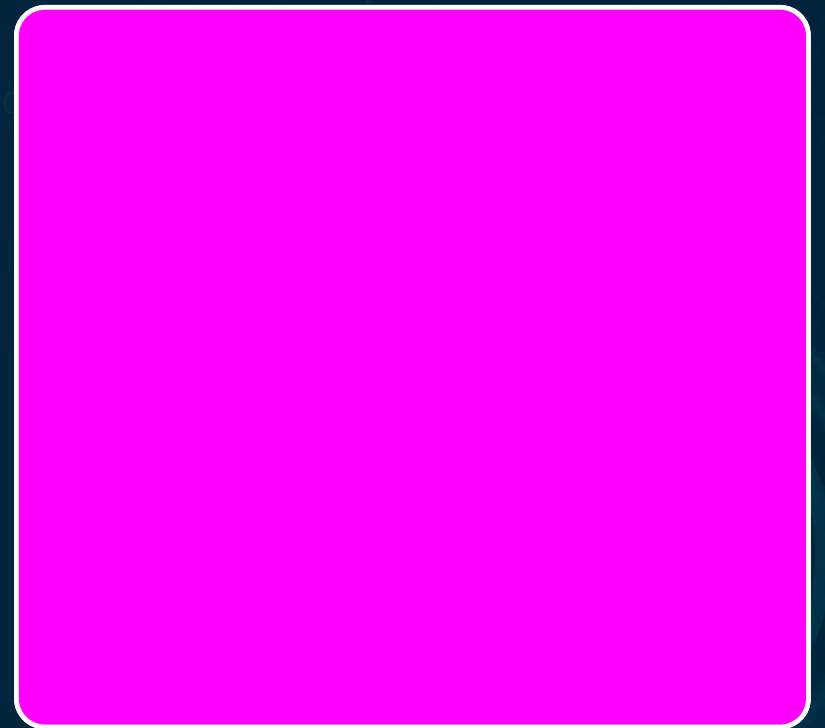


ASSESS THE TWO ROLES INDEPENDENTLY



The GDPR role does not determine the EU AI Act role

Most tested: Deployer + Controller → FRIA and DPIA

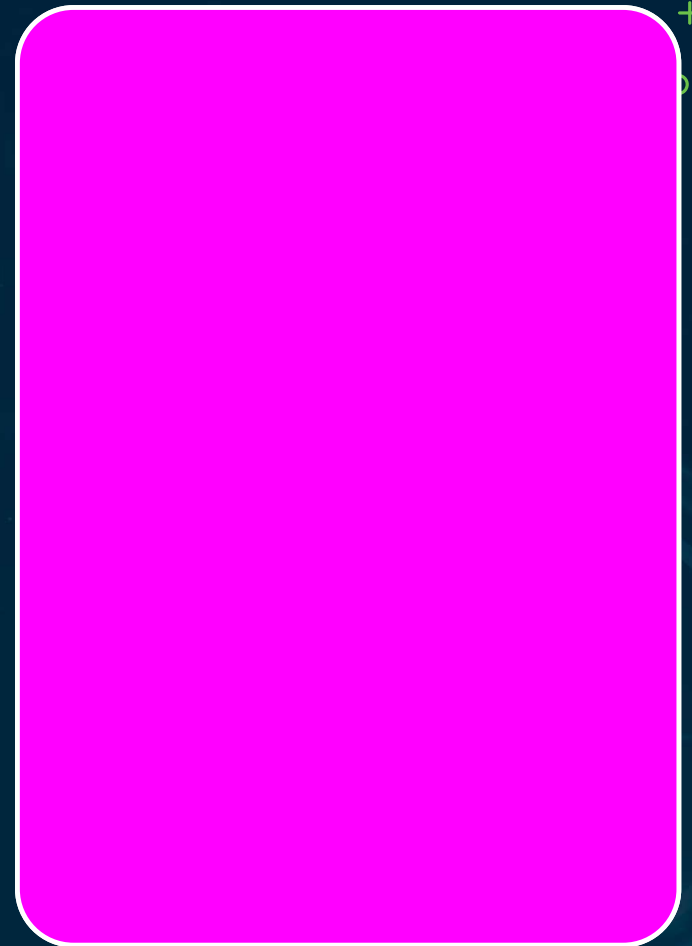


The Accountability Register

Documents the EU AI Act role for every AI system

Maps system ID, role, obligations, evidence location

Deemed-provider assessment must be documented



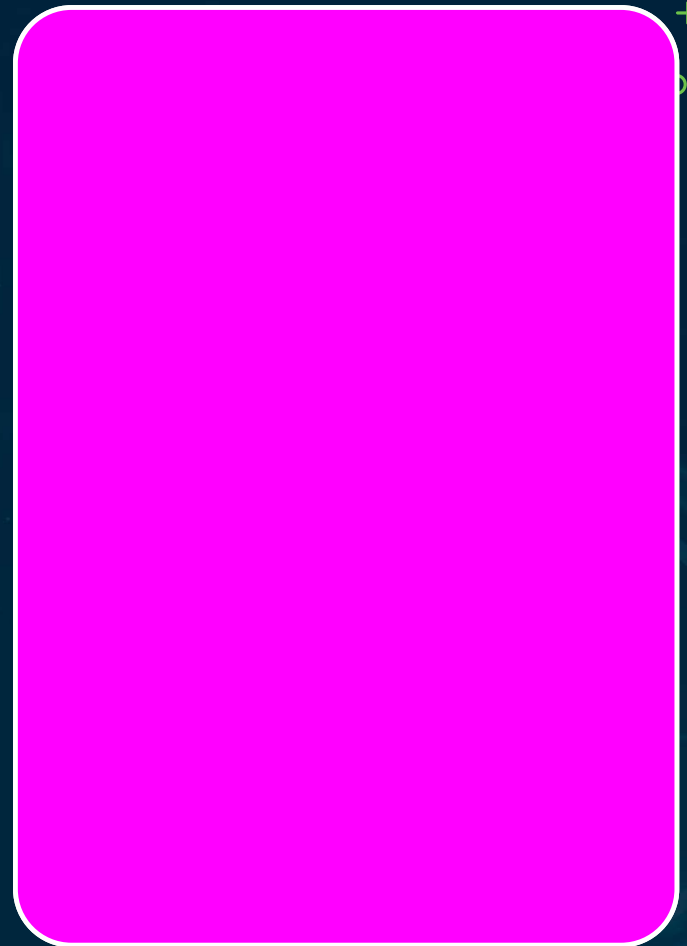
Four Accountability Failures

Deployer obligations 'transferred' by contract —
unenforceable

DPA accepted as a FRIA substitute

Deemed-provider scenario not recognized (fine-tune
+ rebrand)

Provider documentation never requested



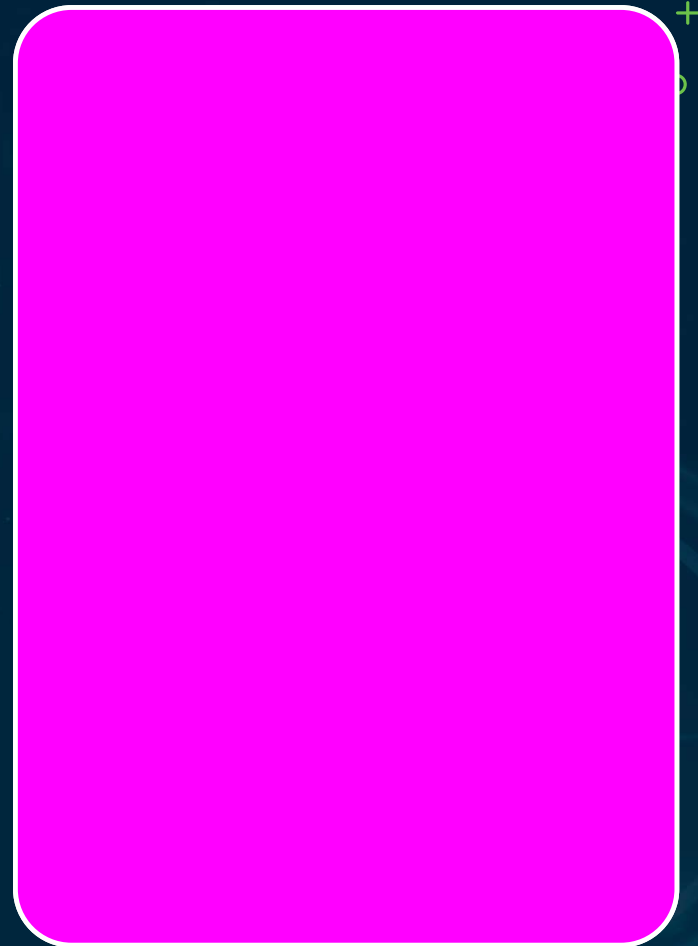
The Fixes + Recap

Deployer obligations are non-transferable — document them

FRIA is required in addition to the DPIA

Fine-tuning triggers a legal deemed-provider assessment

Determine the role first, then apply the obligation



Third, Fourth & Fifth-Party Risk

Chapter 05 · Episode 5 — Dr. Michael Solomon

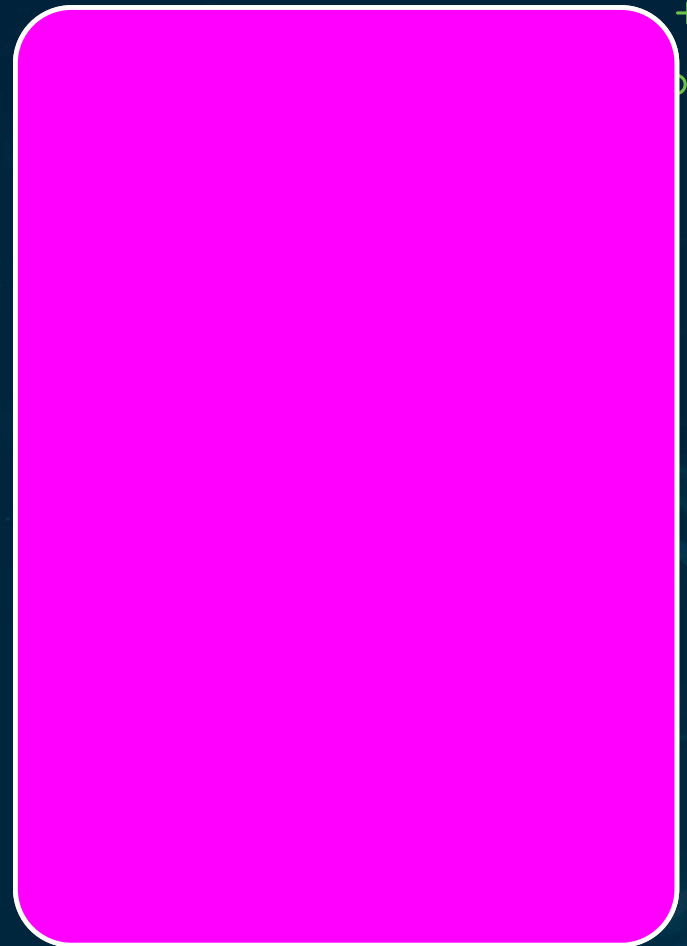


AI Supply Chains Run Deeper

Model components, training data, inference infra — separate chains

Standard DD covers third party; SBOM + disclosure reach further

AI supply chains extend two layers deeper



Supply-Chain Party Layers



2nd Party

Your direct vendor (prior episode)

3rd Party

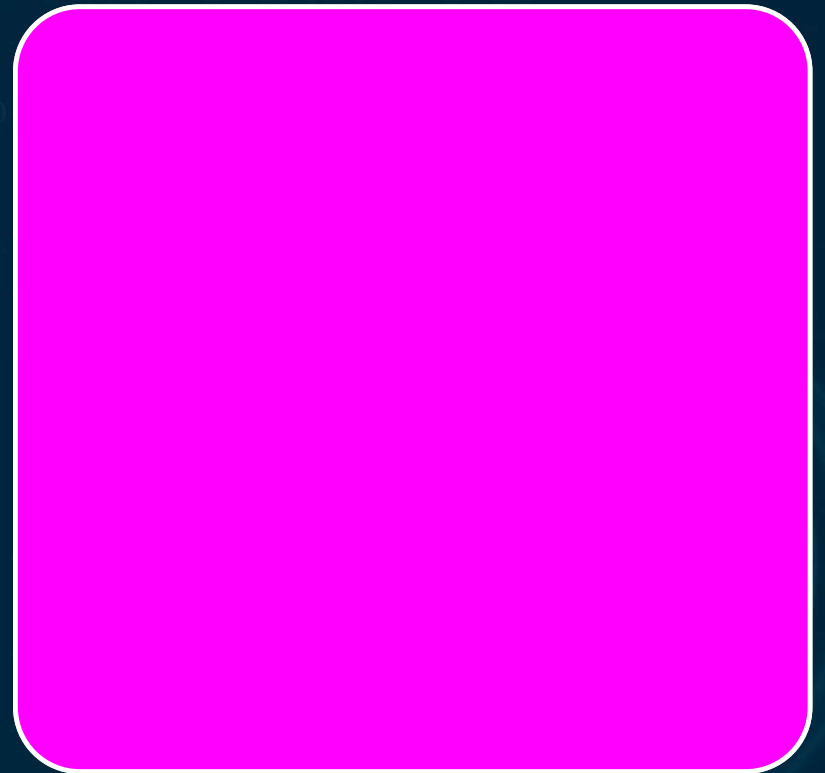
Well understood —
standard due diligence

4th Party

Your vendor's vendors —
disclosure via contract

5th Party

Vendor's vendor's vendors —
SBOM + flow-down

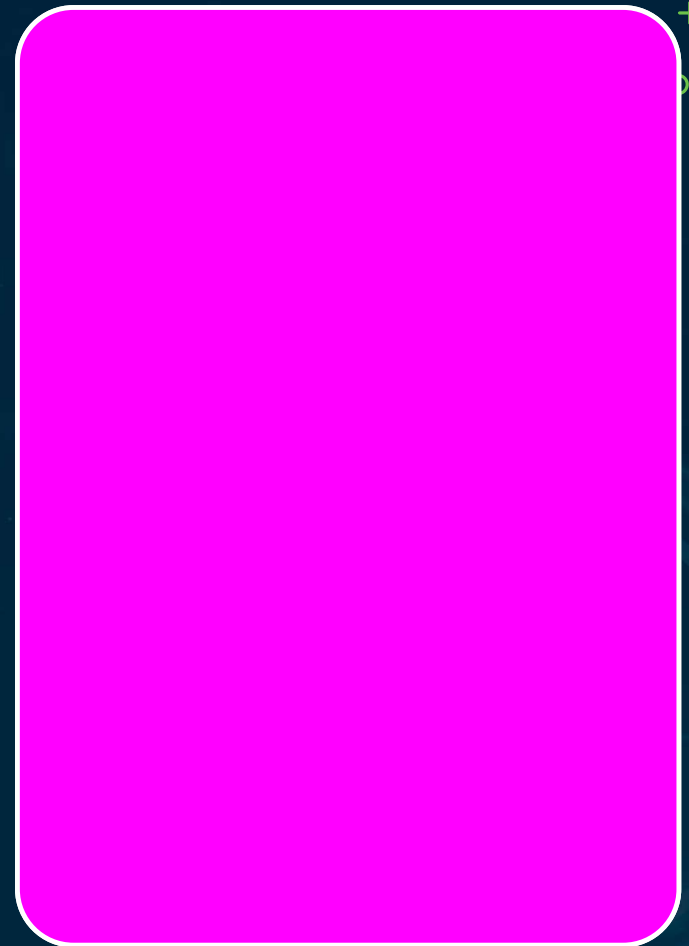


Three Supply-Chain Layers

Foundation model — disclosure +
change notification

Training data — provenance warranty across
the chain

Inference infrastructure — cloud sub-
supplier disclosure



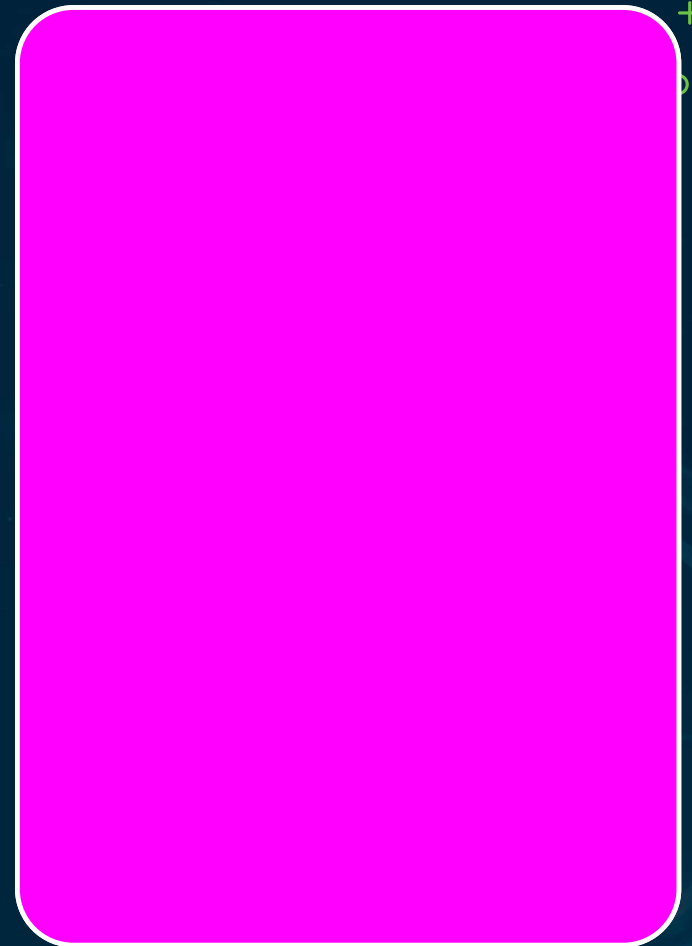
Three Visibility Mechanisms

Subprocessor disclosure — AI-specific DPA extension

SBOM requests for all AI components

Supply-chain mapping → connects to asset inventory

Incomplete mapping = governance gap tracked as a KPI

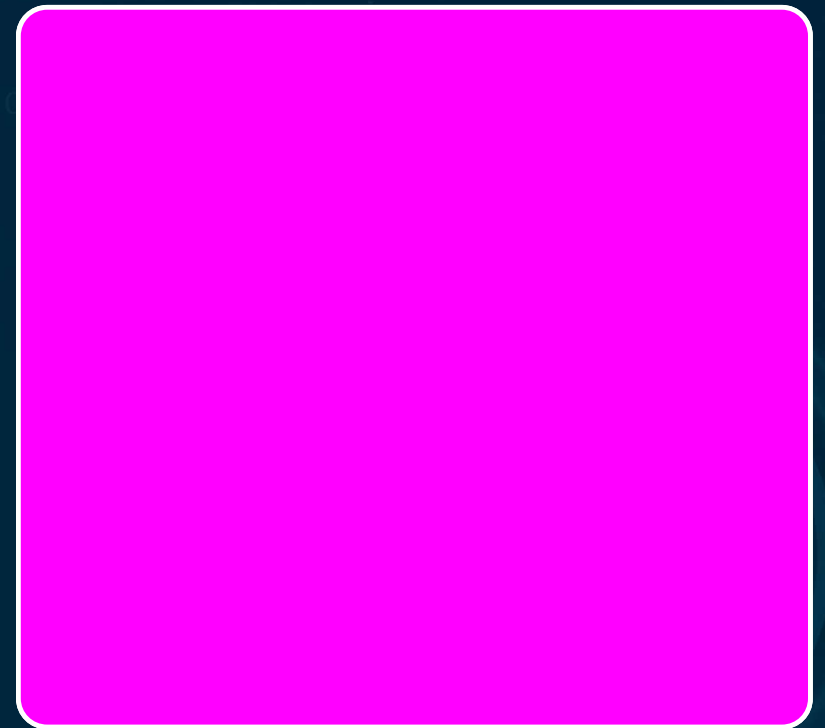


CONCENTRATION RISK

Inventory + SBOM reveals shared dependencies

Above threshold → risk-register entry +
treatment plan

Visible only when the full chain is mapped



Three Flow-Down Mechanisms



A — Obligations

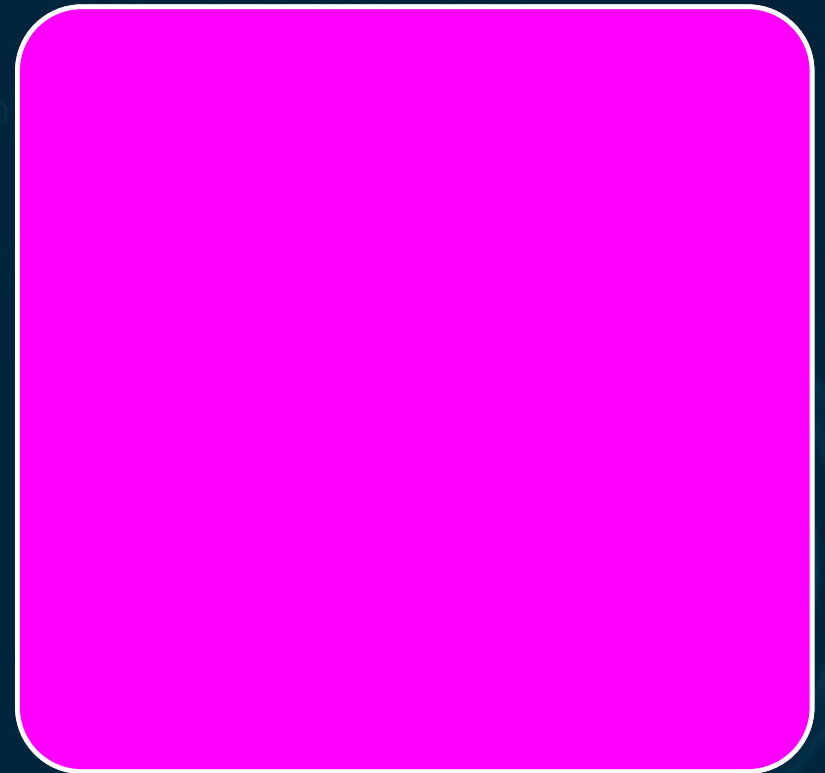
Same core obligations on sub-suppliers

B — Audit Right

Vendor audits sub-suppliers on your behalf

C — Change Notice

Prior notice before sub-supplier changes



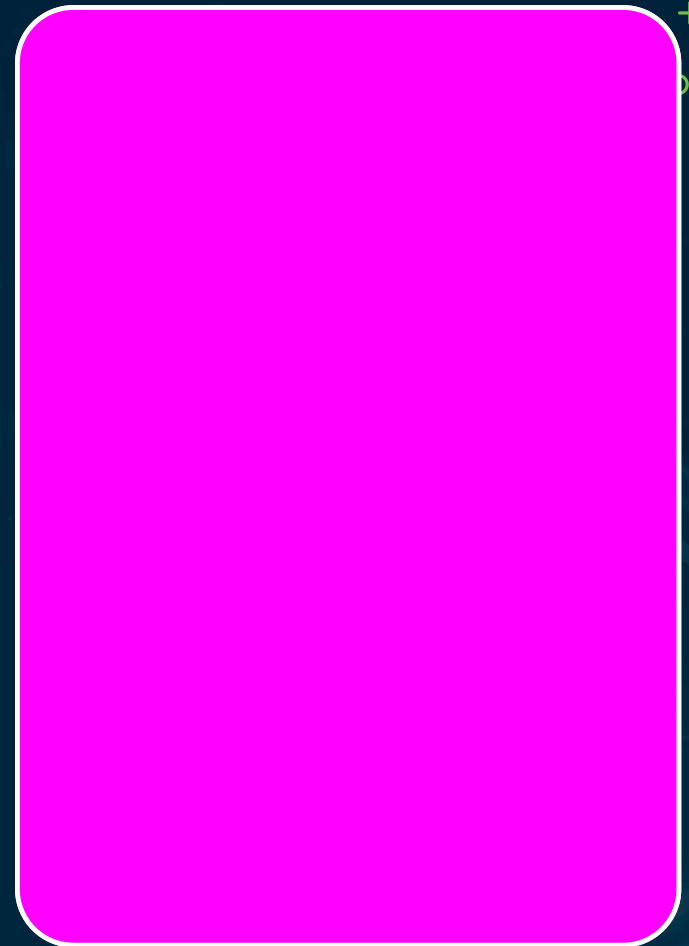
Ongoing Supply-Chain Governance

Mapping-completeness KPI tracks the obligation

Annual review: confirm disclosures + concentration in tolerance

Vendor breach / model compromise → classification process

Mapping is ongoing, not a one-time procurement step



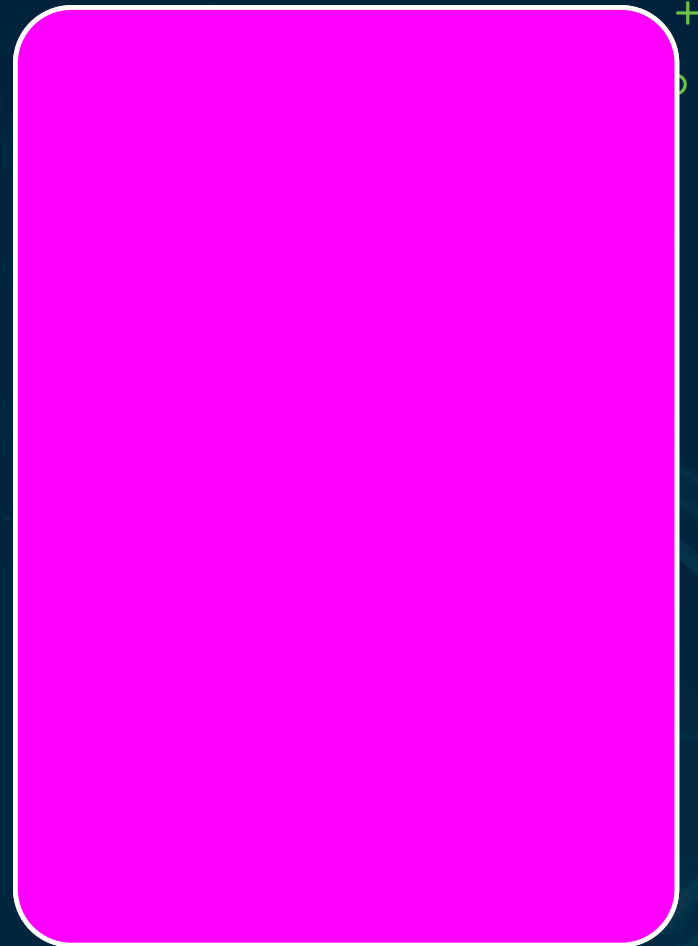
Four Supply-Chain Failures

Manage the vendor, ignore the chain

Concentration not mapped until an incident

SBOM not maintained → can't scope CVE impact in SLA

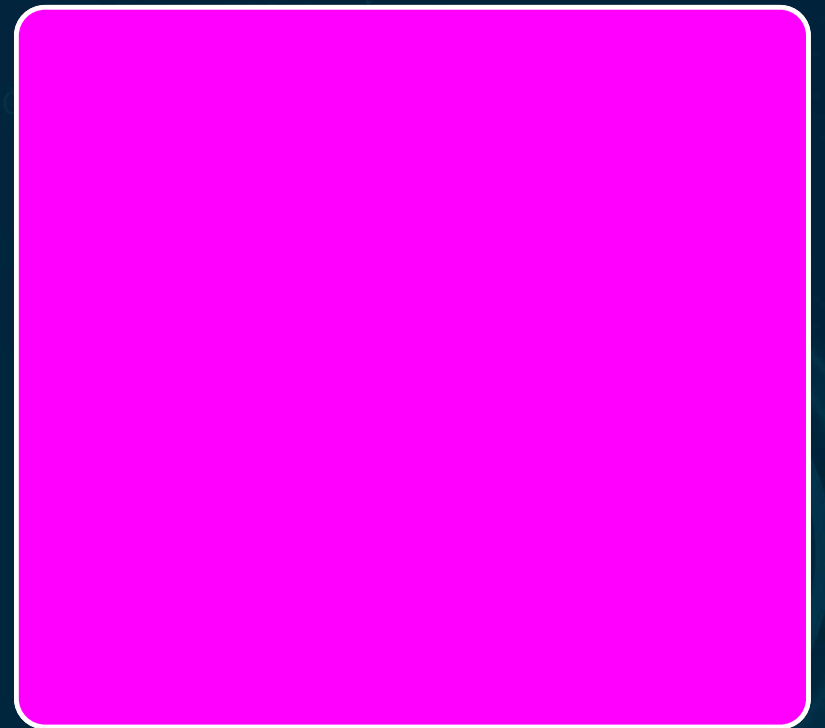
Subprocessor disclosure not contractually required



GAPS = RISK-REGISTER ENTRIES



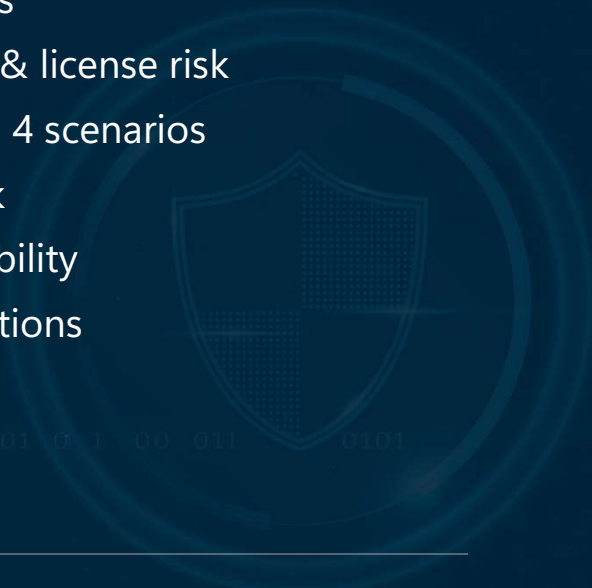
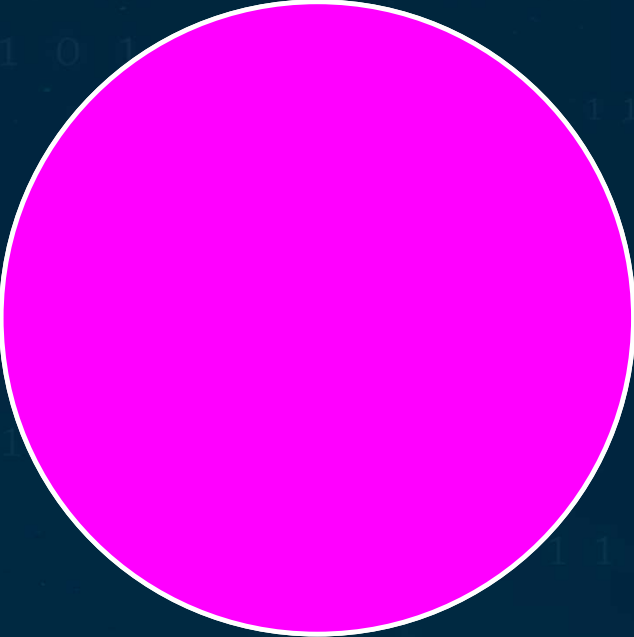
The supply-chain map is a dynamic document
Gaps are logged, not accepted as 'the nature of AI'
SBOM + subprocessor disclosure are the
most testable



IP Ownership & Liability

Chapter 05 · Episode 6 — Dr. Michael Solomon





What This Episode Covers

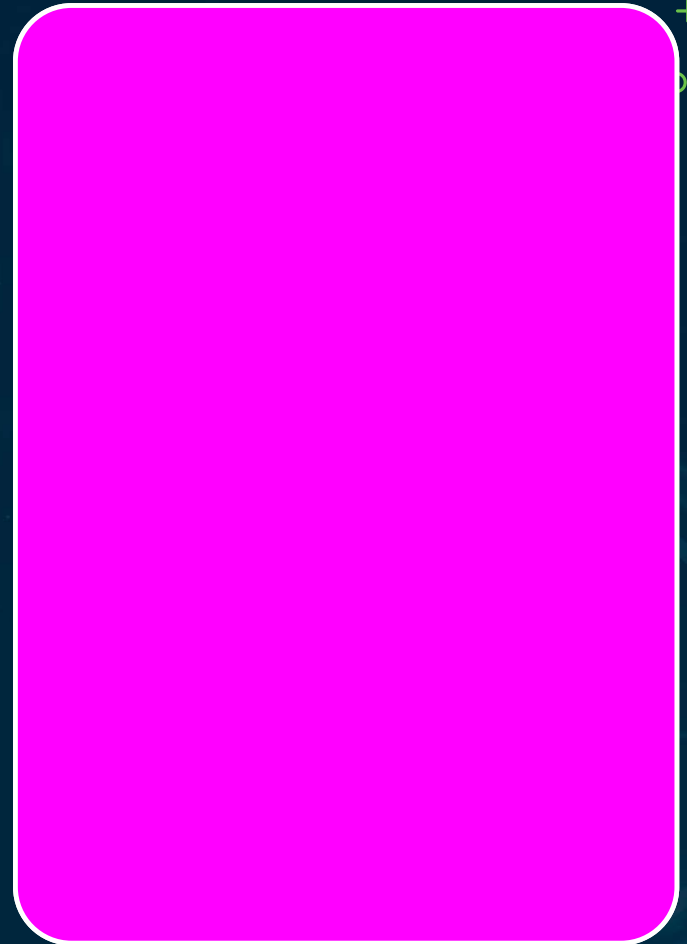
1. 3 IP ownership questions
2. Training-data copyright & license risk
3. Model ownership across 4 scenarios
4. EU AI liability framework
5. Provider vs. deployer liability
6. 6 documentation obligations
7. 4 common failures

Your Role: Ask the Questions

Ensure the questions are asked and records maintained

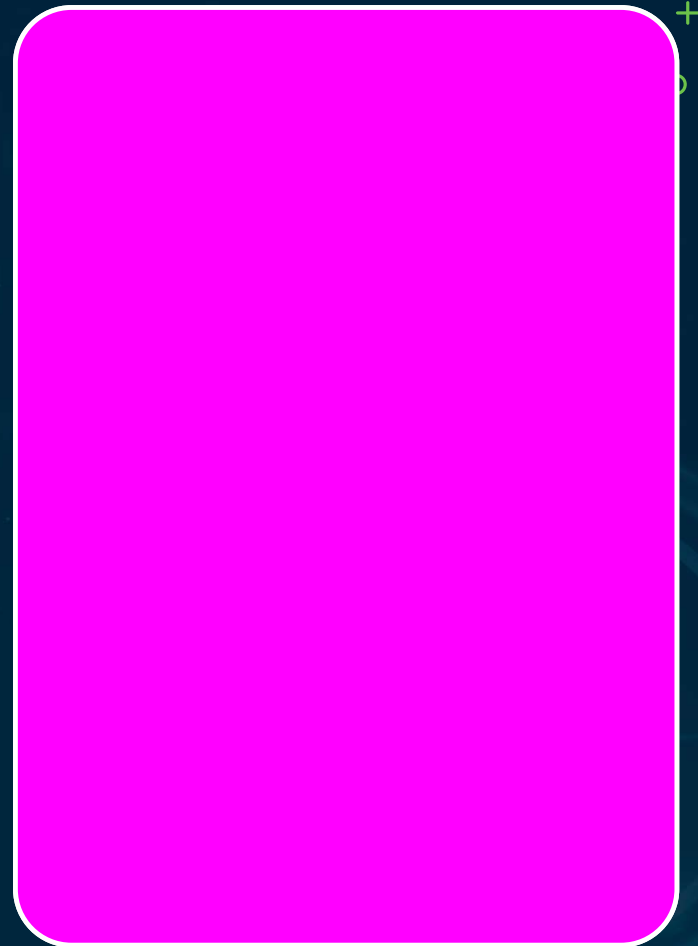
Not to perform the legal analysis yourself

Answers differ by jurisdiction



Three IP Ownership Questions

1. Who owns the training-data rights?
2. Who owns the model?
3. Who owns the AI-generated outputs?



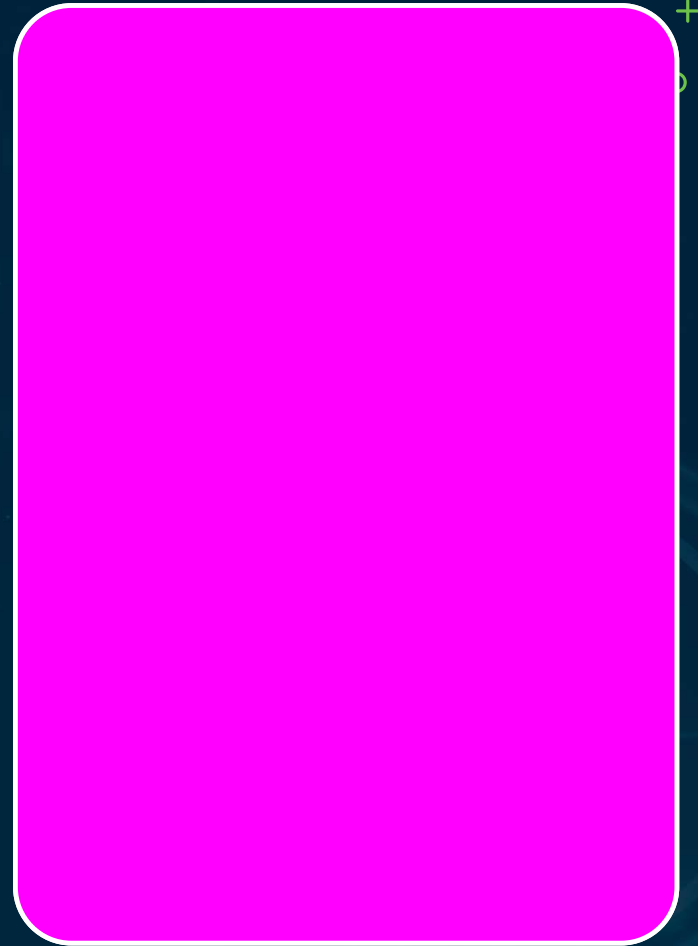
Four Training-Data IP Risks

Copyright infringement (training on protected works)

License-condition breach

Scraping ToS violations

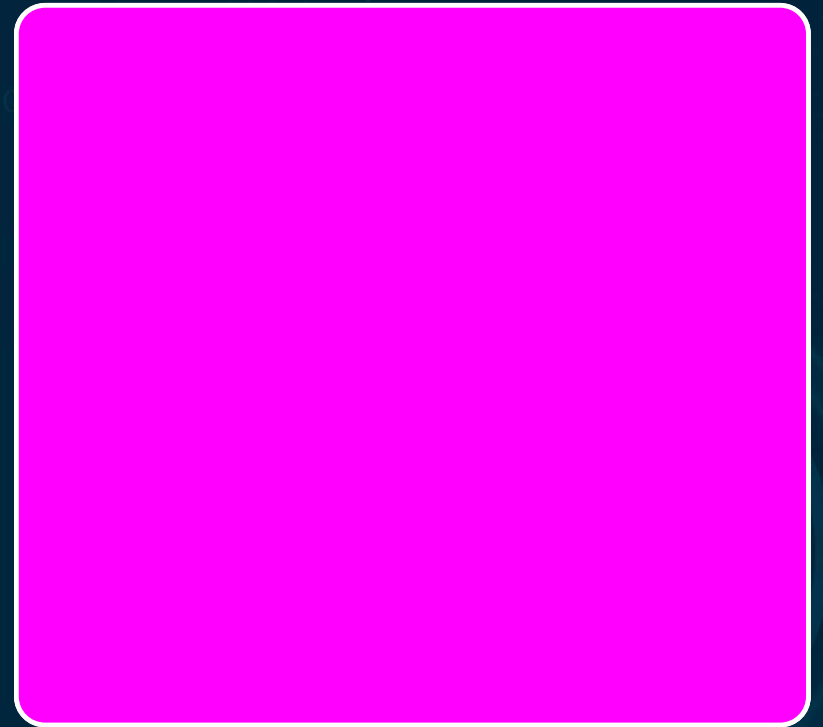
Personal data used without lawful basis



NOT A LICENSE

License register: source, license type, AI-training permission, legal basis

Publicly available $\neq$ licensed



Four Model Ownership Scenarios

Built in-house

Proprietary data — organization owns outright

Fine-tuned

Owens the weights, subject to base license

Open-source base

Copyleft — GPL may require release

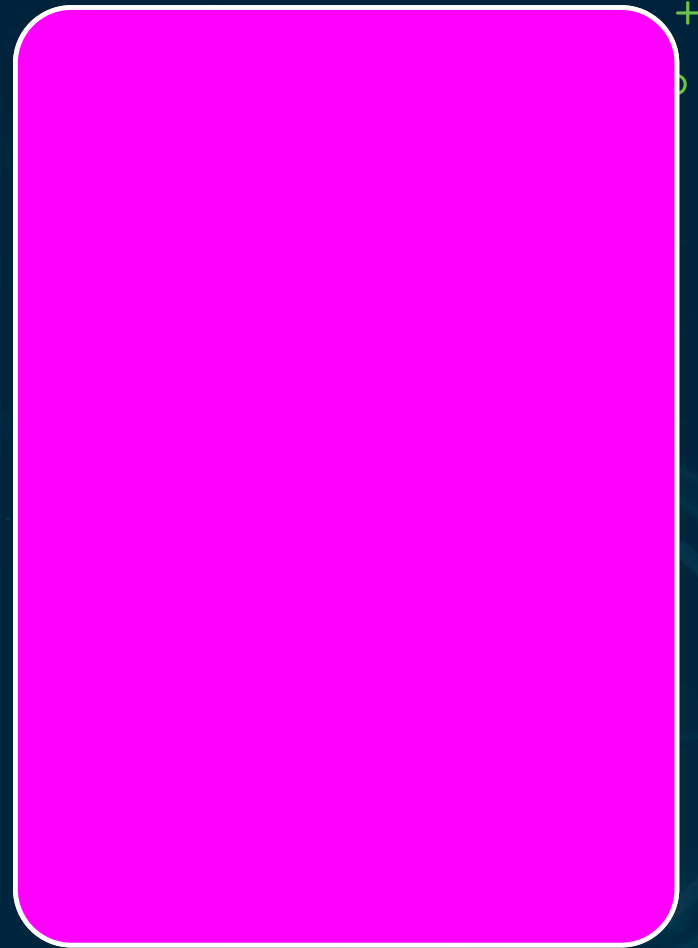
API access

Outputs owned, not the model

Model IP Assessment

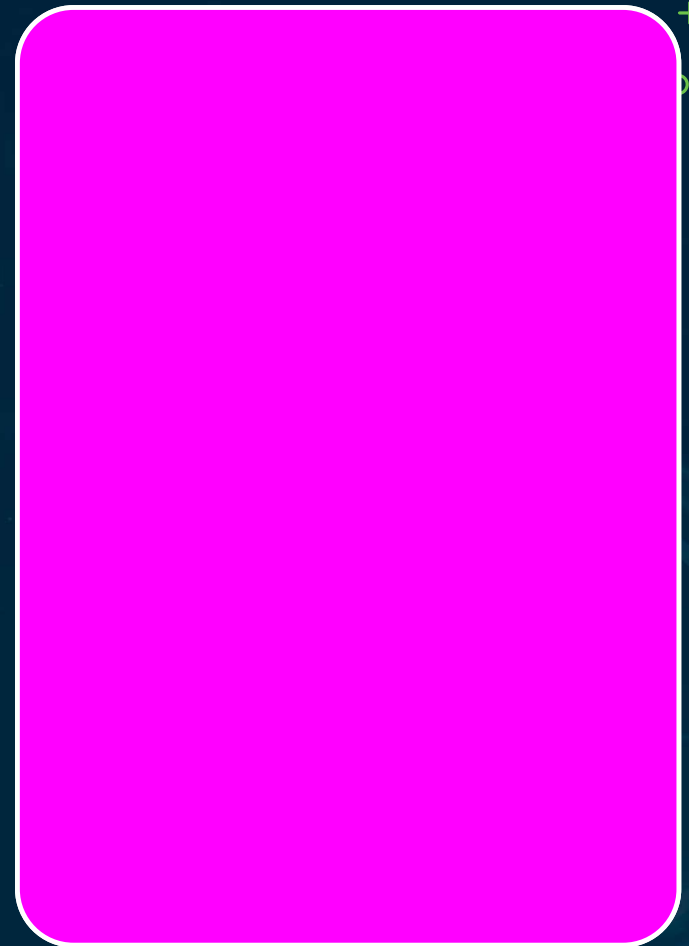
Document the development scenario + base-model
license conditions

Required for every AI system



Five AI Liability Types

1. Product liability – EU product Liability Directive
2. AI Liability Directive – rebuttable presumption
3. Negligence – developer oversight failures
4. GDPR enforcement – Article 22 violation
5. Contractual liability between parties – rebuttable presumption is the most directly testable

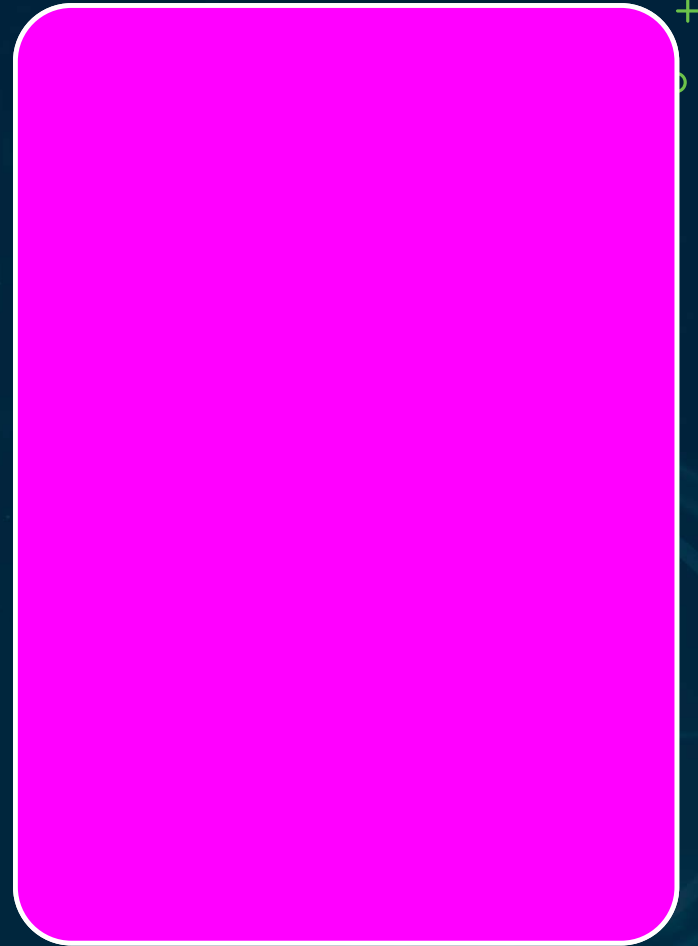


Liability Allocation

Provider bears product liability for defects

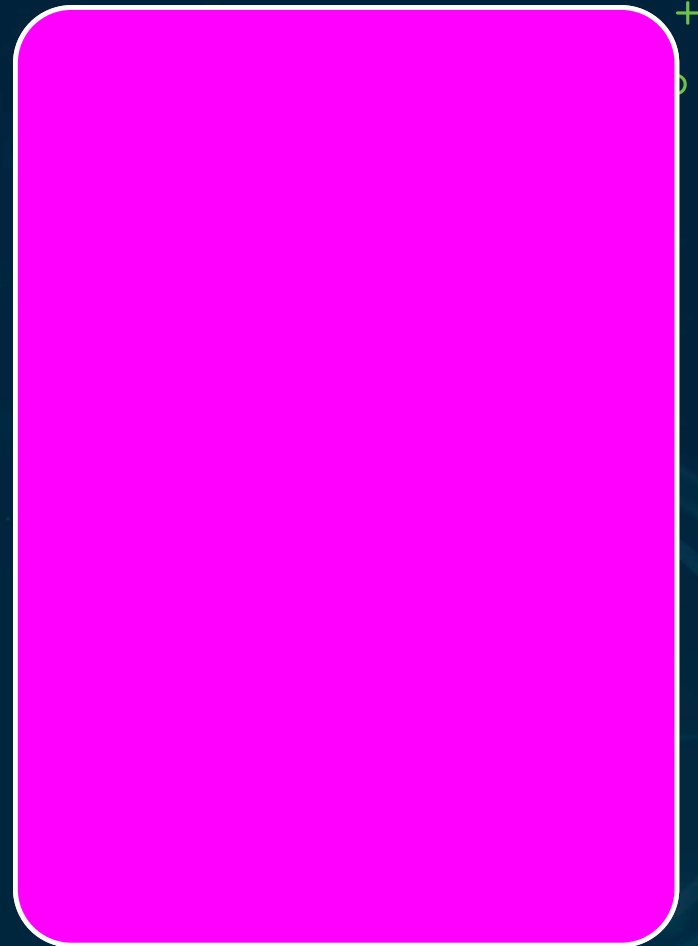
Deployer bears liability for deployment decisions

Article 22 accountability can't shift to users via ToS



Four IP & Liability Failures

- 1 License register not maintained (18 months, no entries)
- 2 "Publicly available" treated as licensed
- 3 Fine-tuning data deletion not confirmed in writing
- 4 Output ownership not addressed in customer terms



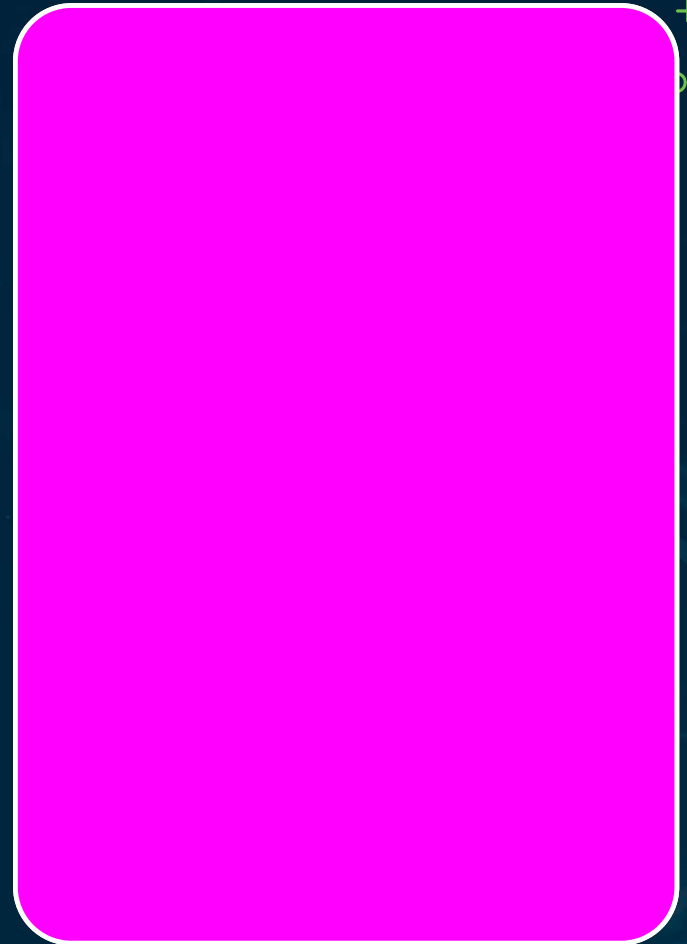
Recap · Module Close

3 ownership questions

4 model-ownership scenarios

5 liability types

Fine-tuning confirmation & "publicly available" are top exam traps



Vendor Monitoring & Risk Changes

Chapter 05 · Episode 7 — Dr. Michael Solomon

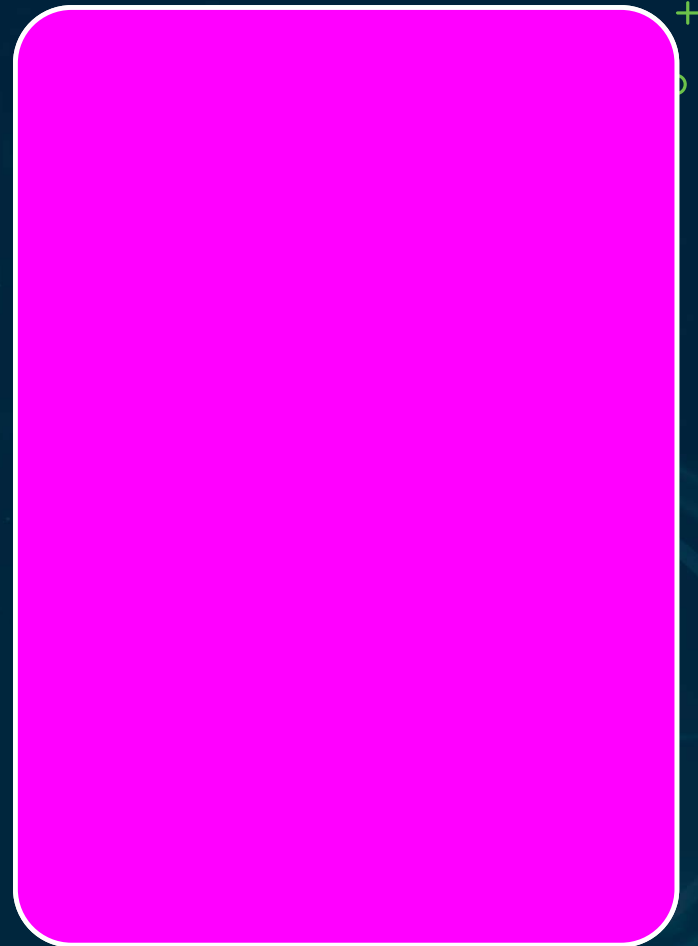


Monitoring Is Ongoing, Not Point-in-Time

Due diligence is a point-in-time assessment

Monitoring is the ongoing governance obligation

A vendor that passed two years ago may be riskier today

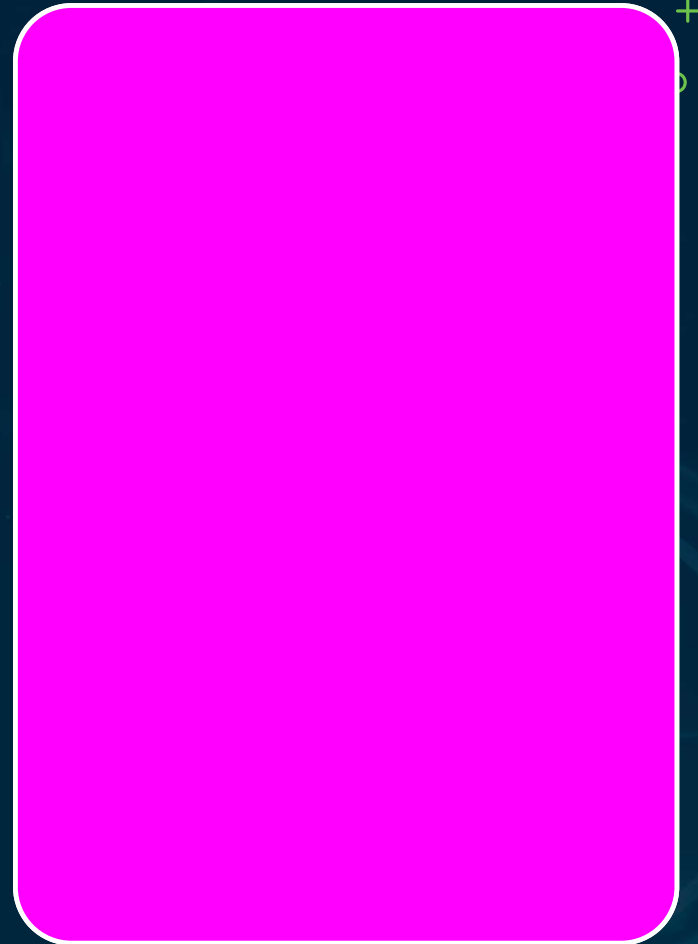


Tier-Based Monitoring Calendar

Tier 1 annual · Tier 2 biennial · Tier 3 on-event

Annual review: questionnaire, contract & incident-history check

A program-plan obligation + dashboard KPI



Five Triggered Events

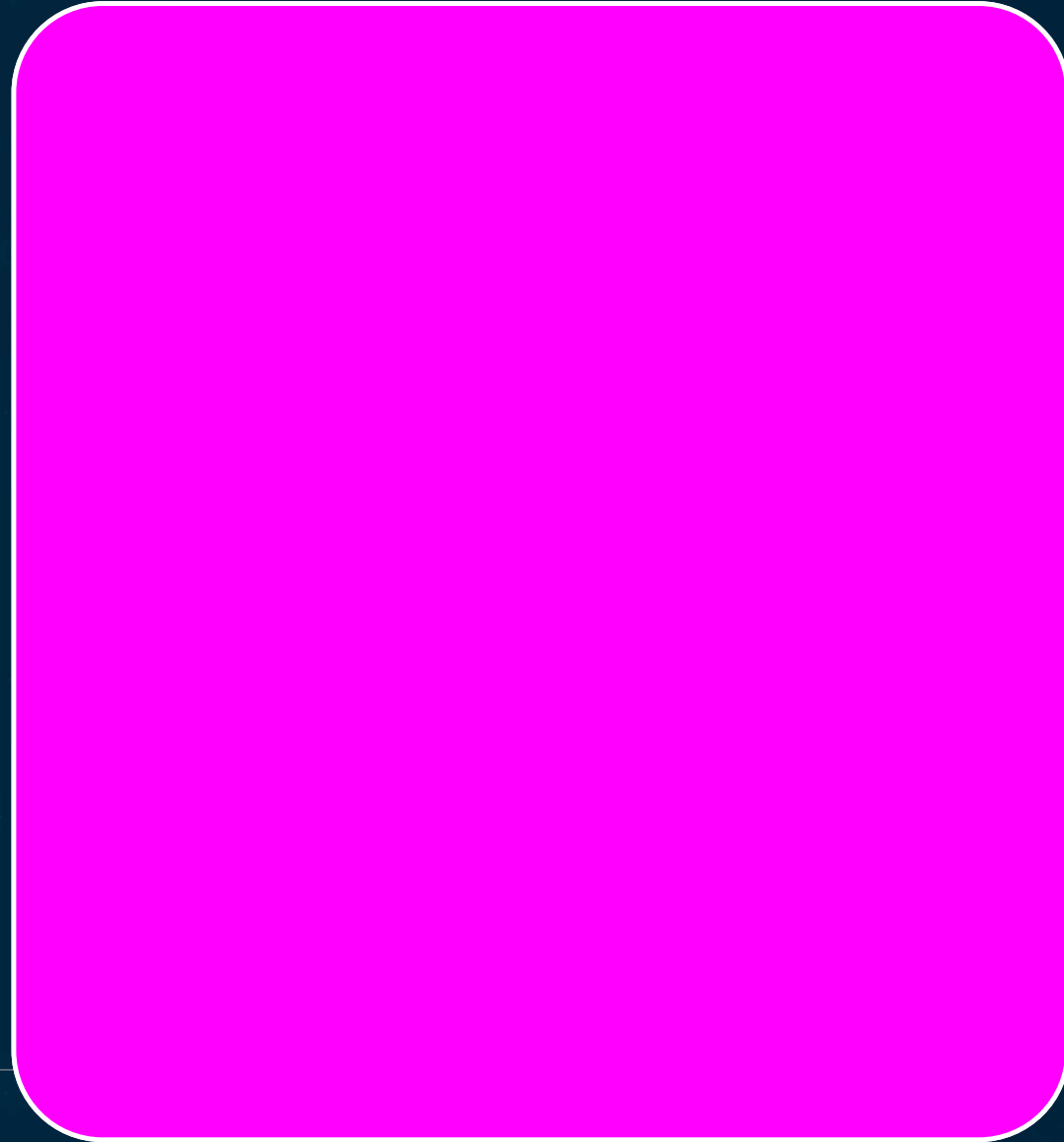
Vendor financial distress

Regulatory action against the vendor

Public incident

Leadership change

Acquisition

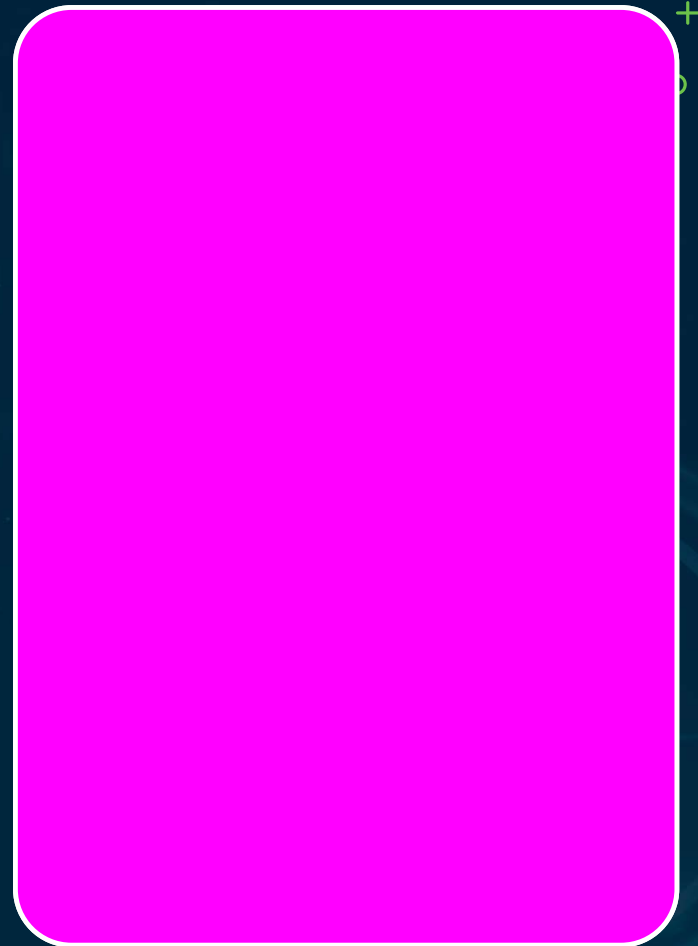


Active Monitoring Sources

Vendor reports, regulatory filings, TI feeds,
CVE databases

CVE monitoring automated via supply-
chain monitoring

Corroborate vendor self-reports — monitoring
isn't passive



Risk-Change Protocol

- 1 — Reassess the vendor's risk tier
- 2 — Update the risk-register entry
- 3 — Assess whether treatment is required
- 4 — Document the reassessment + decision

Escalation – Four Trigger Levels



L1 — In Appetite

Log in monitoring record;
no escalation

L2 — Score Up

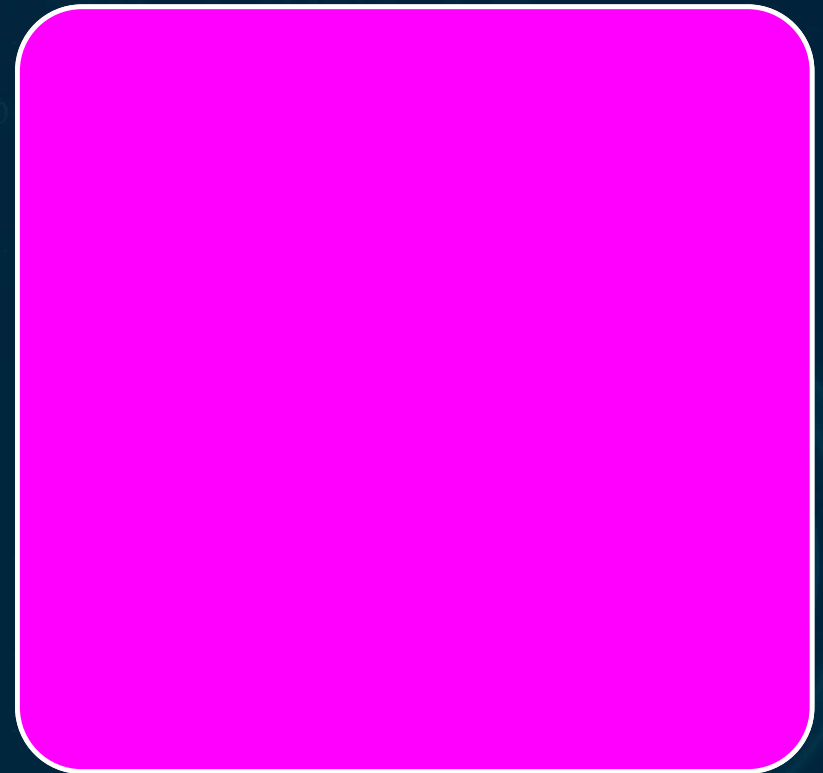
Update register; notify AI
security lead

L3 — Above Appetite

Out-of-cycle steering
cmte; interim controls

L4 — Systemic

CSO + board; act on
concentration risk



Ownership & Documentation

Framework lives in the third-party risk procedure

Ad-hoc escalation is not governance

Tier-1 overdue reviews = the primary dashboard KRI

AI compliance analyst owns the calendar; lead approves triggers

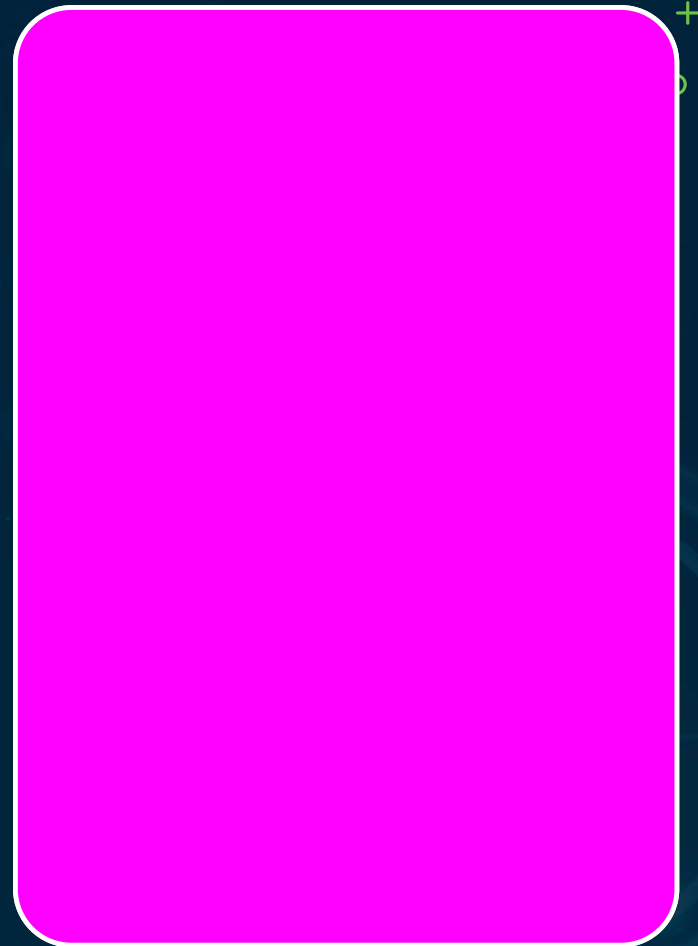
Four Monitoring Failures

Monitoring calendar not maintained (tier-1 overdue)

Triggered review not conducted (vendor acquired)

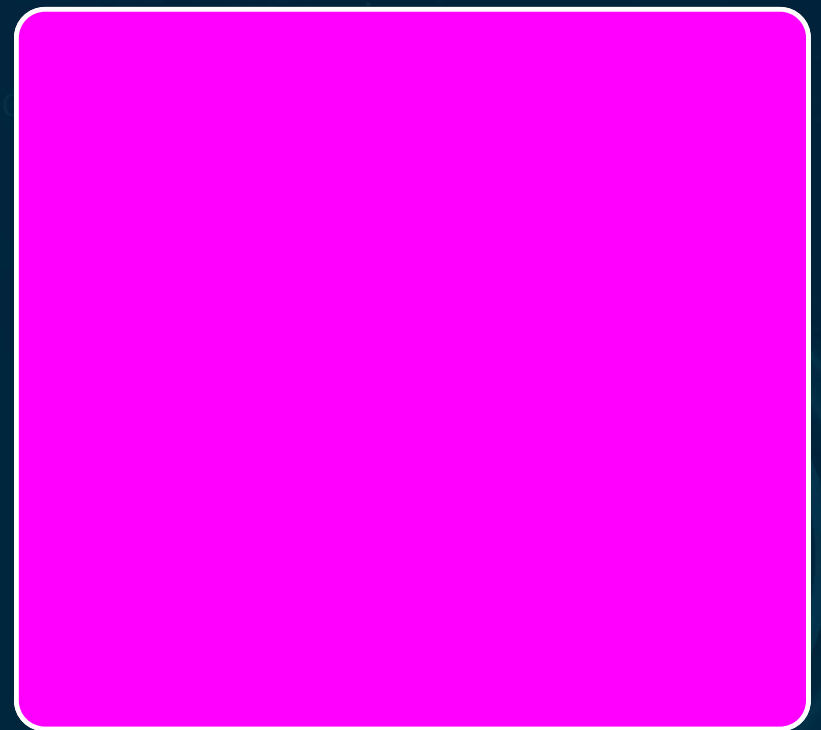
Risk change not updated in the register

Exit plan never tested



THE FIXES

- Calendar as a KPI with overdue escalation
- Five triggers documented; findings update register in SLA
- Exit plans tested in the annual BCP exercise

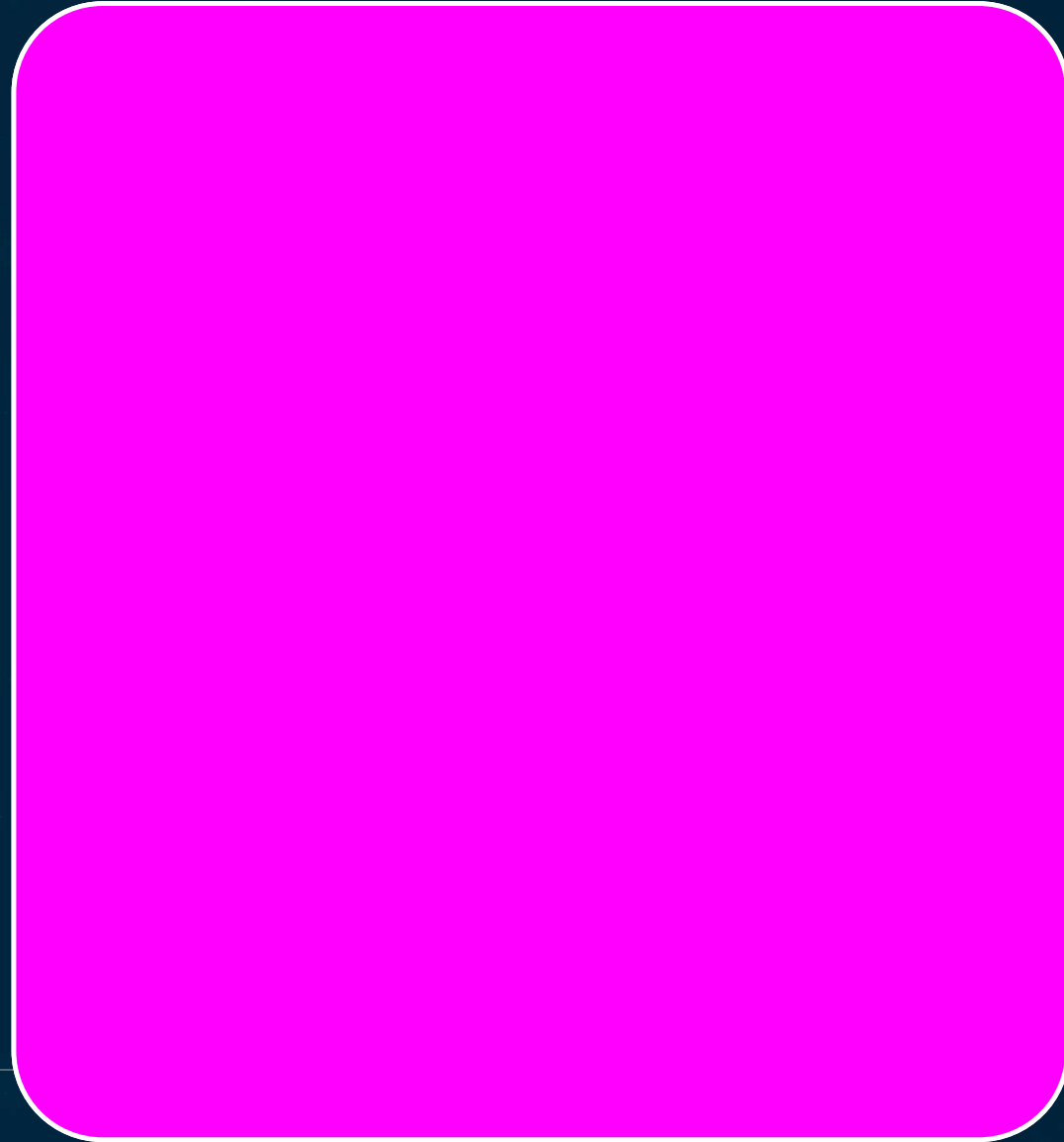


Recap · Vendor Monitoring

Monitoring keeps the third-party risk register current

Five triggers each require a governance response

Annual review includes a monitoring-completeness check



AI Security Architecture & Change Management

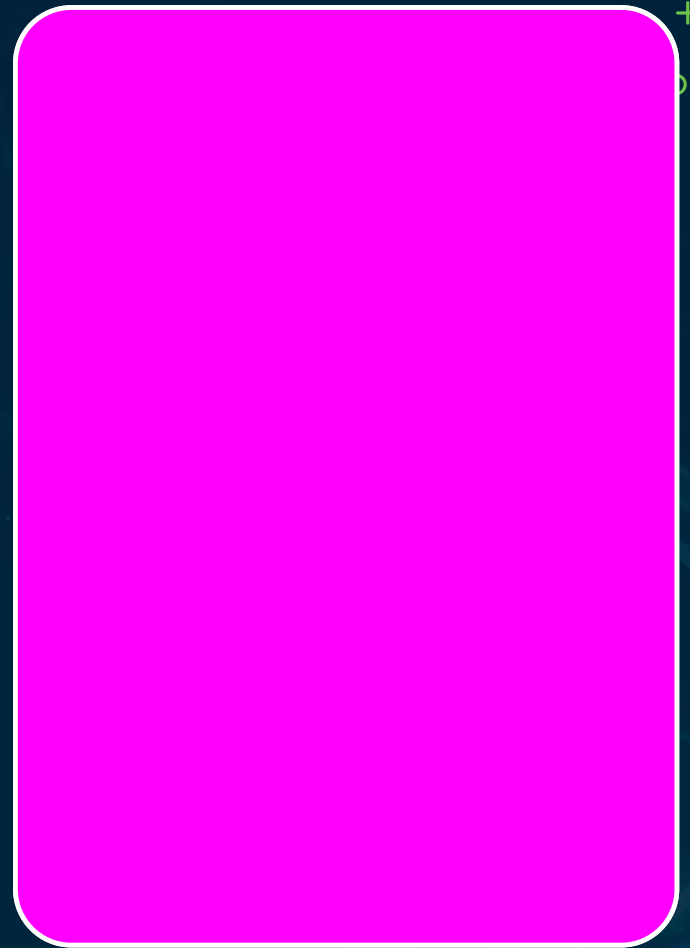
Chapter 05 · Episode 8 — Dr. Michael Solomon



Architecture + Change Management

Architecture defines what controls must be in place

Change management governs how they're maintained as it evolves



Four Architecture Layers



1 — Data Pipeline

Least privilege, integrity,
provenance logging

2 — Model Artifacts

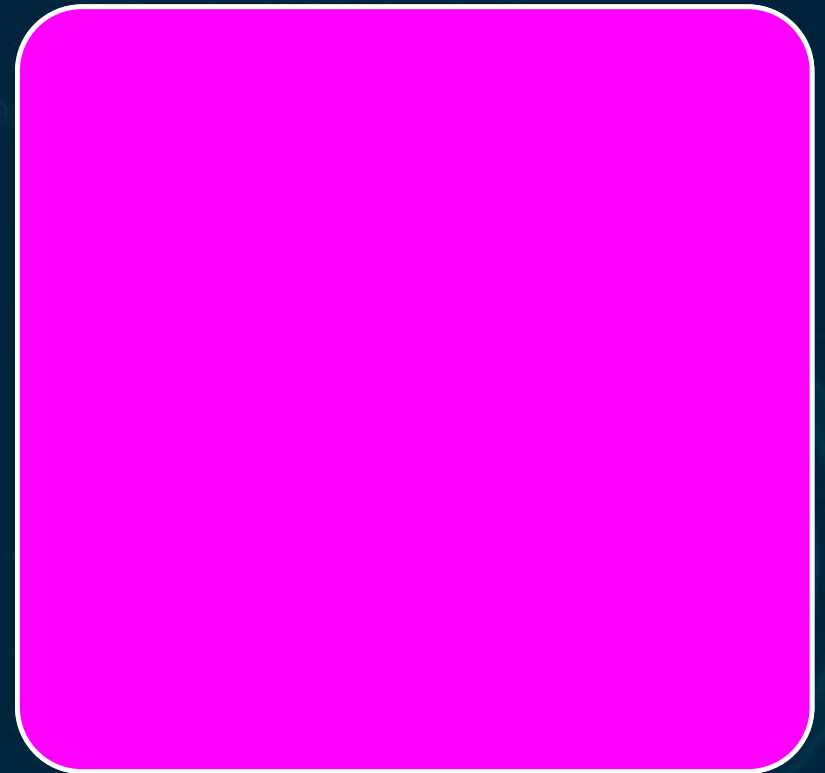
Registry MFA, signing,
version governance

3 — Inference Infrastructure

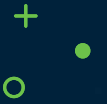
API gateway, segmentation,
injection defense

4 — Governance

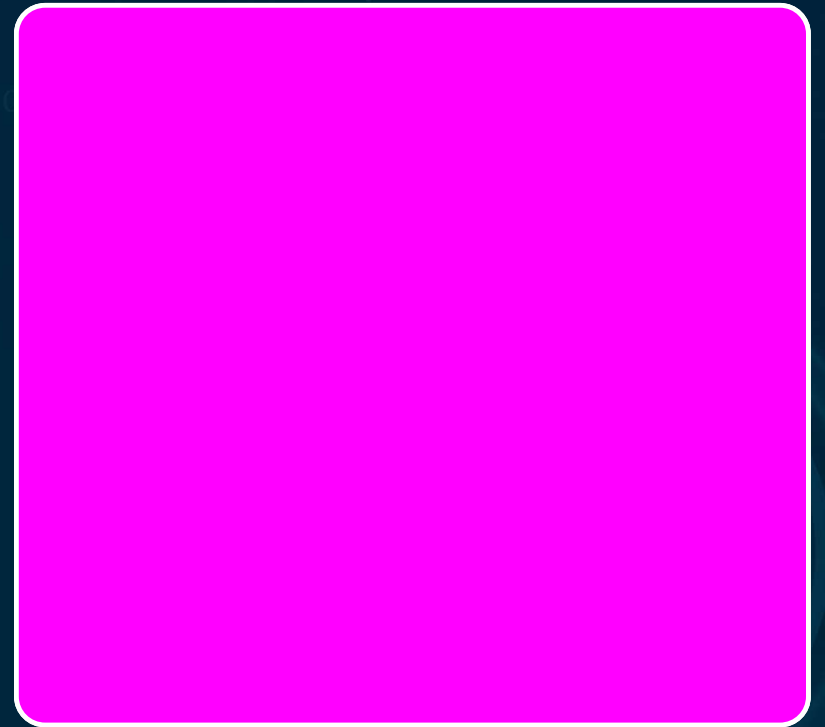
Fairness KRIs, immutable
logs, SIEM



KNOW EACH LAYER'S PRIMARY CONTROL



Four layers, each with controls
standard IT doesn't provide



Five Architectural Principles

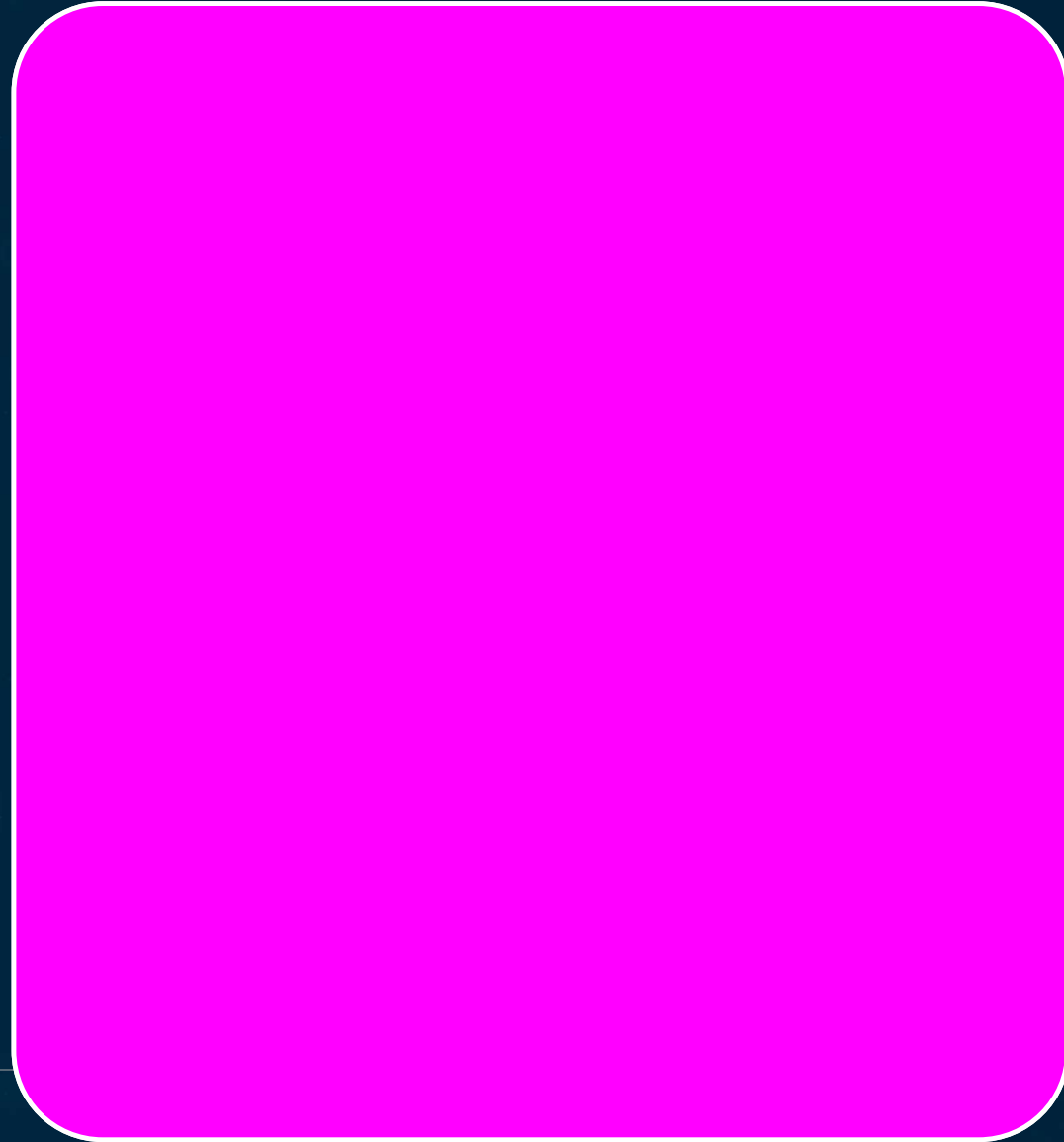
Separate training & inference environments

Least privilege across distinct AI roles

Immutable audit trails per model decision

Input validation + output monitoring

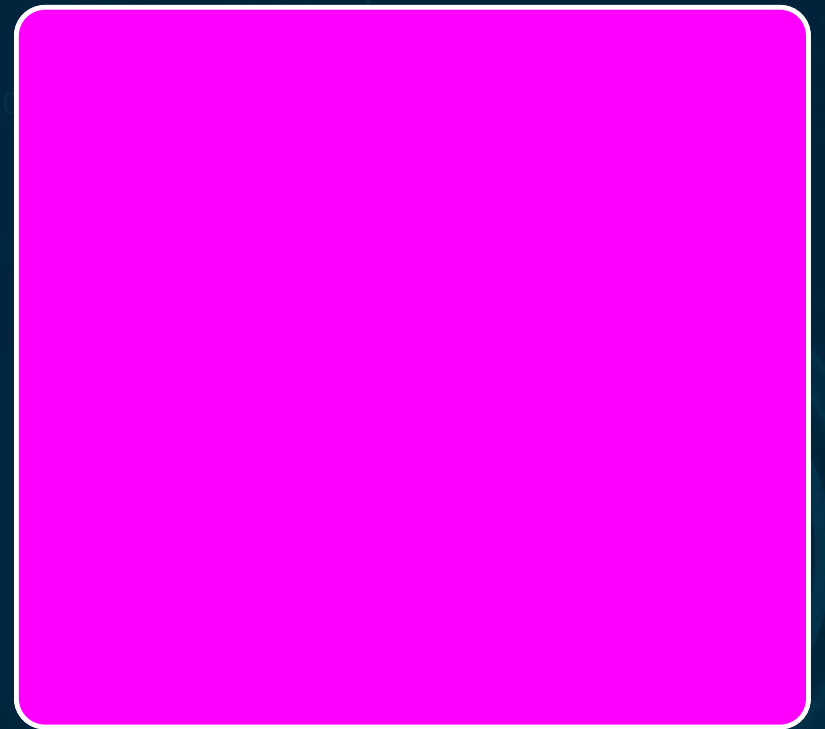
Architecture review as a deployment gate



REVIEW IS A GATE, NOT A CHECK



Architecture review is mandatory, not optional



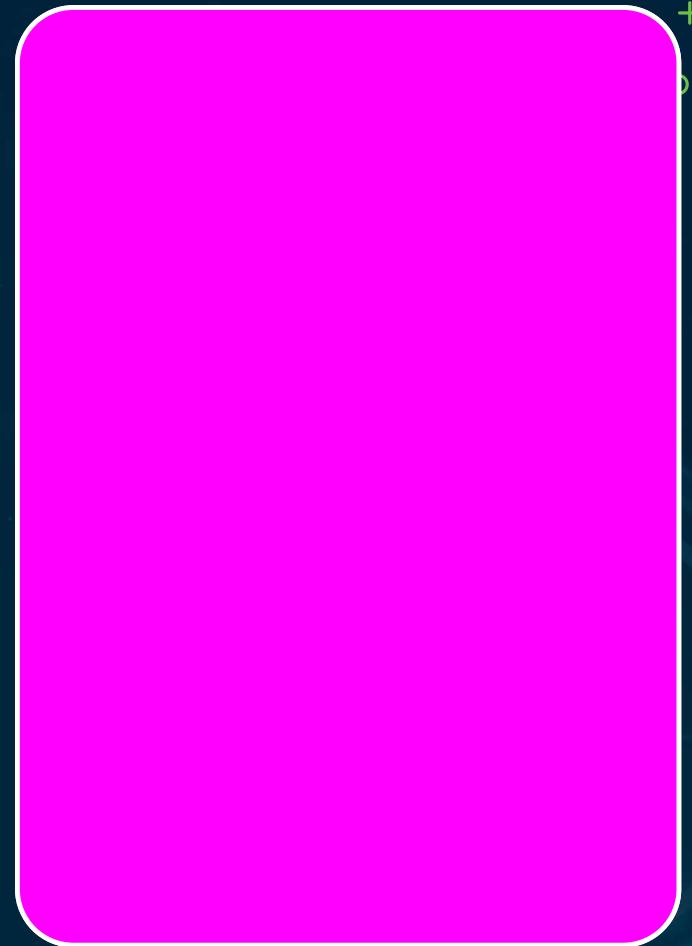
Material Change Threshold

Not every change needs full change management

Always material: weight updates that change output

New use case, new integrations

Any change to EU AI Act classification



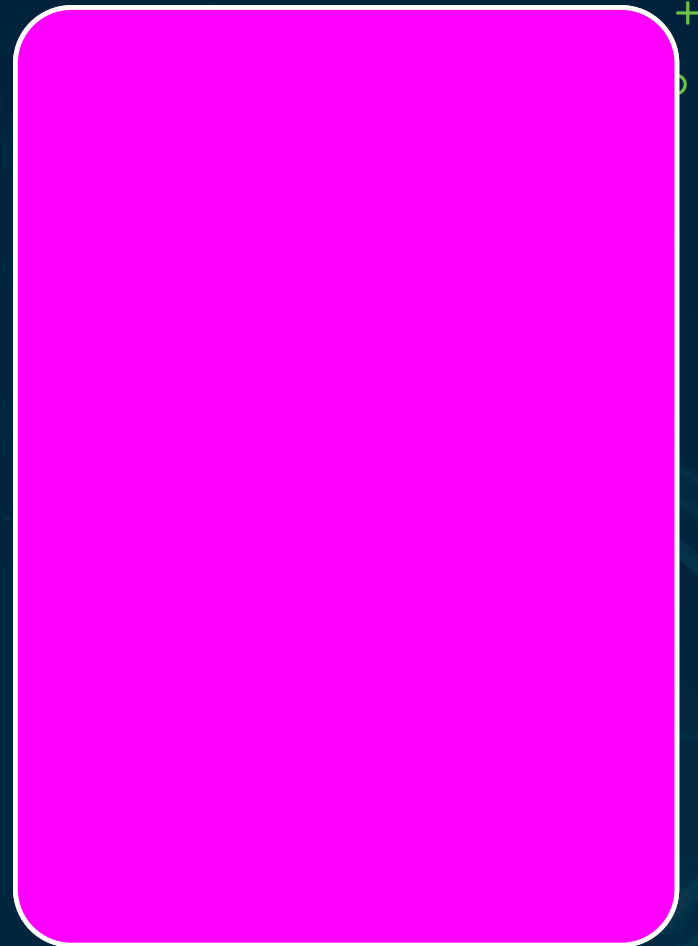
Threshold-Dependent Changes

Performance — material if root-caused to the model

Fairness — material if beyond tolerance

Hyperparameters — material if output
beyond baseline

'Substantial modification' has EU AI Act
legal meaning



Eight-Step Change Process · 1–4



1 — Identify

Change identification



2 — Impact

Technical, security,
regulatory assessment



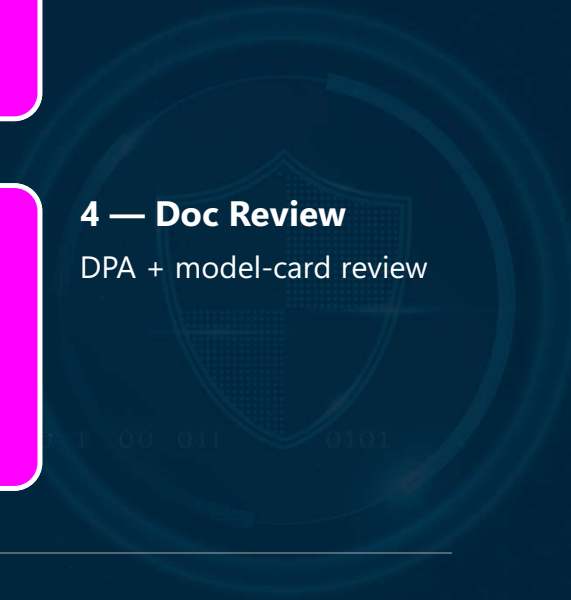
3 — Risk Register

Update affected entries

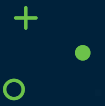


4 — Doc Review

DPA + model-card review



Eight-Step Change Process · 5–8



5 — Arch Review
Security architecture review



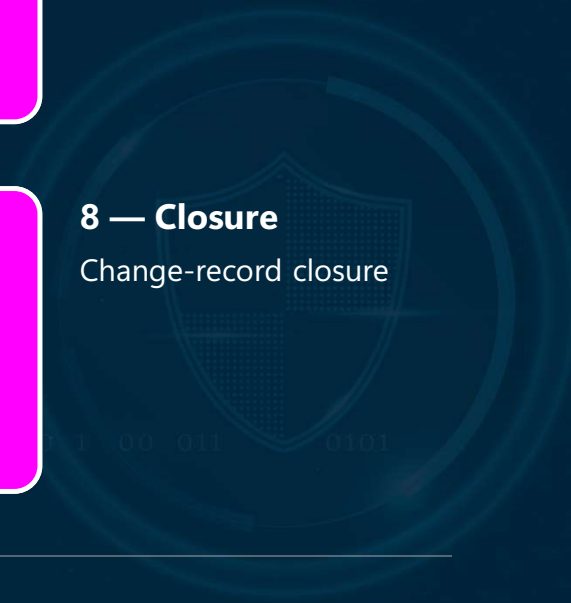
6 — Approval
Lead/CSO sign-off; legal for substantial mod



7 — Staged Deploy
Deploy with testing



8 — Closure
Change-record closure



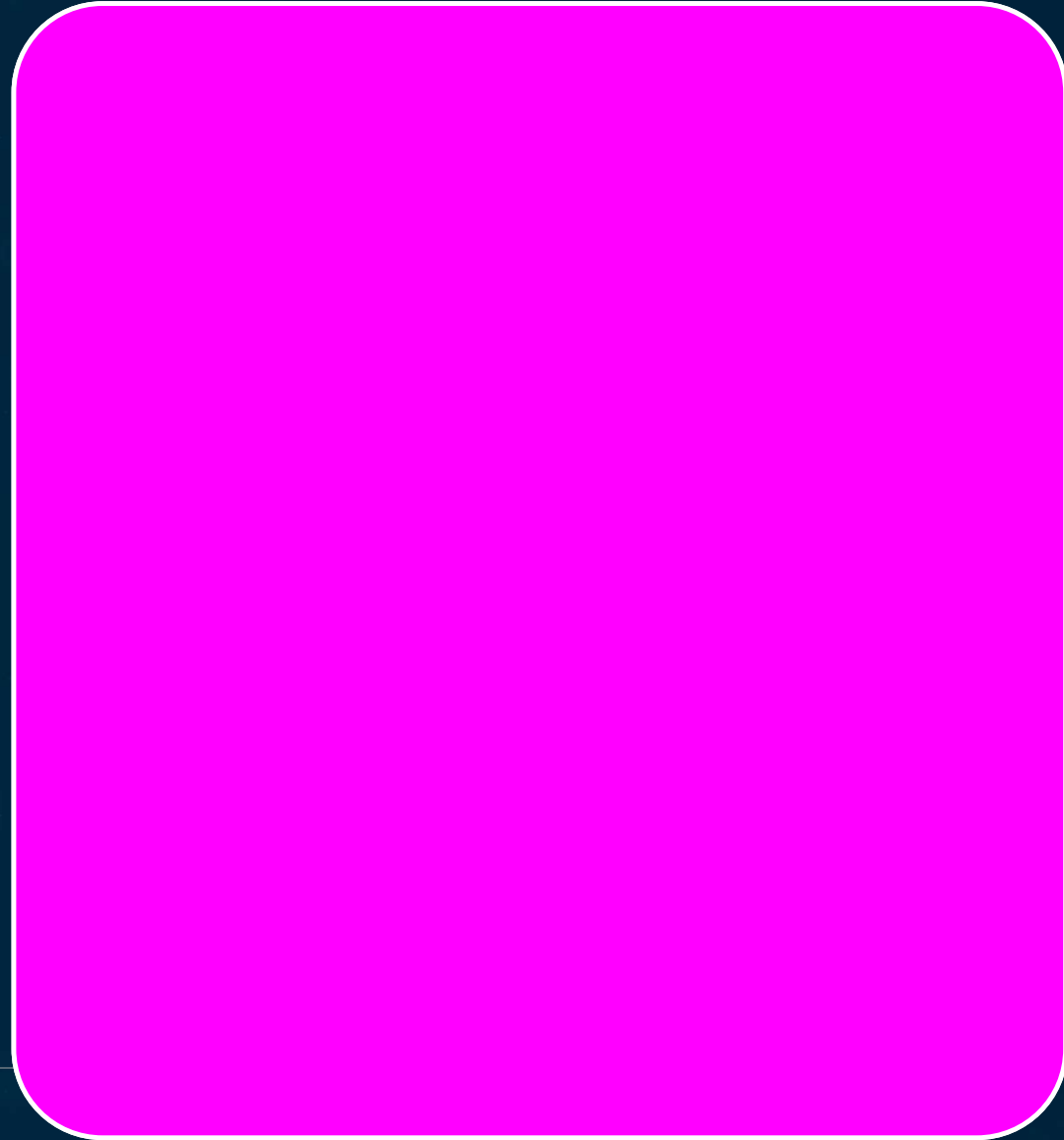
Emergency Change

Bypasses normal flow — but stricter post-change governance

Four qualifiers: active incident, CVE exploit, regulatory, rollback

Verbal approval documented; retrospective within 48h

High frequency signals a process bottleneck

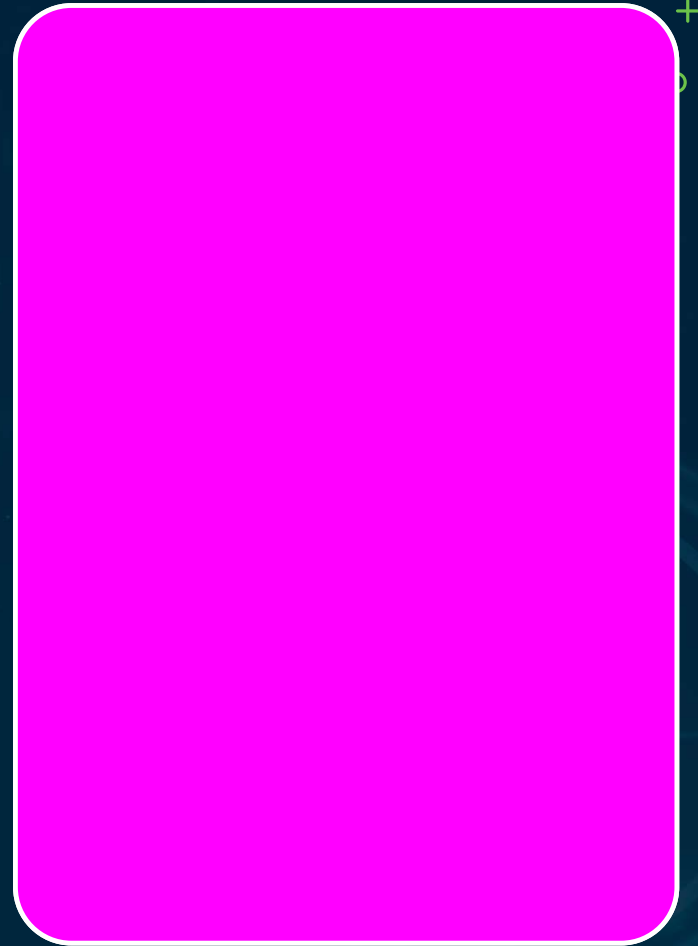


Eight-Check Architecture Review

Data pipeline, registry, inference endpoint,
output monitoring

Audit logging, DPA current, model card, risk
register clean

Every check is binary — 'mostly' doesn't pass



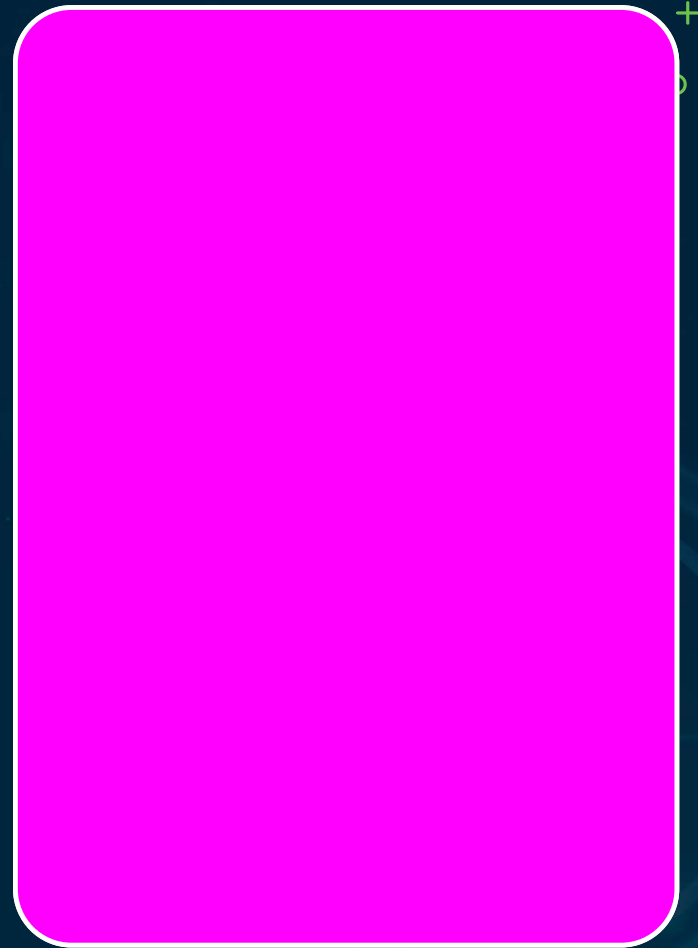
Four Architecture Failures

Training & inference not separated

Model update treated as a software patch

Architecture review skipped for speed

Emergency change used to bypass governance



Recap · Module 5 Finale

Four layers + five principles

Material-change framework + eight-step process

Emergency criteria + eight-check review gate

Legal required for substantial modifications

